République du Cameroun

Université de Yaoundé II

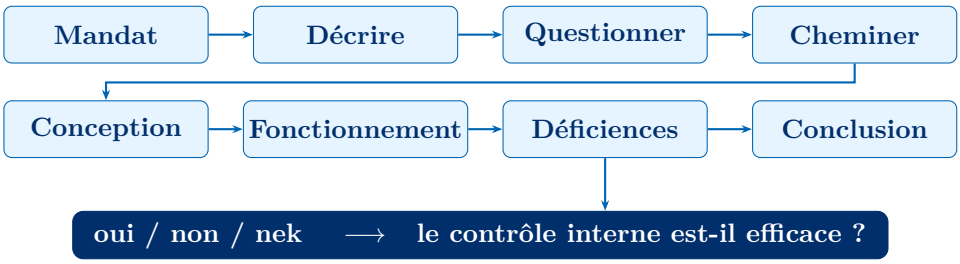
Programme Supérieur de Spécialisation en Finances Publiques (PSSFP)

Master professionnel en finances publiques · Spécialité Audit et Contrôle · Niveau 5

Contrôle et Audit des Systèmes d'Information

Évaluer le contrôle interne des finances publiques dans un environnement numérique

CASI - UE CAS3401



MINKA MI NGUIDJOÏ Thierry Emmanuel

Enseignant Chercheur | LIMSI | ENSPY

Intervenant au PSSFP · Université de Yaoundé II

maletyon@proton.me

Année académique 2026–2027

Version 0.1 | Document pédagogique de l'UE CAS3401

AVANT-PROPOS

> « Le contrôle interne ne disparaît pas quand l'administration s'informatise ; il change de place, et l'auditeur doit le suivre. »
>
> *Principe du cours*

Ce cours s'adresse aux auditeurs et aux contrôleurs des finances publiques du Programme Supérieur de Spécialisation en Finances Publiques. Ils connaissent déjà le contrôle sur pièces : le mandat, la dépense, la régularité, le contradictoire. Ils vont désormais exercer devant des applications de budget, de dépense, de paie et de recette, où la pièce est un enregistrement, la signature un droit d'accès, et le visa un contrôle automatique.

Il repose sur une conviction : l'informatique ne supprime pas le contrôle interne, elle le déplace. La séparation entre l'ordonnateur et le comptable devient une matrice de droits ; la vérification du service fait devient un contrôle de saisie ; l'archive devient une sauvegarde. Un auditeur qui continue de ne regarder que le dossier papier ne voit plus qu'une partie du système. Le cœur du cours est donc le **système de contrôle interne** et son **évaluation** : le décrire, le tester, classer ses déficiences, conclure sur son efficacité.

Le cadre camerounais. Au Cameroun, dans le secteur public, c'est le Contrôle Supérieur de l'État qui a la compétence explicite du contrôle des systèmes d'information : son texte organique, le décret n° 2013/287 du 4 septembre 2013, la range parmi les cinq contrôles qu'il effectue. L'ANTIC conduit les audits de sécurité des réseaux et systèmes d'information au titre de la loi n° 2010/012. La Chambre des Comptes, juge des comptes publics, peut s'y retrouver par extension, à travers les comptes que ces systèmes produisent. Le Chapitre 4 précise ces compétences.

Ce que ce cours n'est pas. Il n'est pas un cours d'informatique, ni une préparation à une certification, ni un cours de sécurité offensive. Il ne demande aucun prérequis technique : un tableur suffit pour les labs.

Ce que ce cours est. Un traité de quinze chapitres, en six parties précédées d'un prologue, conçu pour trente heures effectives en huit journées de quatre heures. La théorie y est lisible ; chaque notion sert un geste de mission. La Partie I pose le contrôle interne et la manière de l'évaluer. La Partie II présente les institutions et les normes. La Partie III conduit la mission, de l'ordre de mission au cycle suivant : principes, décomposition, instrument OUI / NON / NEK, mesures de la conformité et de l'incertitude,

© *MaletYon*

rapport et suivi. La Partie IV évalue le contrôle interne domaine par domaine : accès, exploitation, applications, données, projets. La Partie V réunit tout le cours dans un cas intégrateur traité en salle. La Partie VI ouvre sur la recherche et propose des sujets de mémoire.

Une méthode fondée sur une recherche. La démarche de mission est celle du cours d'audit des systèmes d'information de l'auteur à l'École Nationale Supérieure Polytechnique de Yaoundé, elle-même instanciation, pour le praticien, du programme de recherche de l'*auditologie* [25]. L'instrument de réponse OUI / NON / NEK et ses mesures viennent de l'article [24]. Ces deux textes sont des prépublications déposées sur HAL, et le cours les cite comme telles.

Trois entités fictives. Le cours suit trois dossiers. Au *MINÉQUIR*, ministère imaginaire de l'Équipement rural, une facture est payée deux fois par l'application de dépense. À la *CAPNO*, caisse publique de prévoyance de Garoua, le fichier de paie contient des agents qui n'existent pas. À la recette des finances de Bafoussam, le projet de dématérialisation *e-RECETTES* a été livré sans que personne n'en ait vérifié les sauvegardes. Les noms, les dates et les montants sont fictifs ; les mécanismes sont exacts.

Comment travailler. Entre deux journées, faites la fiche d'auto-évaluation de chaque chapitre et les labs de NDAP SUKULU qui s'y rattachent. Prenez surtout l'habitude que le cours veut transmettre : séparer ce que l'on a constaté de ce que l'on en pense, et écrire ce que l'on ne sait pas.

MINKA MI NGUIDJOÏ Thierry Emmanuel
Yaoundé, novembre 2026

MODE D'EMPLOI DU COURS

Structure générale

Le cours compte un prologue et six parties, soit quinze chapitres. Il est donné en huit journées de quatre heures ; les deux dernières heures de la huitième journée sont offertes aux auditeurs, ce qui fait trente heures effectives. Les fiches d'auto-évaluation et les laboratoires de 60 minutes de NDAP SUKULU sont des travaux à faire hors de ces heures.

Partie	Thème	Compétences visées	Niveau
Prologue	Le paiement du 28 décembre	Voir ce que le dossier papier ne montre pas	★☆☆
I	Fondements et contrôle interne	Situer l'audit d'un SI public, décrire et évaluer un système de contrôle interne	★☆☆ à ★★☆
II	Cadre institutionnel et normatif	Savoir qui contrôle quoi, choisir ses normes et ses critères	★☆☆
III	Démarche de mission	Préparer et décomposer, coter OUI / NON / NEK, mesurer μ, U, H, conclure, rapporter, suivre les cycles	★★☆
IV	Domaines d'audit	Évaluer les accès, l'exploitation, les applications, les données et les projets	★★☆ à ★★★
V	Synthèse	Conduire une mission complète en équipe	★★★
VI	Ouverture sur la recherche	Situer l'auditologie, formuler un sujet de mémoire falsifiable	★★★

Les huit journées

© *MaletYon*

Jour	Contenu	Partie
J01	Prologue ; contrôler et auditer un SI public (Ch. 1)	Prologue, I
J02	Le système de contrôle interne (Ch. 2) ; évaluer le système de contrôle interne (Ch. 3)	I
J03	Qui contrôle les SI publics (Ch. 4) ; normes et référentiels (Ch. 5)	II
J04	La mission : principes, préparation, décomposition (Ch. 6) ; collecter la preuve : OUI, NON, NEK (Ch. 7)	III
J05	Mesurer, conclure, rapporter, suivre (Ch. 8) ; accès et habilitations (Ch. 9)	III, IV
J06	Changements, exploitation et continuité (Ch. 10) ; contrôles d'application (Ch. 11)	IV
J07	Analyse de données et fraude (Ch. 12) ; gouvernance, projets et prestataires (Ch. 13)	IV
J08	Cas intégrateur en salle (Ch. 14) et ouverture sur la recherche (Ch. 15), deux heures ; les deux heures suivantes sont offertes	V, VI

Les encadrés

Définition

Définition. Introduit un terme avec sa définition ; les termes définis sont indexés et repris dans le glossaire (Annexe A).

Scénario Opérationnel · Titre du scénario

Scénario. Un épisode d'un des trois dossiers du cours : MINÉQUIR, CAPNO, e-RECETTES.

Point de contrôle · Code · Intitulé

Point de contrôle. Présente un contrôle sous une forme constante : objectif, risque couvert, test de conception, test de fonctionnement, preuve attendue.

Papier de travail

Papier de travail. Un modèle de feuille de mission, prêt à remplir : ce que l'auditeur fait et ce que le dossier doit contenir.

Lecture auditologique · Titre de la lecture

Lecture auditologique. Des réponses OUI / NON / NEK, avec la constatation, l'analyse et son niveau de confiance, et, selon le cas, le décompte des contrôles cotés ou les trois mesures du domaine.

3 oui sur 8 contrôles applicables · 0 nek **$\mu = 0{,}55$ · $U = 0{,}30$ · $H = 1{,}41$ bit**

Application Vérificateur

Application métier. Traduit le chapitre en gestes concrets pour l'un des métiers visés : vérificateur du Contrôle Supérieur de l'État, juge des comptes, inspecteur, contrôleur financier, auditeur interne.

Outils · Titre de l'outil

Outils. Une formule de tableur, une requête ou une commande, à refaire sur les données du cas.

Jurisprudence & Droit applicable

Cite un texte de loi ou de règlement, lu dans sa version disponible, puis en tire la portée pour l'audit.

★ Attention

Violation typique et **règle** : une erreur fréquente, et ce qu'il faut faire à la place.

★ À retenir

À retenir. Les points essentiels du chapitre.

Exercice

Exercice. Gradués en trois niveaux : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert. Les corrigés figurent dans le livret de correction.

Conventions

- Chaque contrôle testé reçoit une réponse : OUI (le contrôle existe et fonctionne), NON (il manque ou ne fonctionne pas), NEK (connaissance insuffisante pour conclure). Un contrôle sans objet est écarté, raison écrite.
- L'absence d'une trace que le contrôle devait produire vaut NON, et non NEK.
- μ est le taux de conformité, U le taux d'incertitude, H l'entropie en bits (au plus $\log_2 3 \approx 1{,}585$), selon l'article A1 [24] ; la règle de décision examine U d'abord, μ ensuite, H pour contrôler. Les seuils du quadrant ($\mu = 0{,}5$; $U = 0{,}20$) sont des conventions du cours.
- Les axiomes de l'auditologie portent la numérotation de l'article A0 (Chapitre 15).
- Chaque analyse indique un niveau de confiance : faible, moyenne ou élevée.
- Les **termes clés** apparaissent en gras ; les normes s'écrivent **[ISSAI 100]**, les textes camerounais **Loi décret n° 2013/287**.

Matériel d'accompagnement

- **Annexes** : glossaire, outils, papiers de travail types, textes, bibliographie, contacts (Annexes A à F).
- **Livret de correction** : corrigés des exercices et des fiches, réservé au formateur.
- **NDAP SUKULU** : fiches d'auto-évaluation et laboratoires, présentés dans la section qui suit.

NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON



Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.

© MaletYon

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **CAS3401**.
2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.
3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

Note

Si le portail n'est pas encore ouvert. En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

Les laboratoires du cours

Le cours compte dix laboratoires, disponibles sous le code CAS3401. Ils se font à la maison, hors des heures de cours.

Lab	Sujet	Chapitre	Dossier
CAS3401-LAB-01	Prise de connaissance et risques de SIDÉPENSE	6	MINÉQUIR
CAS3401-LAB-02	Évaluer le contrôle interne : questionnaire, cheminement, déficiences	3	MINÉQUIR
CAS3401-LAB-03	Habilitations : séparation des tâches et comptes des agents partis	9	MINÉQUIR
CAS3401-LAB-04	Chronologie du double paiement dans les journaux	7	MINÉQUIR
CAS3401-LAB-05	Intégrité d'une extraction	7	CAPNO
CAS3401-LAB-06	Agents fictifs et doublons dans la paie	12	CAPNO
CAS3401-LAB-07	Loi de Benford et fractionnement des marchés	12	MINÉQUIR
CAS3401-LAB-08	Changements et sauvegardes	10	e-RECETTES
CAS3401-LAB-09	Tester un contrôle d'application	11	MINÉQUIR
CAS3401-LAB-10	Rédiger un constat et classer la déficience	8	les trois

Les laboratoires du cours dans NDAP SUKULU

TABLE DES MATIÈRES

Avant-propos iii

Mode d'emploi du cours v

NDAP SUKULU, la salle de classe compagnon ix

Prologue Opérationnel 3

0 Prologue : Le Paiement du 28 Décembre 3

0.1 Ce qui s'est passé . . . 4
0.1.1 Le marché et le circuit . . . 4
0.1.2 Reconstituer avant de juger . . . 5
0.2 Ce que le contrôle sur pièces a vu . . . 6
0.3 Ce que la trace informatique révèle . . . 7
0.3.1 L'extraction . . . 7
0.3.2 Le test des doublons . . . 7
0.3.3 Le journal . . . 7
0.4 Les contrôles internes qui ont manqué . . . 8
0.5 Qui peut contrôler ce système . . . 10
0.6 Trois réflexes . . . 10
0.7 Le chemin du cours . . . 11

I Fondements et Contrôle Interne 15

1 Contrôler et Auditer un SI Public 17

1.1 Contrôler, auditer, inspecter, vérifier . . . 17
1.1.1 Les éléments d'un audit . . . 18
1.2 Assurance raisonnable, assurance limitée . . . 19
1.3 Trois types d'audit dans le secteur public . . . 19
1.3.1 Les cinq contrôles du CONSUPE . . . 20
1.4 Les systèmes d'information des finances publiques . . . 20
1.4.1 Une chaîne de systèmes . . . 20
1.4.2 Les points de contrôle de la chaîne . . . 21
1.5 Ce que l'informatique change à la preuve . . . 21

© *MaletYon*

2 Le Système de Contrôle Interne en Environnement Informatisé 25

2.1 Qu'est-ce que le contrôle interne ? . . . 26
2.1.1 La définition du COSO . . . 26
2.1.2 Trois catégories d'objectifs . . . 26
2.1.3 Le contrôle interne dans le secteur public . . . 27
2.2 Cinq composantes, dix-sept principes . . . 27
2.2.1 Les principes vus depuis le système d'information . . . 28
2.3 Classer les contrôles . . . 30
2.3.1 Selon le moment . . . 30
2.3.2 Selon le mode d'exécution . . . 30
2.3.3 Selon la portée . . . 30
2.4 Les contrôles généraux informatiques . . . 31
2.5 Séparer les tâches dans une application . . . 32
2.5.1 Du principe au profil . . . 32
2.5.2 La matrice des profils de SIDÉPENSE . . . 32
2.5.3 Quand on ne peut pas séparer . . . 33
2.6 Les limites du contrôle interne . . . 33

3 Évaluer le Système de Contrôle Interne 37

3.1 La démarche en cinq étapes . . . 38
3.2 Décrire le système . . . 38
3.2.1 Le narratif et le diagramme . . . 38
3.2.2 La matrice des risques et des contrôles . . . 39
3.3 Questionner : le questionnaire de contrôle interne . . . 40
3.4 Cheminer : le test de cheminement . . . 41
3.5 Évaluer la conception, tester le fonctionnement . . . 42
3.5.1 Deux questions distinctes . . . 42
3.5.2 Combien d'exécutions tester ? . . . 42
3.5.3 Coter . . . 42
3.6 Classer les déficiences . . . 43
3.6.1 Deux niveaux . . . 43
3.6.2 Une grille de classement . . . 44
3.6.3 Les déficiences du MINÉQUIR . . . 44
3.7 Conclure sur l'efficacité du système . . . 45
3.7.1 La lecture de conformité . . . 45
3.7.2 Une échelle simple . . . 45
3.7.3 Formuler la conclusion . . . 46

II Cadre Institutionnel et Normatif 49

4 Qui Contrôle les SI Publics au Cameroun 51

4.1 Le Contrôle Supérieur de l'État . . . 52
4.1.1 Une institution supérieure de contrôle . . . 52
4.1.2 Le champ du contrôle . . . 52
4.1.3 Les suites : le CDBF . . . 53
4.1.4 Le lien avec l'audit interne . . . 53
4.2 L'ANTIC : l'audit de sécurité . . . 53
4.3 La Chambre des Comptes : par extension . . . 54
4.4 Les autres acteurs . . . 55
4.5 Qui fait quoi, et comment s'articuler . . . 55
4.5.1 Trois angles sur un même système . . . 55
4.5.2 Règles d'articulation . . . 56

5 Normes et Référentiels de l'Auditeur Public 59

5.1 Norme, référentiel, critère . . . 60
5.2 Les normes de l'INTOSAI . . . 60
5.2.1 Le cadre . . . 60
5.2.2 Le GUID 5100 . . . 61
5.2.3 L'audit de conformité selon l'IDI . . . 61
5.3 Les normes de l'audit interne . . . 61
5.4 Les référentiels de critères . . . 62
5.4.1 COBIT 2019 . . . 62
5.4.2 ISO/IEC 27001 et 27002 . . . 62
5.4.3 Les textes camerounais comme critères . . . 62
5.4.4 Choisir et citer un critère . . . 63
5.5 Déontologie . . . 63

III Démarche de Mission 67

6 La mission : principes, préparation, décomposition 69

6.1 Les principes de l'audit . . . 70
6.1.1 Les principes en conflit . . . 71
6.2 Le cycle de la mission . . . 71
6.2.1 Cinq phases . . . 71
6.2.2 Entrées et sorties de chaque phase . . . 72
6.2.3 L'équipe et la supervision . . . 72
6.3 L'ordre de mission et les termes de référence . . . 72
6.3.1 L'ordre de mission . . . 72
6.3.2 Les termes de référence : quatre questions . . . 73
6.4 Les pièces à demander . . . 74
6.4.1 Trois strates . . . 74

6.4.2 Une pièce absente : NON ou NEK ? . . . 74
6.5 La prise de connaissance . . . 75
6.5.1 Une prise de connaissance bornée . . . 75
6.5.2 Lire le système d'information en couches . . . 75
6.5.3 La cartographie des applications et des flux . . . 76
6.5.4 Conduire un entretien de prise de connaissance . . . 76
6.6 Hiérarchiser : risque et connaissance . . . 76
6.6.1 La cotation du risque . . . 76
6.6.2 Le risque et la connaissance . . . 77
6.7 Décomposer : le gabarit canonique et la fiche d'assertion . . . 78
6.7.1 Pourquoi décomposer . . . 78
6.7.2 Le gabarit canonique à huit niveaux . . . 78
6.7.3 Preuve et trace : deux choses différentes . . . 79
6.7.4 La décomposition de la mission MINÉQUIR . . . 79
6.7.5 La fiche d'assertion . . . 79
6.7.6 De la fiche à la cotation . . . 80
6.7.7 Les règles de qualité . . . 80
6.8 Le programme de travail . . . 81

7 Collecter la preuve : OUI, NON, NEK 85

7.1 L'instrument OUI / NON / NEK . . . 86
7.1.1 Pourquoi une troisième réponse . . . 86
7.1.2 Deux usages . . . 86
7.1.3 NEK n'est pas « non applicable » . . . 87
7.2 Le biais du choix forcé . . . 87
7.3 Les preuves et leur fiabilité . . . 88
7.3.1 Suffisante et appropriée . . . 88
7.3.2 Une hiérarchie de fiabilité . . . 88
7.3.3 La corroboration . . . 88
7.4 Les entretiens . . . 89
7.5 Les techniques de test . . . 89
7.6 Échantillonner dans le système . . . 90
7.6.1 Population et échantillon . . . 90
7.6.2 L'échantillonnage par attributs, démontré . . . 90
7.6.3 Conclure sur l'échantillon . . . 91
7.6.4 Tester toute la population . . . 91
7.7 Obtenir une extraction . . . 91
7.7.1 Quatre garanties . . . 91
7.7.2 L'empreinte et les totaux de contrôle . . . 92
7.8 Les papiers de travail . . . 92

8 Mesurer, conclure, rapporter, suivre 97

8.1 Trois mesures . . . 98
8.1.1 Les définitions . . . 98
8.1.2 Quatre cas limites . . . 99
8.1.3 Les quatre domaines du MINÉQUIR . . . 99
8.2 Décomposer l'entropie . . . 100
8.3 Le quadrant conformité × incertitude . . . 100
8.4 La règle de décision du cours . . . 102
8.5 Le constat en cinq éléments . . . 102
8.5.1 Le constat . . . 103
8.5.2 L'observation en sept éléments . . . 103
8.5.3 Écrire une recommandation . . . 104
8.6 Le rapport . . . 104
8.7 La procédure contradictoire . . . 105
8.7.1 Pourquoi le contradictoire . . . 105
8.7.2 Maintenir, modifier, retirer . . . 105
8.8 Suivre les recommandations . . . 106
8.9 Comparer deux cycles . . . 106
8.9.1 Pourquoi le taux de conformité ne suffit pas . . . 106
8.9.2 Le lissage . . . 107
8.10 Quand le constat devient une affaire . . . 108

IV Domaines d'Audit 111

9 Accès et Habilitations 113

9.1 Le cycle de vie d'un compte . . . 114
9.2 Les comptes à risque . . . 114
9.3 La matrice des profils . . . 115
9.4 La revue des habilitations . . . 116
9.5 L'authentification . . . 116
9.6 Lecture du domaine . . . 117

10 Changements, Exploitation et Continuité 119

10.1 La gestion des changements . . . 120
10.1.1 Le circuit attendu . . . 120
10.1.2 Le test . . . 120
10.2 L'exploitation . . . 121
10.3 Les sauvegardes . . . 121
10.4 La continuité . . . 122

11 Contrôles d'Application de la Dépense et de la Recette 125

11.1 Quatre familles de contrôles d'application . . . 126
11.2 Sur la chaîne de la dépense . . . 126
11.3 Sur la chaîne de la recette . . . 127
11.4 Tester un contrôle automatique . . . 127
11.4.1 L'essai, si les contrôles généraux tiennent . . . 127
11.4.2 L'analyse de la population, sinon . . . 128

12 Analyse de Données et Détection de la Fraude 131

12.1 Le risque de fraude . . . 132
12.2 Analyser un fichier de paie . . . 132
12.2.1 Trois questions . . . 132
12.3 Le fractionnement des commandes . . . 133
12.4 La loi de Benford . . . 134
12.5 De l'indice au constat . . . 134

13 Gouvernance, Projets Numériques et Prestataires 137

13.1 La gouvernance de la fonction informatique . . . 138
13.2 Auditer un projet numérique . . . 138
13.2.1 Le cycle du projet et ses contrôles . . . 138
13.3 Les prestataires et l'hébergement externe . . . 139
13.4 Les données personnelles . . . 140

V Synthèse 143

14 Cas Intégrateur : la Mission e-RECETTES 145

14.1 Le mandat . . . 146
14.2 Le dossier . . . 146
14.3 Le déroulé . . . 148
14.4 La grille de restitution . . . 149
14.5 Les erreurs fréquentes . . . 149

VI Ouverture sur la Recherche 151

15 Ouvrir sur la recherche : l'auditologie 153

15.1 L'objet : la mission auditologique . . . 154
15.2 Six axiomes . . . 155
15.2.1 Quatre propositions . . . 155
15.3 Cinq piliers . . . 156
15.4 La méthode : science du design et falsifiabilité . . . 156

15.4.1 Une science du design . . . 156
15.4.2 Un noyau dur et une ceinture protectrice . . . 156
15.4.3 Ce que l'auditologie n'est pas . . . 157
15.5 Établi, déposé, à valider . . . 157
15.6 Axes de recherche pour l'auditeur public . . . 157
15.6.1 Exemples de sujets . . . 158
15.7 Conduire un mémoire de recherche appliquée . . . 160

A Glossaire **163**

B Référentiel des Outils **167**

C Papiers de Travail Types **169**

D Textes Juridiques et Normatifs **171**

E Bibliographie Commentée **175**

F Contacts et Ressources **177**

Références bibliographiques **179**

TABLE DES FIGURES

© *MaletYon*

LISTE DES TABLEAUX

© *MaletYon*

Prologue Opérationnel

© *MaletYon*

0

PROLOGUE : LE PAIEMENT DU 28 DÉCEMBRE

« Le dossier était en ordre ; le système, non. »

Note de synthèse d'une vérificatrice

Niveau : *Introductif* • Aucun prérequis informatique. Il suffit de connaître le circuit de la dépense publique : engagement, liquidation, ordonnancement, paiement. Ce prologue se lit avant toute définition : il part d'un contrôle qui n'a rien vu.

✦ Objectifs du chapitre

- ➢ Reconstituer, à partir des pièces et des traces informatiques, la chronologie d'un double paiement (dossier MINÉQUIR).
- ➢ Expliquer pourquoi un contrôle sur pièces, bien conduit, peut ne pas voir une irrégularité qui se trouve dans le système.
- ➢ Distinguer une constatation, appuyée sur une preuve conservée, de l'analyse que l'on en tire.
- ➢ Identifier les contrôles internes qui auraient dû empêcher ou détecter le double paiement, et les coter OUI, NON ou NEK.
- ➢ Citer le texte qui donne au Contrôle Supérieur de l'État la compétence du contrôle des systèmes d'information.
- ➢ Énoncer les trois réflexes de l'auditeur public face à un système d'information : le mandat, la preuve, le contradictoire.

Avant de commencer : un contrôle qui n'a rien vu

Yaoundé, lundi 16 mars 2026. Mme NGO BIYONG, vérificatrice au Contrôle Supérieur de l'État, reçoit son ordre de mission : vérifier l'exécution du budget 2025 de la Direction des Affaires Financières du ministère de l'Équipement rural, le MINÉQUIR[1]. Dans le dossier permanent, une pièce attire son attention : le rapport d'une inspection conduite

[1] Le MINÉQUIR, ses agents, ses fournisseurs, les dates et les montants de ce dossier sont fictifs. Les mécanismes du circuit de la dépense, les contrôles et les textes cités sont exacts.

© MaletYon

en janvier sur les dépenses de décembre. Il examine quarante dossiers de paiement et conclut à une « régularité satisfaisante ».

Trois semaines plus tard, la même vérificatrice établit qu'une facture a été payée deux fois en décembre, la seconde fois sur un compte bancaire qui n'appartient pas au fournisseur. Le montant en jeu est de **187 450 000 francs CFA**. L'inspection de janvier ne s'était pas trompée sur les dossiers qu'elle a examinés : ils étaient complets et réguliers. Elle n'a simplement jamais vu le second paiement, parce qu'il n'avait pas de dossier.

Ce prologue reconstitue ce dossier. Il montre ce qu'un contrôle sur pièces peut voir et ce qu'il ne peut pas voir, ce que la trace informatique révèle, et quels contrôles internes ont manqué. Il en tire les trois réflexes qui structurent tout le cours. Les notions y sont nommées ; elles sont définies avec précision dans les chapitres suivants.

★ Attention

Violation typique. Tirer l'échantillon d'un contrôle dans les classeurs de dossiers papier, alors que les paiements sont produits par une application : ce qui n'a pas de dossier ne peut pas être tiré.

Règle : la population d'un contrôle est l'ensemble des opérations enregistrées dans le système, pas l'ensemble des dossiers rangés.

0.1 Ce qui s'est passé

0.1.1 Le marché et le circuit

Le MINÉQUIR a passé en 2025 le marché n° 0412/M/MINÉQUIR/2025 avec la société BATIRURAL SARL, de Mbalmayo, pour l'aménagement de pistes rurales. Le décompte n° 3 de ce marché, facturé sous le numéro F-2025-117, s'élève à 187 450 000 FCFA.

Depuis 2024, la dépense du ministère passe par une application, SIDÉPENSE. Chaque étape du circuit y est un écran et un profil d'utilisateur : l'engagement réserve le crédit, la liquidation constate le service fait et arrête le montant, l'ordonnancement émet le mandat, puis le poste comptable reçoit le mandat par voie électronique et paie. Les pièces justificatives sont scannées et jointes au mandat ; le dossier papier est classé à la Direction des Affaires Financières.

Élément	Description
Entité	Direction des Affaires Financières (DAF) du MINÉQUIR, Yaoundé
Application	SIDÉPENSE : engagement, liquidation, ordonnancement, transmission des mandats au poste comptable, fichier des fournisseurs
Volume 2025	9 611 mandats
Acteurs	M. EBOUMBOU, directeur des affaires financières ; M. ATANGANA, chef de la cellule informatique ; M. FOTSO, chef du poste comptable
Contrôle	Inspection sur pièces (janvier 2026) ; mission du CONSUPE (mars 2026), conduite par Mme NGO BIYONG

Tableau P.1. Le dossier MINÉQUIR

0.1.2 Reconstituer avant de juger

Une vérificatrice ne commence pas par chercher un responsable : elle reconstitue la suite des événements, et rattache chaque événement à une pièce. Ce qu'on lui raconte sans pièce reste une déclaration, à vérifier. Le Tableau P.2 donne la chronologie établie par Mme NGO BIYONG.

Date	Événement	Pièce
14 août 2025	M. MBARGA, chef du service de la liquidation, est muté à Ebolowa	Décision de mutation
22 déc. 2025	Mandat 2025-08817 (décompte n° 3) émis par le circuit normal	Mandat, dossier papier complet
24 déc. 2025	Paiement sur le compte n° 1 de BATIRURAL (banque A)	Relevé du poste comptable
27 déc. 2025, 21 h 52	Le RIB de BATIRURAL est remplacé, dans le fichier des fournisseurs, par un compte n° 2 (banque B) au nom de « BATIRURAL SERVICES »	Journal de SIDÉPENSE
28 déc. 2025, 23 h 14	Mandat 2025-09342, facture « F-2025-117 bis », même montant, liquidé et ordonnancé par le compte `mbarga.j`	Journal de SIDÉPENSE, mandat électronique
30 déc. 2025	Paiement du second mandat sur le compte n° 2	Relevé du poste comptable
Janv. 2026	Inspection de 40 dossiers papier de décembre : « régularité satisfaisante »	Rapport d'inspection
16 mars 2026	Ordre de mission du CONSUPE	Ordre de mission
23 mars 2026	Extraction des 9 611 mandats de 2025 et du journal des opérations	Fichiers extraits, empreintes

Tableau P.2. Chronologie du double paiement (reconstitution de la vérificatrice)

Ce tableau ne contient que des faits. Il ne dit pas encore qui a agi, ni pourquoi : le compte `mbarga.j` a servi, mais rien n'établit à ce stade que M. MBARGA l'ait utilisé lui-même. Séparer ce qui est établi de ce que l'on en déduit est la première discipline de l'auditeur.

Définition

Constatation (*finding*) : fait vérifiable, établi par l'auditeur et appuyé sur une preuve conservée. Un tiers compétent qui refait la même démarche sur les mêmes pièces aboutit au même résultat.

Analyse : interprétation que l'auditeur tire d'une ou plusieurs constatations, au regard d'un critère, avec un niveau de confiance déclaré (faible, moyen ou élevé).

0.2 Ce que le contrôle sur pièces a vu

L'inspection de janvier a fait correctement ce qu'elle a fait. Elle a tiré quarante dossiers dans les classeurs de décembre, vérifié pour chacun l'engagement, le service fait, la facture, le visa et l'imputation. Les quarante dossiers étaient complets. Le mandat 2025-08817 en faisait partie.

Son erreur n'est pas dans l'examen, elle est dans la **population**. L'échantillon a été tiré dans les classeurs, c'est-à-dire parmi les mandats qui avaient un dossier papier. Le mandat 2025-09342 n'en avait pas : il a été créé directement dans l'application, avec un scan de la facture du premier mandat, renommée « bis ». Aucun tirage dans les classeurs ne pouvait le faire sortir.

Scénario Opérationnel · Dossier MINÉQUIR. Deux populations

Constatation. Les classeurs de décembre contiennent 1 184 dossiers ; l'application enregistre 1 191 mandats émis en décembre. Sept mandats n'ont pas de dossier papier, dont le mandat 2025-09342.

Analyse (confiance élevée). L'inspection a conclu sur la population des dossiers rangés, pas sur celle des mandats émis. Sa conclusion vaut pour les 1 184 dossiers ; elle ne dit rien des sept autres. Un rapprochement entre les deux populations, fait avant le tirage, aurait suffi à les faire apparaître.

Cette différence entre deux populations est la première leçon du cours : dès que l'administration s'informatise, le dossier papier n'est plus le système, il n'en est qu'une sortie.

0.3 Ce que la trace informatique révèle

0.3.1 L'extraction

Mme NGO BIYONG ne part pas des classeurs, mais de l'application. Elle demande par écrit à M. ATANGANA une extraction de tous les mandats de 2025 et du journal des opérations, assiste à l'extraction, calcule l'empreinte des fichiers et la fait contresigner. Elle vérifie ensuite que le total des mandats extraits est égal au total des paiements du compte administratif. Le Chapitre 7 détaille ces précautions : sans elles, une extraction n'est qu'un fichier remis par l'audité.

0.3.2 Le test des doublons

Sur les 9 611 mandats, elle recherche ceux qui portent le même fournisseur et le même montant. Le test, fait dans un tableur, renvoie trois paires. Deux s'expliquent par des pièces (deux livraisons identiques d'un même fournisseur). La troisième est celle de BATIRURAL : même fournisseur, même montant, même numéro de facture au suffixe près, et deux comptes bancaires différents.

Outils · Recherche des doublons dans un tableur

Dans la feuille des mandats (colonnes : B fournisseur, D montant), une colonne de clé et une colonne de comptage suffisent :

```
F2 : =B2&"|"&D2
G2 : =NB.SI($F$2:$F$9612;F2)
```

Un filtre sur `G > 1` affiche les mandats qui partagent le même fournisseur et le même montant. Le test ne prouve rien à lui seul : il désigne les mandats à examiner, pièce par pièce.

0.3.3 Le journal

Le journal de SIDÉPENSE enregistre, pour chaque opération sensible, l'utilisateur, la date, l'heure et l'action. Il permet de reconstituer les deux opérations du Tableau P.3.

```
2025-12-27 21:52:07 mbarga.j FOURNISSEUR MODIF_RIB   BATIRURAL  cpte1->cpte2
2025-12-28 23:09:41 mbarga.j MANDAT      LIQUIDATION 2025-09342 187450000
2025-12-28 23:14:18 mbarga.j MANDAT      ORDONNANCE  2025-09342 187450000
2025-12-30 10:02:55 pc.fotso MANDAT      PAIEMENT    2025-09342 cpte2
```

Tableau P.3. Extrait du journal de SIDÉPENSE (fichier extrait le 23 mars 2026, empreinte au dossier)

Scénario Opérationnel · Dossier MINÉQUIR. Ce que dit le journal

Constatations.

(a) Le compte `mbarga.j` était actif le 28 décembre 2025, quatre mois après la mutation de son titulaire.

(b) Le même compte a modifié un RIB, liquidé et ordonnancé le même mandat ; aucune deuxième personne n'est intervenue.

(c) Les deux opérations ont eu lieu un samedi soir et un dimanche soir, hors des heures de service.

(d) SIDÉPENSE a accepté un second mandat de même fournisseur, même montant et même numéro de facture au suffixe « bis » près.

Analyse (confiance moyenne). Le double paiement n'est pas une erreur de saisie : la modification du RIB la veille, sur le seul compte du fournisseur concerné, et l'heure des opérations désignent une manœuvre. L'identité de la personne qui a utilisé le compte n'est pas établie : un compte resté actif peut être utilisé par quelqu'un qui en connaît le mot de passe.

0.4 Les contrôles internes qui ont manqué

La question de l'auditeur n'est pas seulement « qui a fait cela ? », qui relève d'autres procédures, mais « qu'est-ce qui aurait dû l'empêcher, ou le détecter, et pourquoi cela n'a-t-il pas fonctionné ? ». C'est la question du **contrôle interne** : l'ensemble des dispositifs qui donnent une assurance raisonnable que les opérations sont régulières, les informations fiables et les biens protégés. Le Chapitre 2 le définit selon le COSO, et le Chapitre 3 apprend à l'évaluer.

Mme NGO BIYONG dresse la liste des contrôles qu'elle s'attendait à trouver sur ce circuit, et cote chacun. Elle répond OUI si le contrôle existe et a fonctionné, NON s'il manque ou n'a pas fonctionné, NEK (*Not Enough Knowledge*) si elle n'a pas encore de quoi conclure.

N°	Contrôle attendu	Cote	Preuve
1	Les comptes des agents mutés sont désactivés à la date de la mutation	NON	Liste des comptes actifs, décision de mutation
2	Un même profil ne peut pas liquider et ordonnancer	NON	Matrice des profils de SIDÉPENSE
3	Toute modification de RIB exige une seconde validation	NON	Journal : une seule intervention
4	L'application bloque un mandat de même fournisseur, même montant et même facture	NON	Mandat 2025-09342 accepté
5	Le poste comptable vérifie les pièces jointes avant paiement	NEK	Pièces du poste comptable demandées, non reçues
6	Les opérations sensibles sont journalisées	OUI	Journal extrait
7	Les paiements de fin de gestion font l'objet d'une revue	NON	Aucune revue produite
8	Les journaux sont conservés et protégés	OUI	Journal intact depuis 2024

Tableau P.4. Les contrôles attendus sur le circuit de la dépense

Lecture auditologique · Circuit de la dépense, MINÉQUIR

Constatation. Sur huit contrôles attendus, deux existent et fonctionnent, cinq manquent ou n'ont pas fonctionné, un ne peut pas encore être coté.

Analyse (confiance élevée). Les deux contrôles qui fonctionnent sont des contrôles de *détection* a posteriori : ils ont permis de reconstituer les faits, pas de les empêcher. Tous les contrôles de *prévention* ont manqué. La cote NEK du contrôle 5 n'est pas une faiblesse de la mission : elle dit honnêtement ce qui reste à établir, et désigne la prochaine pièce à obtenir.

2 oui sur 8 contrôles applicables · 1 nek

Note

Pourquoi nek et pas non ? Si le poste comptable devait produire une trace de sa vérification et ne l'a pas produite, la réponse est NON : l'absence d'une trace exigée est une constatation. Ici, la vérificatrice n'a pas encore reçu les pièces qu'elle a demandées : elle ne sait pas. Elle l'écrit, et relance.

0.5 Qui peut contrôler ce système

Mme NGO BIYONG n'a pas eu à demander la permission d'auditer SIDÉPENSE. Le texte organique du Contrôle Supérieur de l'État le lui permet expressément.

⚖ Jurisprudence & Droit applicable

Loi Décret n° 2013/287 du 4 septembre 2013 portant organisation des services du Contrôle supérieur de l'État, article 2, alinéa 3 [30] : *« Dans l'exercice de leurs attributions, les services du Contrôle supérieur de l'Etat effectuent : un contrôle de conformité et de régularité ; un contrôle financier ; un contrôle de performance ; un contrôle de l'environnement ; un contrôle des systèmes d'information. »*

Article 2, alinéa 4 : *« Les contrôles sont effectués par les vérificateurs du Contrôle supérieur de l'Etat sur pièces et sur place. A cet effet, et nonobstant les contrôles effectués par les autres organes de contrôle, les responsables des structures auditées sont tenus de présenter les pièces relatives à la période auditée. »*

Portée pour l'audit. Le contrôle des systèmes d'information est une compétence écrite du CONSUPE, au même titre que le contrôle de régularité. L'obligation de présenter les pièces couvre les pièces électroniques : une extraction, un journal, une matrice des profils sont des pièces relatives à la période auditée.

Deux autres institutions regardent les systèmes d'information publics, chacune sous un angle différent. L'ANTIC conduit les audits de sécurité des réseaux et des systèmes d'information prévus par la **Loi loi n° 2010/012**. La Chambre des Comptes de la Cour suprême juge les comptes des comptables publics ; elle rencontre les systèmes d'information par extension, parce que ces comptes en sont issus. Le Chapitre 4 précise qui fait quoi, et comment ces interventions s'articulent.

❍

0.6 Trois réflexes

Le dossier MINÉQUIR fait apparaître les trois réflexes que le cours installe, chapitre après chapitre.

1. **Le mandat.** Savoir au nom de quoi l'on contrôle, sur quel périmètre et selon quels critères. C'est l'ordre de mission qui a permis d'exiger l'extraction ; c'est le critère (« un mandat ne peut pas être payé deux fois ») qui a permis de coter (Chapitres 4 et 6).
2. **La preuve.** Partir du système, pas du classeur ; obtenir la donnée soi-même ou y assister, en garantir l'intégrité, et conserver tout ce qui fonde une cote (Chapitre 7).

3. **Le contradictoire.** Soumettre les constatations à l'entité avant de conclure. Le directeur des affaires financières et le chef de la cellule informatique recevront le Tableau P.4 et pourront le contester pièce par pièce (Chapitre 8).

Papier de travail

Le contenu minimal d'un papier de travail, pour chaque contrôle coté :

- le contrôle attendu et le critère qui le fonde ;
- le test effectué, la date et la personne qui l'a fait ;
- la pièce obtenue (nom du fichier, empreinte, source) ;
- la cote (OUI, NON ou NEK) et la constatation qui la justifie ;
- pour un NEK, la pièce manquante et la relance.

Application Vérificateur

Avant tout tirage d'échantillon, rapprochez le nombre et le montant des opérations du système avec ceux de la source que vous allez échantillonner (classeurs, bordereaux). Un écart, même de quelques unités, désigne les opérations qu'il faut examiner en premier.

Application Inspecteur

Un rapport qui conclut « régularité satisfaisante » doit dire sur quelle population il porte. Écrivez-le : « sur les 1 184 dossiers classés de décembre », et non « sur les dépenses de décembre ».

Application Contrôleur financier

Les paiements de fin de gestion concentrent le risque : volume élevé, délais courts, personnel réduit. Une revue des mandats émis hors des heures de service et des RIB modifiés dans les derniers jours de l'exercice est un contrôle simple, et il aurait arrêté le second paiement.

0.7 Le chemin du cours

Le cours se déroule en huit journées de quatre heures. Les deux dernières heures de la huitième journée sont offertes.

Jour	Question traitée	Chapitres
J01	Qu'est-ce qu'auditer un système d'information public ?	P00, 1
J02	Qu'est-ce qu'un système de contrôle interne, et comment l'évaluer ?	2, 3
J03	Qui contrôle quoi, et selon quelles normes ?	4, 5
J04	Comment préparer la mission et obtenir la preuve ?	6, 7
J05	Comment conclure ? Que vaut le contrôle des accès ?	8, 9
J06	Que valent l'exploitation et les contrôles des applications ?	10, 11
J07	Que disent les données ? Que valent les projets et les prestataires ?	12, 13
J08	Une mission complète, en équipe	14

Tableau P.5. Les huit journées

Trois dossiers accompagnent le cours. Le MINÉQUIR revient dans les chapitres sur le contrôle interne, la mission, les accès et les applications. La *CAPNO*, caisse publique de prévoyance de Garoua, sert aux chapitres sur la preuve et l'analyse des données : son fichier de paie contient des agents qui n'existent pas. Le projet *e-RECETTES*, à Bafoussam, sert aux chapitres sur l'exploitation, les projets et au cas intégrateur.

❍

★ À retenir

- **Le dossier n'est pas le système.** Dans une administration informatisée, le classeur n'est qu'une sortie de l'application ; la population d'un contrôle se prend dans le système.
- **Reconstituer avant de juger.** Chaque événement est rattaché à une pièce ; ce qui n'a pas de pièce reste une déclaration.
- **Constatation et analyse se séparent.** La constatation est vérifiable par un tiers ; l'analyse porte un niveau de confiance.
- **La question du contrôle interne.** Ce qui aurait dû empêcher ou détecter l'irrégularité, et pourquoi cela n'a pas fonctionné.
- **Trois réponses.** OUI, NON, NEK ; l'absence d'une trace exigée vaut NON, une pièce non encore obtenue vaut NEK.
- **Une compétence écrite.** Le décret n° 2013/287 range le contrôle des systèmes d'information parmi les cinq contrôles du CONSUPE.
- **Trois réflexes.** Le mandat, la preuve, le contradictoire.

✍ Exercice P.1. Constatation ou analyse ? ★☆☆

Classez chacun des énoncés suivants et justifiez en une ligne.

(a) « Le compte `mbarga.j` a ordonnancé le mandat 2025-09342 le 28 décembre 2025 à 23 h 14 (journal extrait le 23 mars, empreinte au dossier). »

(b) « M. MBARGA a détourné 187 450 000 FCFA. »

(c) « Sept mandats de décembre n'ont pas de dossier papier. »

(d) « Le contrôle des modifications de RIB n'est pas efficace. »

(e) « La cellule informatique semble débordée. »

✍ Exercice P.2. Coter un contrôle ★☆☆

Pour chacune des situations suivantes, donnez la cote (OUI, NON ou NEK) et justifiez.

(a) La procédure exige un procès-verbal mensuel de revue des comptes actifs ; la DAF n'en produit aucun pour 2025.

(b) Le chef de la cellule informatique affirme que les mots de passe expirent tous les 90 jours ; le paramétrage n'a pas encore été montré.

(c) La matrice des profils, extraite par la vérificatrice, ne donne à aucun profil à la fois la liquidation et l'ordonnancement.

(d) Le test de doublon a été paramétré en juin 2026, après les faits.

✍ Exercice P.3. Deux populations ★★☆

L'inspection de janvier a examiné 40 dossiers parmi 1 184.

(a) Quelle était la probabilité que le mandat 2025-09342 figure dans son échantillon ? Justifiez.

(b) Proposez, en trois étapes, la démarche qui aurait permis de le détecter sans augmenter la taille de l'échantillon.

(c) Rédigez la phrase de conclusion que l'inspection aurait dû écrire, compte tenu de sa population réelle.

✍ Exercice P.4. Le premier constat ★★★

À partir du Tableau P.4 et du journal (Tableau P.3) :

(a) Rédigez, en séparant constatation et analyse, le constat portant sur le contrôle 2 (séparation entre liquidation et ordonnancement).

(b) Indiquez le critère que vous citez, et la pièce qui fonde la cote.

(c) Formulez une recommandation adressée au directeur des affaires financières, et

une adressée au chef de la cellule informatique.

(d) Dites quelles réponses vous attendez de chacun pendant la procédure contradictoire, et ce qui pourrait vous faire changer la cote.

Note

Transition. Le prologue a montré un contrôle qui n'a rien vu et une vérificatrice qui a vu, parce qu'elle est partie du système. Le Chapitre 1 pose le vocabulaire : ce que signifient contrôler, auditer, vérifier, et ce qui change quand l'objet du contrôle est un système d'information public.

partie I

Fondements et Contrôle Interne

© *MaletYon*

1

CONTRÔLER ET AUDITER UN SI PUBLIC

> « Auditer, c'est donner à un tiers une assurance sur ce qu'il ne peut pas vérifier lui-même. »
>
> Principe du cours

Niveau : *Fondamental* • Prologue. Aucune connaissance informatique préalable.

✦ Objectifs du chapitre

- ➢ Distinguer contrôle, audit, inspection et vérification, et situer chacun dans l'administration financière camerounaise.
- ➢ Expliquer la différence entre assurance raisonnable et assurance limitée.
- ➢ Reconnaître les trois types d'audit du secteur public (financier, de conformité, de performance) et ce que chacun demande au système d'information.
- ➢ Situer le contrôle des systèmes d'information parmi les cinq contrôles du CONSUPE.
- ➢ Cartographier les systèmes d'information des finances publiques et leurs points de contrôle.
- ➢ Expliquer ce que l'informatique change à la preuve.

Pourquoi ce chapitre

Les auditeurs du PSSFP connaissent déjà le contrôle des finances publiques. Ce chapitre ne le leur réapprend pas : il fixe un vocabulaire commun et montre ce qui change quand l'objet du contrôle devient un système d'information. La question directrice est simple : *que faut-il regarder, et dans quel ordre, quand la dépense passe par une application ?*

❍

1.1 Contrôler, auditer, inspecter, vérifier

Les mots du contrôle sont employés indifféremment dans les services. Le cours les distingue, parce que chacun engage une démarche et une responsabilité différentes.

© MaletYon

Définition

Contrôle : dispositif ou action, intégré au fonctionnement de l'entité, qui vise à empêcher ou à détecter une anomalie (un visa, un rapprochement, un blocage automatique). Il est exercé par les services eux-mêmes.

Audit : examen méthodique, indépendant et documenté, qui compare une situation à des critères connus à l'avance et qui conduit à une opinion motivée, communiquée à un tiers.

Inspection : vérification ponctuelle de la régularité d'opérations ou du fonctionnement d'un service, souvent déclenchée par un événement, au nom de l'autorité hiérarchique.

Vérification : dans la langue du décret n° 2013/287, l'activité des vérificateurs du Contrôle Supérieur de l'État, conduite sur pièces et sur place ; elle recouvre l'audit externe du secteur public.

La différence tient en deux questions. **Qui agit ?** Le contrôle est exercé par l'entité ; l'audit et la vérification par quelqu'un qui n'a pas participé aux opérations. **Pour qui ?** Le contrôle sert l'entité ; l'audit sert un tiers (le Président de la République pour le CONSUPE, le juge des comptes, le parlement, un conseil d'administration) qui ne peut pas vérifier lui-même.

1.1.1 Les éléments d'un audit

Tout audit, quel que soit son objet, manipule les mêmes cinq éléments. Le cours les emploie dans ce sens précis.

Élément	Définition et exemple (dossier MINÉQUIR)
Critère	Exigence de référence, connue avant le test : « un mandat ne peut pas être payé deux fois »
Preuve	Information vérifiable que l'auditeur obtient et conserve : l'extraction des 9 611 mandats, son empreinte
Constatation	Comparaison de la preuve au critère : « le mandat 2025-09342 reprend la facture du mandat 2025-08817 »
Conclusion	Résultat de l'ensemble des constatations sur un objectif : « le contrôle des doublons n'existe pas dans SIDÉPENSE »
Opinion	Forme que prend la conclusion dans le rapport, avec son niveau d'assurance

Tableau 1.1. Les cinq éléments d'un audit

★ Attention

Violation typique. Choisir le critère après avoir vu les faits : « les droits de M. MBARGA étaient excessifs », sans dire quelle règle les limitait.

Règle : le critère est écrit avant le test, et cité dans le constat. Un constat sans critère est une opinion personnelle.

1.2 Assurance raisonnable, assurance limitée

Aucun auditeur n'examine tout. Il donne donc une assurance, jamais une certitude.

■ Définition

Assurance raisonnable : niveau de confiance élevé, mais non absolu, obtenu par des travaux étendus. Elle s'exprime sous une forme positive : « les contrôles examinés fonctionnent efficacement ».

Assurance limitée : niveau de confiance plus faible, obtenu par des travaux réduits. Elle s'exprime sous une forme négative : « nous n'avons rien relevé qui laisse penser que… ».

Le choix se fait au moment du mandat, pas à la fin de la mission. Une inspection de deux jours ne peut donner qu'une assurance limitée ; si son rapport conclut sous une forme positive, il promet plus qu'il n'a vérifié. C'est exactement le défaut du rapport de janvier dans le prologue (Chapitre 0) : « régularité satisfaisante » sur une population incomplète.

1.3 Trois types d'audit dans le secteur public

Les normes de l'INTOSAI distinguent trois types d'audit du secteur public [10]. Chacun interroge le système d'information d'une manière différente.

Type	Question	Ce qu'il demande au SI
Audit financier	Les états financiers et les comptes sont-ils fiables ?	Les données produites par l'application sont-elles exactes et exhaustives ?
Audit de conformité	Les opérations respectent-elles les lois, les règlements et les règles internes ?	L'application impose-t-elle les règles (séparation des tâches, plafonds, visas) ?
Audit de performance	Les ressources sont-elles employées avec économie, efficience et efficacité ?	Le système atteint-il ses objectifs, à quel coût, et ses données permettent-elles de le savoir ?

Tableau 1.2. Les trois types d'audit et le système d'information

L'audit des systèmes d'information n'est pas un quatrième type à côté des trois autres. Il les sert tous les trois : on audite un SI pour savoir si l'on peut se fier à ses données (financier), s'il fait respecter les règles (conformité), ou s'il rend le service attendu (performance). Les lignes directrices GUID 5100 de l'INTOSAI le disent ainsi : un audit des SI peut être une mission autonome, de performance ou de conformité, ou une partie d'une mission plus large, financière, de conformité ou de performance [11].

1.3.1 Les cinq contrôles du CONSUPE

Le décret n° 2013/287 range le contrôle des systèmes d'information parmi les cinq contrôles qu'effectuent les services du Contrôle supérieur de l'État [30].

⚖ Jurisprudence & Droit applicable

Loi Décret n° 2013/287, article 2, alinéa 1 : *« Les services du Contrôle supérieur de l'Etat constituent l'institution supérieure de contrôle des finances publiques (ISC) du Cameroun. Ils sont chargés de l'audit externe. »*

Article 2, alinéa 3 : *« Dans l'exercice de leurs attributions, les services du Contrôle supérieur de l'Etat effectuent : un contrôle de conformité et de régularité ; un contrôle financier ; un contrôle de performance ; un contrôle de l'environnement ; un contrôle des systèmes d'information. »*

Portée pour l'audit. Le décret reprend les trois types de l'INTOSAI (conformité, financier, performance) et leur ajoute deux contrôles, dont celui des systèmes d'information. Le vérificateur peut donc conduire une mission dont l'objet principal est un SI, ou intégrer un volet SI à une mission de régularité ou de performance.

1.4 Les systèmes d'information des finances publiques

1.4.1 Une chaîne de systèmes

Les finances publiques reposent sur une chaîne d'applications, de la préparation du budget à la reddition des comptes. Le cours ne décrit pas les applications réelles de l'État camerounais, qui évoluent et dont le détail n'est pas public : il raisonne sur des fonctions, que l'auditeur retrouve sous des noms différents d'une administration à l'autre.

Fonction	Ce que fait le système	Risque typique
Budget	Prépare, vote, notifie et modifie les crédits	Crédits modifiés sans acte, virements non autorisés
Dépense	Engage, liquide, ordonnance, transmet au comptable	Double paiement, service fait fictif, fractionnement
Recette	Liquide, émet et recouvre les titres de recettes	Titres annulés sans motif, recouvrements non reversés
Paie	Calcule et verse la solde	Agents fictifs, éléments de solde indus
Trésorerie	Exécute les paiements, tient les comptes de disponibilités	Paiement sur un compte bancaire modifié
Comptabilité	Produit les comptes et les états financiers	États qui ne correspondent pas aux opérations

Tableau 1.3. Les fonctions des systèmes financiers publics et leurs risques

1.4.2 Les points de contrôle de la chaîne

Dans une chaîne de systèmes, les anomalies naissent souvent aux **jointures** : là où une application transmet des données à une autre (de la dépense vers la trésorerie, de la paie vers la comptabilité), et là où une donnée de référence est modifiée (un RIB, un barème, un plafond). L'auditeur y place ses premiers tests.

Scénario Opérationnel · Dossier MINÉQUIR. Trois jointures

Constatation. Dans SIDÉPENSE, trois données conditionnent tous les paiements : le fichier des fournisseurs (et leurs RIB), la table des profils d'utilisateurs, et le fichier de transmission des mandats au poste comptable.

Analyse (confiance élevée). Le double paiement du prologue a utilisé deux de ces trois jointures : un RIB modifié et un profil resté actif. Une mission qui teste ces trois points en premier couvre une grande part du risque de la chaîne, pour un effort limité.

1.5 Ce que l'informatique change à la preuve

Le contrôle sur pièces repose sur une évidence : la pièce existe, elle est signée, elle est classée. Dans une administration informatisée, chacune de ces évidences change de forme.

Sur papier	Dans le système	Ce que l'auditeur doit vérifier
La pièce	Un enregistrement dans une base	Qu'il n'a pas été modifié après coup
La signature	Un droit d'accès utilisé	Que le titulaire du compte est bien celui qui a agi
Le visa	Un contrôle automatique	Que le paramétrage n'a pas été changé
Le classeur	Une extraction	Qu'elle est complète, et qu'il l'a obtenue lui-même
L'archive	Une sauvegarde	Qu'elle peut être restaurée

Tableau 1.4. Ce que l'informatique change à la preuve

Deux conséquences en découlent. D'abord, la **population** d'un test est dans le système, pas dans les classeurs. Ensuite, une preuve électronique ne vaut que si l'auditeur peut en établir l'intégrité : une extraction remise sur une clé, sans empreinte ni rapprochement, est une déclaration de l'audité. Le Chapitre 7 donne la manière de faire.

Note

Une réponse de plus. Parce que la preuve électronique peut manquer ou être incertaine, le cours admet trois réponses pour chaque contrôle testé : OUI, NON et NEK (connaissance insuffisante). Elles viennent d'un programme de recherche sur l'audit, l'auditologie, qui cherche à mesurer ce que l'auditeur ne sait pas [24], [25]. Le cours n'en garde que l'essentiel : dire ce que l'on ne sait pas, plutôt que de le cacher sous un OUI ou un NON.

Application Vérificateur

Avant la mission, demandez la liste des applications qui produisent les opérations de votre périmètre, avec, pour chacune, le service propriétaire et l'interlocuteur technique. Cette liste est la première pièce de votre dossier permanent.

Application Juge des comptes

Un compte produit par une application n'est fiable que si les contrôles de l'application le sont. Lorsque vous relevez une anomalie dans un compte, demandez quel contrôle de l'application aurait dû l'empêcher : la réponse oriente l'instruction.

Application Auditeur interne

Votre rapport n'est pas lu que par votre direction : l'article 5 du décret n° 2013/287 le fait transmettre au CONSUPE (Chapitre 4). Rédigez vos constats SI comme s'ils devaient être repris par un vérificateur.

❍

★ À retenir

- **Contrôler n'est pas auditer.** Le contrôle est exercé par l'entité ; l'audit est un examen indépendant au profit d'un tiers.
- **Cinq éléments.** Critère, preuve, constatation, conclusion, opinion ; le critère est écrit avant le test.
- **Une assurance, pas une certitude.** Raisonnable ou limitée, choisie au mandat, et formulée en conséquence.
- **Trois types d'audit, un même SI.** L'audit des SI sert l'audit financier, de conformité et de performance.
- **Une compétence écrite.** Le décret n° 2013/287 compte le contrôle des SI parmi les cinq contrôles du CONSUPE.
- **Les jointures d'abord.** Les données de référence et les transmissions entre applications concentrent le risque.
- **La preuve change de forme.** Population dans le système, intégrité à établir, trois réponses possibles.

✍ Exercice 1.1. Qui fait quoi ? ★☆☆

Pour chacune des situations suivantes, dites s'il s'agit d'un contrôle, d'un audit, d'une inspection ou d'une vérification, et justifiez.

(a) Le chef du service de la liquidation vérifie chaque matin la liste des mandats saisis la veille.

(b) Un vérificateur du CONSUPE examine l'exécution du budget 2025 de la DAF du MINÉQUIR.

(c) L'inspecteur général du ministère se rend à la DAF après un article de presse.

(d) SIDÉPENSE refuse un engagement supérieur au crédit disponible.

✍ Exercice 1.2. Les cinq éléments ★☆☆

Dans le dossier CAPNO, le fichier de paie de décembre compte 4 312 agents, dont 12 partagent le même compte bancaire avec au moins un autre agent. Identifiez, dans cette phrase et dans la suite que vous imaginerez, un critère, une preuve, une constatation et une conclusion.

✍ Exercice 1.3. Choisir l'assurance ★★☆

On vous confie trois jours pour examiner la paie de la CAPNO.

(a) Quel niveau d'assurance pouvez-vous donner ? Pourquoi ?

(b) Rédigez la phrase de conclusion correspondante, dans les deux cas : vous n'avez rien trouvé ; vous avez trouvé 37 agents qui ne figurent pas au fichier du personnel.

✍ Exercice 1.4. Cartographier ★★★

Pour le projet e-RECETTES de Bafoussam (dématérialisation des recettes), dressez le tableau des fonctions du système, des jointures avec les autres systèmes (trésorerie, comptabilité), et du risque principal à chaque jointure. Dites quelles trois jointures vous testeriez en premier, et pourquoi.

● Note

Transition. Ce chapitre a posé le vocabulaire et désigné l'objet : les systèmes qui portent les finances publiques. Le Chapitre 2 présente ce que l'auditeur y cherche avant tout : le système de contrôle interne.

2

LE SYSTÈME DE CONTRÔLE INTERNE EN ENVIRONNEMENT INFORMATISÉ

« L'organisation est-elle sous contrôle ? »

Question à laquelle le Référentiel COSO veut permettre de répondre

Niveau : *Fondamental* • Chapitre 1.

✦ Objectifs du chapitre

- ➢ Définir le contrôle interne selon le COSO 2013 et en expliquer les quatre idées clés.
- ➢ Énoncer les trois catégories d'objectifs et les illustrer dans une administration financière.
- ➢ Présenter les cinq composantes et les dix-sept principes, et dire ce que chacun exige du système d'information.
- ➢ Classer un contrôle selon son moment (préventif, détectif, correctif) et son mode (manuel, automatisé, semi-automatisé).
- ➢ Distinguer les contrôles généraux informatiques des contrôles d'application, et expliquer pourquoi les premiers conditionnent les seconds.
- ➢ Traduire la séparation entre ordonnateur et comptable, et entre les étapes de la dépense, en profils d'une application.
- ➢ Énoncer les limites du contrôle interne.

Pourquoi ce chapitre

Le prologue a posé une question : qu'est-ce qui aurait dû empêcher le double paiement ? La réponse porte un nom, le *système de contrôle interne*. Ce chapitre dit ce qu'il est ; le Chapitre 3 dit comment l'évaluer. Ensemble, ils forment le cœur du cours : tous les chapitres de la Partie IV appliquent la même grille, domaine par domaine.

© *MaletYon*

2.1 Qu'est-ce que le contrôle interne ?

2.1.1 La définition du COSO

Le cadre de référence le plus utilisé au monde est celui du COSO (*Committee of Sponsoring Organizations of the Treadway Commission*), dans sa version de 2013, traduite en français par l'IFACI [3], [4].

Définition

Contrôle interne : processus mis en œuvre par l'organe de gouvernance, la direction et le personnel, destiné à fournir une assurance raisonnable quant à la réalisation d'objectifs liés aux opérations, à l'information (*reporting*) et à la conformité.

Système de contrôle interne (SCI) : l'ensemble organisé des dispositifs de contrôle interne d'une entité, considéré comme un tout ; c'est lui que l'auditeur évalue.

Définition du contrôle interne reformulée d'après le COSO 2013.

La définition contient quatre idées, que l'auditeur public retrouve dans son propre métier.

1. **Un processus, pas un document.** Un manuel de procédures que personne n'applique n'est pas un contrôle interne.
2. **L'affaire de tous.** Il est porté par l'ordonnateur, le chef de service, l'agent de saisie, l'informaticien, et pas seulement par le contrôleur.
3. **Une assurance raisonnable.** Le coût d'un contrôle ne doit pas dépasser le risque qu'il traite ; aucun dispositif n'empêche tout.
4. **Des objectifs.** On ne contrôle pas « en général », mais en vue d'objectifs précis : sans objectif, pas de risque, et sans risque, pas de contrôle à justifier.

2.1.2 Trois catégories d'objectifs

Catégorie	Question	Exemple au MINÉQUIR
Opérations	Les activités sont-elles efficaces, les ressources protégées ?	Chaque facture n'est payée qu'une fois, au bon créancier
Information	L'information produite est-elle fiable ?	Le compte administratif reflète les mandats réellement émis
Conformité	Les lois et règlements sont-ils respectés ?	Le circuit engagement, liquidation, ordonnancement, paiement est respecté

Tableau 2.1. Les objectifs du contrôle interne

2.1.3 Le contrôle interne dans le secteur public

L'INTOSAI a adapté le cadre du COSO au secteur public dans ses lignes directrices INTOSAI GOV 9100. Elles ajoutent deux préoccupations propres à l'administration : la **protection des ressources publiques** contre la perte, le gaspillage et l'usage abusif, et la conduite des opérations dans le respect de l'**éthique** du service public. Le cours retient le COSO 2013 comme cadre de travail, parce qu'il est le plus récent et le seul dont le texte est dans le dossier des normes, et lit chaque principe avec ces deux préoccupations.

Au Cameroun, l'évaluation des structures de contrôle interne est une mission écrite du CONSUPE.

⚖ Jurisprudence & Droit applicable

Loi Décret n° 2013/287, article 28, alinéa 1 [30] : les sections des divisions d'inspection sont chargées, chacune dans son domaine de compétence, *« de la préparation et de l'exécution des opérations de vérification ; du suivi et de l'évaluation des activités des structures de contrôle interne ; de la tenue de la documentation technique et du fichier. »*

Portée pour l'audit. Le vérificateur ne se contente pas de relever des irrégularités : il évalue les dispositifs qui auraient dû les empêcher. L'article 27 place par ailleurs les systèmes d'information dans le champ d'une section de la division chargée des administrations publiques.

2.2 Cinq composantes, dix-sept principes

Le COSO organise le contrôle interne en **cinq composantes**, détaillées en **dix-sept principes**. Un dispositif n'est efficace que si les cinq composantes sont mises en place, fonctionnent, et fonctionnent conjointement : une excellente activité de contrôle ne compense pas une direction qui la contourne.

Composante	N°	Principe (reformulé)
Environnement de contrôle	1	S'engager en faveur de l'intégrité et de l'éthique
	2	Faire surveiller le contrôle interne par une instance indépendante de la direction
	3	Définir les structures, les pouvoirs et les responsabilités
	4	Développer et retenir des personnes compétentes
	5	Faire rendre compte chacun de ses responsabilités de contrôle
Évaluation des risques	6	Fixer des objectifs assez clairs pour en identifier les risques
	7	Identifier et analyser les risques
	8	Évaluer le risque de fraude
	9	Identifier et analyser les changements significatifs
Activités de contrôle	10	Choisir et mettre en place des activités de contrôle qui réduisent les risques
	11	Choisir et mettre en place des contrôles généraux informatiques
	12	Déployer les contrôles par des politiques et des procédures
Information et communication	13	Produire et utiliser une information pertinente et de qualité
	14	Communiquer en interne sur le contrôle interne
	15	Communiquer avec les tiers
Pilotage	16	Conduire des évaluations continues ou ponctuelles
	17	Évaluer les déficiences et les communiquer à temps

Tableau 2.2. Les composantes et les principes du COSO 2013 (reformulation du cours)

2.2.1 Les principes vus depuis le système d'information

L'auditeur des SI lit chaque principe avec une question : *qu'est-ce que ce principe exige du système d'information, et quelle pièce le prouve ?* Le Tableau 2.3 en donne la réponse pour une administration financière. C'est la base du questionnaire de contrôle interne du Chapitre 3.

N°	Ce que le principe exige du SI	Pièce que l'auditeur peut demander
1	Une charte d'usage des outils informatiques, connue des agents	Charte, accusés de réception
2	Une instance qui examine les risques informatiques	Comptes rendus du comité de direction ou d'un comité dédié
3	Des rôles écrits pour la cellule informatique et les propriétaires d'application	Organigramme, décisions de nomination, délégations
4	Des compétences informatiques entretenues	Plan de formation
5	Des propriétaires d'application qui valident les droits	Revues des habilitations signées
6	Des objectifs écrits de disponibilité et de sécurité	Schéma directeur, politique de sécurité
7	Une analyse des risques informatiques	Cartographie des risques
8	Une analyse des fraudes possibles par le système	Scénarios de fraude (Chapitre 12)
9	L'analyse des changements majeurs (nouvelle application, migration)	Dossier de mise en service
10	Des contrôles dans les applications	Paramétrage, contrôles bloquants
11	Des contrôles généraux informatiques	Accès, changements, exploitation (section 2.4)
12	Des procédures informatiques écrites et appliquées	Procédures, preuves d'exécution
13	Des données fiables pour le pilotage	Rapprochements, contrôles de qualité
14	Une communication interne sur les règles	Notes de service
15	Des échanges fiables avec les tiers (banques, trésor, prestataires)	Conventions d'échange, contrats
16	Une surveillance des contrôles	Tableaux de bord, revues périodiques
17	Un suivi des déficiences	Plan d'action, suivi des recommandations

Tableau 2.3. Les dix-sept principes vus depuis le système d'information

Note

Le principe 11 concerne directement l'auditeur des SI. Le COSO y demande de choisir et de mettre en place des contrôles généraux sur les technologies : les accès, les changements, l'exploitation. Les Chapitres 9 et 10 les évaluent.

2.3 Classer les contrôles

2.3.1 Selon le moment

Définition

Contrôle préventif : empêche l'anomalie de se produire (SIDÉPENSE refuse un engagement supérieur au crédit disponible).

Contrôle détectif : repère l'anomalie après coup (la revue mensuelle des mandats émis hors des heures de service).

Contrôle correctif : corrige l'anomalie et ses effets (le recouvrement d'un paiement indu).

Un dispositif solide combine les trois. Le préventif est préférable, parce qu'il évite le dommage ; mais il peut être contourné, et seul le détectif révèle alors le contournement. Au MINÉQUIR, tous les contrôles préventifs du circuit ont manqué, et seuls deux contrôles détectifs ont fonctionné (Chapitre 0).

2.3.2 Selon le mode d'exécution

Mode	Forces	Faiblesses
Manuel (un visa)	Jugement humain, adaptable	Variable, oublié en fin de gestion, preuve souvent absente
Automatisé (un blocage)	Constant, exhaustif	Ne vaut que si le paramétrage est protégé ; une erreur se répète à chaque opération
Semi-automatisé (une liste d'anomalies examinée par un agent)	Combine exhaustivité et jugement	Dépend de l'exactitude de la liste et de la diligence de l'agent

Tableau 2.4. Les modes d'exécution d'un contrôle

2.3.3 Selon la portée

Définition

Contrôles généraux informatiques (CGI, *IT general controls*) : contrôles qui s'appliquent à l'environnement dans lequel les applications sont exploitées et maintenues : gestion des accès, gestion des changements, exploitation (sauvegardes, traitements, incidents).

Contrôles d'application : contrôles intégrés à une application, qui agissent sur les opérations : contrôles de saisie, de traitement, d'interface et de sortie.

★ Attention

Violation typique. Constater que SIDÉPENSE refuse tout mandat supérieur au crédit disponible, et conclure que le contrôle budgétaire est efficace. Or un compte d'administration peut modifier le crédit directement dans la base, sans acte et sans trace.

Règle : un contrôle d'application ne vaut que si les contrôles généraux qui le protègent (accès, changements) sont efficaces. L'auditeur les teste en premier.

2.4 Les contrôles généraux informatiques

Famille	Objectif	Contrôles typiques
Accès	Seules les personnes autorisées accèdent aux applications et aux données, avec les seuls droits nécessaires	Création et retrait des comptes, revue des droits, comptes à privilèges
Changements	Aucune modification de programme ou de paramètre n'est mise en service sans être demandée, testée et approuvée	Demande écrite, tests, approbation, journal des mises en service
Exploitation	Les traitements s'exécutent comme prévu, les incidents sont traités, les données sont sauvegardées	Planification, suivi des incidents, sauvegardes testées
Acquisition et développement	Les nouvelles applications répondent aux besoins et intègrent les contrôles	Cahier des charges, recette, réception

Tableau 2.5. Les quatre familles de contrôles généraux informatiques

L'ordre compte. Si les accès ne sont pas maîtrisés, n'importe qui peut modifier un paramètre ; si les changements ne le sont pas, un contrôle automatique peut être désactivé sans que personne ne le sache ; dans les deux cas, tester les contrôles d'application ne prouve plus rien. Le cours suit donc cet ordre : accès (Chapitre 9), changements et exploitation (Chapitre 10), puis contrôles d'application (Chapitre 11).

2.5 Séparer les tâches dans une application

2.5.1 Du principe au profil

Le droit des finances publiques sépare l'ordonnateur, qui engage, liquide et ordonnance, du comptable, qui paie après contrôle ; il sépare aussi les étapes de la dépense [23]. Dans une administration informatisée, ces séparations n'existent que si l'application les impose.

Définition

Séparation des tâches : répartition des étapes d'une opération entre des personnes différentes, de sorte qu'aucune ne puisse à elle seule réaliser et dissimuler une irrégularité.

Profil : ensemble de droits attribué dans une application (créer un engagement, liquider, ordonnancer, modifier un RIB). Un utilisateur peut avoir plusieurs profils : c'est leur combinaison qui crée, ou non, un conflit.

2.5.2 La matrice des profils de SIDÉPENSE

SIDÉPENSE connaît cinq profils : ENG (engagement), LIQ (liquidation), ORD (ordonnancement), FRS (gestion du fichier des fournisseurs, dont les RIB) et ADM (administration des comptes). Le Tableau 2.6 indique les combinaisons qui ne doivent jamais être réunies sur un même compte.

Paire	Pourquoi elle est interdite	Ce qu'elle permet
LIQ + ORD	L'ordonnancement contrôle la liquidation	Arrêter un montant et émettre seul le mandat
FRS + ORD	Le RIB doit être fixé par un autre que celui qui émet le mandat	Changer le bénéficiaire puis le payer
FRS + LIQ	Même raison, en amont	Créer un service fait au profit d'un compte choisi
ADM + tout profil métier	L'administrateur peut s'attribuer n'importe quel droit	Contourner toutes les séparations

Tableau 2.6. Les paires de profils incompatibles dans SIDÉPENSE

Scénario Opérationnel · Dossier MINÉQUIR. Le compte mbarga.j

Constatation. À la date du 28 décembre 2025, le compte `mbarga.j` détient les profils LIQ, ORD et FRS (matrice des profils extraite le 23 mars 2026).

Analyse (confiance élevée). Le compte réunit les trois paires interdites du Tableau 2.6 qui ne demandent pas l'administration. Un seul compte suffisait pour

modifier le RIB, liquider et ordonnancer : le contrôle interne du circuit reposait entièrement sur la confiance en une personne, et cette personne n'était plus en poste.

2.5.3 Quand on ne peut pas séparer

Dans un petit service, trois agents ne peuvent pas tenir cinq profils sans cumul. La pratique admet alors des **contrôles compensatoires** : une revue, par une personne indépendante, de toutes les opérations réalisées par un compte qui cumule des profils. Le contrôle compensatoire doit être écrit, exécuté et prouvé ; sinon, le cumul est une déficience.

2.6 Les limites du contrôle interne

Le COSO rappelle que le contrôle interne, même bien conçu, a des limites [4]. L'auditeur doit les connaître, pour ne pas reprocher à un dispositif ce qu'aucun dispositif ne peut empêcher, et pour savoir où chercher.

- **Le jugement humain** peut être erroné ; les décisions sont prises sous la contrainte du temps.
- **Les défaillances** existent : fatigue, erreur, oubli, surtout en fin de gestion.
- **La collusion** de deux personnes ou plus défait la séparation des tâches.
- **Le contournement par la direction** : un responsable peut passer outre un contrôle qu'il a lui-même mis en place.
- **Les événements extérieurs** échappent à l'entité.

Application Contrôleur financier

Le contrôle a priori que vous exercez est une activité de contrôle au sens du COSO (principe 10). S'il passe par SIDÉPENSE, demandez à voir le profil qui porte votre visa, et la liste des personnes qui le détiennent : votre visa ne vaut que si personne d'autre ne peut l'apposer.

Application Auditeur interne

Le COSO fait du pilotage (principes 16 et 17) une composante du contrôle interne : votre propre travail en fait partie. Gardez une liste des déficiences que vous avez signalées et de leur suivi ; le vérificateur la demandera.

★ À retenir

- **Un processus orienté vers des objectifs.** Le contrôle interne donne une assurance raisonnable sur les opérations, l'information et la conformité.
- **Cinq composantes, dix-sept principes.** Environnement, risques, activités de contrôle, information et communication, pilotage ; chacune doit être en place, fonctionner, et fonctionner avec les autres.
- **Chaque principe a une traduction informatique**, et une pièce qui la prouve.
- **Préventif, détectif, correctif ; manuel, automatisé, semi-automatisé.** Un dispositif solide combine les modes.
- **Les contrôles généraux d'abord.** Sans maîtrise des accès et des changements, aucun contrôle d'application n'est fiable.
- **La séparation se lit dans les profils.** Elle n'existe que si l'application l'impose ; sinon, il faut un contrôle compensatoire prouvé.
- **Une mission écrite du CONSUPE.** Le décret n° 2013/287 (art. 28) le charge d'évaluer les structures de contrôle interne.

✍ Exercice 2.1. Classer des contrôles ★☆☆

Classez chaque contrôle selon son moment et son mode.

(a) SIDÉPENSE refuse un engagement supérieur au crédit disponible.

(b) Le chef de la liquidation signe chaque soir la liste des mandats du jour, éditée par l'application.

(c) Le poste comptable rejette un mandat dont la facture scannée est illisible.

(d) La DAF émet un ordre de reversement après un paiement indu.

✍ Exercice 2.2. Composantes et principes ★☆☆

Rattachez chacun des manques suivants, relevés au MINÉQUIR, à une composante et à un principe du COSO : (a) aucune cartographie des risques de SIDÉPENSE ; (b) aucune procédure de désactivation des comptes lors des mutations ; (c) les anomalies de fin de gestion ne remontent jamais au directeur ; (d) la cellule informatique n'a aucune fiche de poste.

✍ Exercice 2.3. Une matrice des profils ★★☆

La DAF compte six utilisateurs de SIDÉPENSE : ABENA (ENG), BELLO (LIQ, ORD), CHOUPO (LIQ), DJOMO (ORD, FRS), ESSOMBA (FRS), FOUDA (ADM).

(a) Identifiez les comptes en conflit au regard du Tableau 2.6.

(b) Proposez une nouvelle répartition sans conflit, sans créer de compte.

(c) Si une répartition sans conflit est impossible, décrivez le contrôle compensatoire et la preuve qu'il doit laisser.

✍ Exercice 2.4. Les contrôles généraux d'abord ★★★

Le chef de la cellule informatique vous montre que SIDÉPENSE bloque désormais les doublons (même fournisseur, même montant, même facture). Dites quels contrôles généraux vous devez tester avant de conclure que ce blocage est efficace pour toute l'année 2026, quelle pièce vous demandez pour chacun, et ce que vous concluez si l'une de ces pièces manque.

● Note

Transition. Le contrôle interne est maintenant défini, composante par composante. Reste la question de l'auditeur : comment savoir s'il est efficace ? Le Chapitre 3 en donne la démarche, du questionnaire à la conclusion.

3

ÉVALUER LE SYSTÈME DE CONTRÔLE INTERNE

« Un contrôle mal conçu est inefficace, même exécuté à la lettre ; un contrôle bien conçu mais non exécuté ne protège de rien. »

Règle du cours

Niveau : *Intermédiaire* • Chapitre 2.

✦ Objectifs du chapitre

- ➢ Conduire l'évaluation d'un système de contrôle interne en cinq étapes : décrire, questionner, cheminer, évaluer la conception, tester le fonctionnement.
- ➢ Construire une matrice des risques et des contrôles pour un circuit financier informatisé.
- ➢ Utiliser un questionnaire de contrôle interne, en distinguant la réponse de l'audité de la preuve.
- ➢ Réaliser un test de cheminement et en tirer ce qu'il établit, et ce qu'il n'établit pas.
- ➢ Dimensionner un test de fonctionnement et coter le contrôle OUI, NON ou NEK.
- ➢ Classer les déficiences (déficience, déficience majeure) selon le COSO 2013.
- ➢ Formuler une conclusion sur l'efficacité du système de contrôle interne.

Pourquoi ce chapitre

Dans le prologue, la vérificatrice a coté huit contrôles. Elle savait quels contrôles attendre, comment les tester, et ce que voulait dire un NON. Ce chapitre donne cette démarche, pas à pas. Il est le plus important du cours : chaque chapitre de la Partie IV l'applique à un domaine, et le cas intégrateur la reprend en entier.

La question directrice est celle de l'article 28 du décret n° 2013/287 : évaluer les structures de contrôle interne. Elle se décompose en deux questions plus précises. *Le dispositif est-il conçu pour réduire les risques ? A-t-il fonctionné pendant toute la période ?*

© MaletYon

3.1 La démarche en cinq étapes

N°	Étape	Question	Production
1	Décrire	Comment le circuit fonctionne-t-il, et où sont les risques ?	Narratif, diagramme, matrice des risques et des contrôles
2	Questionner	Quels contrôles l'entité dit-elle exercer ?	Questionnaire de contrôle interne rempli
3	Cheminer	Le circuit fonctionne-t-il comme on me l'a décrit ?	Fiche de test de cheminement
4	Évaluer la conception	Ces contrôles, s'ils fonctionnent, réduisent-ils les risques ?	Cotation de la conception
5	Tester le fonctionnement	Ont-ils fonctionné toute la période ?	Feuilles de test, cotation finale

Tableau 3.1. Les cinq étapes de l'évaluation du contrôle interne

Les étapes s'enchaînent, et chacune peut arrêter la suivante. Un contrôle dont la conception est défaillante n'a pas à être testé dans son fonctionnement : il est déjà une déficience. Un contrôle que l'entité ne déclare pas, mais que la matrice des risques exige, est un NON dès l'étape 2. Les étapes 6 et 7, classer les déficiences et conclure, sont traitées aux sections 3.6 et 3.7.

3.2 Décrire le système

3.2.1 Le narratif et le diagramme

L'auditeur commence par décrire le circuit, avec les mots de l'entité : qui fait quoi, dans quel ordre, avec quel écran, et quelle trace reste. Le narratif s'accompagne d'un diagramme, qui fait apparaître les étapes, les acteurs et les points de contrôle.

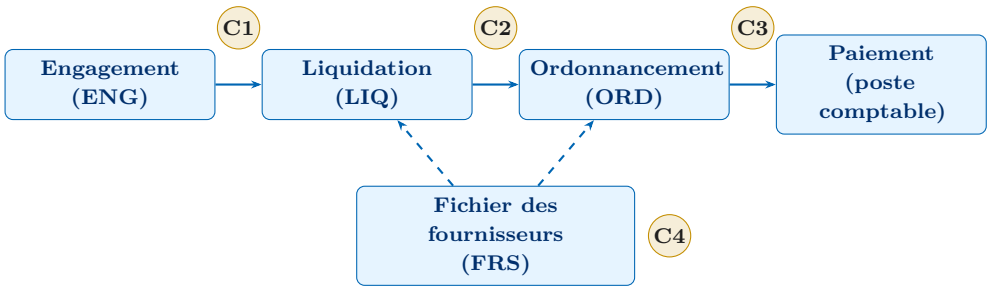


Figure 3.1. Le circuit de la dépense dans SIDÉPENSE et ses points de contrôle (C1 contrôle du crédit ; C2 contrôle de la liquidation ; C3 contrôle des doublons et des pièces ; C4 contrôle des modifications de RIB)

3.2.2 La matrice des risques et des contrôles

La description aboutit à une **matrice des risques et des contrôles** : pour chaque risque du circuit, le ou les contrôles qui doivent le couvrir. C'est la liste de ce que l'auditeur s'attend à trouver, établie *avant* d'interroger l'entité, à partir des textes, des référentiels et de son expérience.

Risque	Contrôle attendu	Type	Principe
R1. Un agent parti agit encore	Désactivation du compte à la date de la mutation	Préventif	11
R2. Un agent émet seul un mandat	Profils LIQ et ORD jamais réunis	Préventif	10, 11
R3. Le bénéficiaire est changé	Seconde validation de tout RIB modifié	Préventif	10
R4. Une facture est payée deux fois	Blocage des doublons dans l'application	Préventif	10
R5. Le mandat n'est pas justifié	Vérification des pièces jointes par le poste comptable	Préventif	10
R6. Une opération ne laisse pas de trace	Journalisation des opérations sensibles	Détectif	13
R7. Une anomalie de fin de gestion passe	Revue des mandats émis hors heures et des RIB modifiés	Détectif	16
R8. Les traces disparaissent	Conservation protégée des journaux	Détectif	13

Tableau 3.2. Matrice des risques et des contrôles du circuit de la dépense (MINÉQUIR)

★ Attention

Violation typique. Construire la liste des contrôles à partir de ce que l'entité déclare faire. On ne trouve alors que des contrôles qui existent ; ceux qui manquent n'apparaissent jamais.

Règle : la matrice part des risques, pas des contrôles déclarés. Un risque sans contrôle en face est déjà une constatation.

3.3 Questionner : le questionnaire de contrôle interne

Définition

Questionnaire de contrôle interne (QCI) : liste de questions fermées, tirée de la matrice des risques et des contrôles, qui demande à l'entité si chaque contrôle attendu existe, qui l'exerce, à quelle fréquence, et quelle trace il laisse.

Une question bien formée appelle une réponse vérifiable. « Les droits sont-ils bien gérés ? » n'appelle qu'un « oui ». « Qui désactive le compte d'un agent muté, dans quel délai, et sur quelle pièce ? » appelle une réponse que l'on peut tester.

N°	Question	Réponse déclarée	Pièce demandée
1	Qui informe la cellule informatique d'une mutation, et sous quel délai ?	« Le service du personnel, en principe »	Procédure, exemples de notifications
2	Qui désactive le compte, et quelle trace reste ?	« La cellule, dès qu'elle est informée »	Journal des désactivations 2025
3	Les profils LIQ et ORD peuvent-ils être réunis sur un compte ?	« Non »	Matrice des profils
4	Qui peut modifier un RIB, et avec quelle validation ?	« Le service de la liquidation »	Liste des détenteurs du profil FRS, journal des modifications
5	L'application bloque-t-elle les doublons ?	« Oui, le numéro de facture est unique »	Paramétrage, essai
6	Une revue des mandats de fin de gestion est-elle faite ?	« Le DAF suit les gros montants »	Comptes rendus de revue

Tableau 3.3. Extrait du QCI sur le circuit de la dépense, rempli par la DAF et la cellule informatique

Note

Une réponse au QCI est une déclaration, pas une preuve. Elle dit ce que l'entité croit faire. Le cheminement et les tests disent ce qu'elle fait. La réponse à la question 5 en est l'exemple : le numéro de facture est bien unique, mais le suffixe « bis » suffit à en faire un autre numéro. Le contrôle déclaré existe ; il ne couvre pas le risque.

3.4 Cheminer : le test de cheminement

Définition

Test de cheminement (*walkthrough*) : suivi d'une opération réelle, du début à la fin du circuit, en examinant à chaque étape l'écran utilisé, la trace produite et le contrôle exercé. Il établit que l'auditeur a compris le circuit et que les contrôles existent tels qu'ils sont décrits ; il n'établit pas qu'ils ont fonctionné pendant toute la période.

Mme NGO BIYONG choisit le mandat 2025-08817, le premier paiement du décompte n° 3, et le suit dans SIDÉPENSE, assise à côté de l'agent qui l'a traité.

Étape	Ce que la vérificatrice observe	Trace obtenue
Engagement	Le crédit est contrôlé : un essai à un montant supérieur est refusé	Capture de l'écran de refus
Liquidation	L'agent joint la facture et le PV de réception, puis valide	Historique du mandat
Ordonnancemei	Un autre agent valide ; l'application ne vérifie pas qu'il est différent du liquidateur	Historique (deux noms différents, par choix et non par contrainte)
Transmission	Le mandat part au poste comptable avec ses pièces scannées	Bordereau électronique
Paiement	Le poste comptable vérifie les pièces, puis paie	Visa électronique, relevé

Tableau 3.4. Test de cheminement du mandat 2025-08817

Scénario Opérationnel · Dossier MINÉQUIR. Ce que montre le cheminement

Constatation. Sur le mandat 2025-08817, liquidation et ordonnancement ont été faits par deux agents différents. L'application n'empêche pas qu'un même agent fasse les deux.

Analyse (confiance élevée). La séparation a été respectée sur ce mandat, mais par habitude, pas par contrainte. Un cheminement réussi ne prouve donc pas que le contrôle existe : il montre ici que la séparation dépend de la bonne volonté des agents. C'est un défaut de *conception*, que le cheminement suffit à établir.

3.5 Évaluer la conception, tester le fonctionnement

3.5.1 Deux questions distinctes

Évaluation	Question	Comment
Conception	Le contrôle, s'il fonctionne, réduit-il le risque ?	Lecture de la procédure, du paramétrage, cheminement
Fonctionnement	Le contrôle a-t-il fonctionné comme prévu pendant toute la période ?	Test d'un échantillon d'exécutions et de leurs traces, ou test du paramétrage

Tableau 3.5. Conception et fonctionnement d'un contrôle

3.5.2 Combien d'exécutions tester ?

Le fonctionnement d'un contrôle manuel se teste sur un échantillon dont la taille dépend de la fréquence du contrôle. Le cours retient les ordres de grandeur du Tableau 3.6 ; ce sont des conventions de travail, que la méthodologie de chaque institution peut fixer autrement.

Fréquence du contrôle	Exécutions par an	Échantillon indicatif
Annuelle	1	1
Trimestrielle	4	2
Mensuelle	12	2 à 5
Hebdomadaire	52	5 à 15
Quotidienne	environ 250	20 à 40
Plusieurs fois par jour	plus de 250	25 à 60
Automatisée		Un essai qui doit passer et un qui doit être bloqué, si les contrôles généraux sont efficaces

Tableau 3.6. Tailles d'échantillon indicatives (convention du cours)

3.5.3 Coter

- **oui** : le contrôle est bien conçu et a fonctionné sur tout l'échantillon (ou l'essai automatisé a donné le résultat attendu).
- **non** : la conception est défaillante, ou une exécution au moins a manqué, ou la trace que le contrôle devait produire n'existe pas.
- **nek** : malgré des diligences normales, l'auditeur ne peut pas conclure : pièce non remise, sources contradictoires qu'il ne peut pas départager. Il écrit les diligences faites et relance.

Point de contrôle · C-ACC-01 · Comptes des agents mutés

Objectif. Aucun agent muté ou parti ne peut agir dans SIDÉPENSE.
Risque couvert. R1 : un compte resté actif est utilisé par son ancien titulaire ou par un tiers.
Critère. Le compte est désactivé au plus tard à la date d'effet de la mutation (procédure à écrire ; à défaut, principe 11 du COSO).
Test de conception. Existe-t-il une notification du service du personnel à la cellule informatique ? Réponse : non, aucune procédure écrite.
Test de fonctionnement. Rapprocher la liste des 31 mutations et départs de 2025 de la liste des comptes actifs au 23 mars 2026.
Résultat. 9 comptes sur 31 sont encore actifs, dont `mbarga.j`.
Cote. NON (conception et fonctionnement défaillants).

★ Attention

Violation typique. Coter NEK un contrôle dont la procédure exige un procès-verbal, alors que l'entité a confirmé qu'il n'en existe aucun.

Règle : l'absence d'une trace exigée par le critère est un NON établi. NEK est réservé au cas où l'auditeur ne peut pas savoir.

Scénario Opérationnel · Dossier MINÉQUIR. Le contrôle 5 est levé

Constatation. Le 2 avril 2026, le poste comptable remet les visas électroniques des mandats 2025-08817 et 2025-09342. Les deux portent la vérification des pièces jointes ; les pièces étaient complètes et lisibles.

Analyse (confiance élevée). Le contrôle des pièces a fonctionné tel qu'il est conçu : il vérifie la présence et la lisibilité des pièces, pas leur unicité. Le contrôle 5 passe de NEK à OUI. Le double paiement relève d'un autre contrôle, le blocage des doublons (contrôle 4), coté NON.

3.6 Classer les déficiences

3.6.1 Deux niveaux

Le COSO 2013 distingue deux niveaux de déficience [4].

Définition

Déficience du contrôle interne : insuffisance d'une ou plusieurs composantes ou d'un ou plusieurs principes, qui réduit la probabilité que l'entité atteigne ses objectifs.

Déficience majeure : déficience, ou combinaison de déficiences, qui réduit *fortement* cette probabilité.

Définitions reformulées d'après le COSO 2013, § 138.

Deux règles du COSO (§§ 139 et 140) commandent la conclusion. Lorsqu'une déficience majeure existe, l'entité ne peut pas conclure que son système de contrôle interne est efficace. Et une déficience majeure d'une composante, ou d'un principe, ne peut pas être compensée par le bon fonctionnement d'une autre composante, ou d'autres principes.

3.6.2 Une grille de classement

Pour décider si une déficience est majeure, le cours retient quatre questions. Elles ne remplacent pas le jugement ; elles l'obligent à s'expliquer.

N°	Question	Penche vers « majeure » si…
1	Quelle perte, ou quelle irrégularité, la déficience rend-elle possible ?	Elle porte sur des montants importants ou sur tout le circuit
2	Avec quelle probabilité ?	Rien n'empêche qu'elle se produise, ou elle s'est déjà produite
3	Un contrôle compensatoire la couvre-t-il, et est-il prouvé ?	Aucun, ou il n'est pas prouvé
4	Ouvre-t-elle une possibilité de fraude ?	Oui, en particulier par contournement de la séparation des tâches

Tableau 3.7. Grille de classement des déficiences (convention du cours)

3.6.3 Les déficiences du MINÉQUIR

Les cinq NON de la matrice ne font pas cinq déficiences : plusieurs contrôles manquants peuvent relever d'une même cause. La vérificatrice les regroupe en trois déficiences.

	Déficience	Contrôles	Principes	Classement
A	Les accès ne sont pas maîtrisés : comptes des partants actifs, séparation LIQ / ORD non imposée	1, 2	10, 11	Majeure (questions 1 à 4)
B	Le fichier des fournisseurs n'est pas protégé et les doublons ne sont pas bloqués	3, 4	10	Déficience
C	Aucune revue des opérations de fin de gestion	7	16	Déficience

Tableau 3.8. Classement des déficiences du circuit de la dépense

Note

Pourquoi B n'est pas majeure à elle seule. Si les accès étaient maîtrisés, une modification de RIB et un mandat en double exigeraient deux personnes différentes, et la collusion resterait nécessaire. C'est la déficience A qui rend B dangereuse. Le classement dit cette relation : la combinaison A et B est majeure, et c'est elle qui a permis le double paiement.

3.7 Conclure sur l'efficacité du système

3.7.1 La lecture de conformité

Lecture auditologique · Circuit de la dépense, après les tests

Constatation. Sur huit contrôles attendus, trois existent et fonctionnent (contrôles 5, 6 et 8), cinq manquent ou n'ont pas fonctionné. Aucun contrôle ne reste à établir.

Analyse (confiance élevée). Les contrôles qui fonctionnent sont la vérification des pièces et deux contrôles de détection. La déficience majeure A porte sur les accès, dont dépendent tous les autres contrôles.

3 oui sur 8 contrôles applicables · 0 nek

3.7.2 Une échelle simple

Pour situer un domaine et suivre son évolution d'une mission à l'autre, le cours propose une échelle à cinq niveaux. C'est une convention pédagogique, pas une norme : elle aide à dire où l'on en est, elle ne remplace pas la conclusion.

Niveau	Nom	Description
0	Inexistant	Le risque n'est pas identifié ; aucun contrôle
1	Informel	Des contrôles existent, par habitude, sans procédure ni trace
2	Défini	Les contrôles sont écrits, mais leur exécution n'est pas prouvée
3	Appliqué	Les contrôles sont écrits, exécutés et tracés ; les tests de fonctionnement sont concluants
4	Piloté	Les contrôles sont surveillés, les déficiences suivies et corrigées

Tableau 3.9. Échelle de maturité du contrôle interne (convention du cours)

Le circuit de la dépense du MINÉQUIR est au niveau 1 : la séparation des tâches existe par habitude (cheminement), sans être imposée ni écrite.

3.7.3 Formuler la conclusion

La conclusion porte sur un objectif, une période et un périmètre, et dit sur quoi elle repose. Celle de Mme NGO BIYONG s'écrit ainsi :

> *Sur la base des travaux décrits au rapport (matrice des risques et des contrôles, questionnaire, test de cheminement, tests de fonctionnement sur l'exercice 2025), le système de contrôle interne du circuit de la dépense de la DAF du MINÉQUIR n'est pas efficace : il présente une déficience majeure dans la maîtrise des accès à SIDÉPENSE, qui a permis un double paiement de 187 450 000 FCFA.*

Papier de travail

Le dossier d'évaluation d'un circuit contient, dans cet ordre :

1. le narratif et le diagramme, validés par l'entité ;
2. la matrice des risques et des contrôles, datée ;
3. le QCI rempli, avec le nom et la fonction de chaque répondant ;
4. la fiche du test de cheminement et ses traces ;
5. une feuille de test par contrôle : conception, échantillon, résultat, cote, pièces ;
6. le tableau de classement des déficiences, avec la réponse aux quatre questions pour chaque déficience majeure ;
7. la conclusion, et la référence des pièces sur lesquelles elle repose.

Application Vérificateur

L'article 28 du décret n° 2013/287 vous charge d'évaluer les structures de contrôle interne. Joignez à votre rapport la matrice des risques et des contrôles : elle montre que votre conclusion repose sur une liste établie à l'avance, et non sur ce que l'entité a bien voulu montrer.

Application Inspecteur

Une inspection déclenchée par une alerte peut sauter l'étape du QCI, mais pas celle du cheminement : suivez au moins une opération réelle dans l'application avant de conclure sur un circuit.

Application Auditeur interne

Votre évaluation annuelle du contrôle interne sera relue par le CONSUPE. Tenez une matrice des risques et des contrôles par circuit, et mettez-la à jour à chaque changement d'application : c'est votre meilleure défense devant un vérificateur.

★ À retenir

- **Cinq étapes.** Décrire, questionner, cheminer, évaluer la conception, tester le fonctionnement ; puis classer et conclure.
- **La matrice part des risques**, pas des contrôles déclarés.
- **Le QCI recueille des déclarations** ; le cheminement et les tests produisent des preuves.
- **Conception d'abord.** Un contrôle mal conçu est une déficience, sans test de fonctionnement.
- **Trois cotes.** OUI, NON, NEK ; l'absence d'une trace exigée est un NON.
- **Deux niveaux de déficience.** Une déficience majeure interdit de conclure à l'efficacité, et ne se compense pas.
- **Une conclusion située.** Un objectif, une période, un périmètre, et les travaux sur lesquels elle repose.

✍ Exercice 3.1. Formuler des questions ★☆☆

Réécrivez les questions suivantes du QCI pour qu'elles appellent une réponse vérifiable : (a) « Les sauvegardes sont-elles faites ? » ; (b) « Les mots de passe sont-ils sûrs ? » ; (c) « Le fichier de paie est-il contrôlé ? ».

✍ Exercice 3.2. Dimensionner et coter ★☆☆

Le chef de la liquidation signe chaque soir la liste des mandats du jour.

(a) Combien de listes testez-vous pour l'exercice 2025 ?

(b) Sur l'échantillon, deux listes ne sont pas signées. Quelle cote ?

(c) Les listes de novembre n'ont pas été retrouvées, et le service affirme qu'elles ont été signées. Quelle cote pour novembre, et que faites-vous ?

✍ Exercice 3.3. Une matrice pour la paie ★★☆

Construisez la matrice des risques et des contrôles du circuit de la paie de la CAPNO (entrée d'un agent, modification d'un élément de solde, départ, calcul, virement), avec au moins six risques, le contrôle attendu pour chacun, son type et le principe du COSO correspondant.

✍ Exercice 3.4. Classer et conclure ★★★

À la CAPNO, l'auditeur interne relève : (1) 37 agents payés ne figurent pas au fichier du personnel ; (2) le profil qui crée un agent peut aussi valider la paie ; (3) aucun rapprochement entre la paie et le fichier du personnel n'est fait ; (4) les sauvegardes

ne sont pas testées.

(a) Regroupez ces constats en déficiences, et classez chacune à l'aide du Tableau 3.7.

(b) Rédigez la conclusion sur l'efficacité du contrôle interne de la paie.

(c) Dites ce qui changerait votre classement.

Note

Transition. La Partie I a donné l'objet et la méthode : évaluer le contrôle interne d'un système d'information. Reste à savoir au nom de quoi l'on évalue. Le Chapitre 4 présente les institutions qui contrôlent les systèmes d'information publics au Cameroun, et leurs compétences.

partie II

Cadre Institutionnel et Normatif

© MaletYon

4

QUI CONTRÔLE LES SI PUBLICS AU CAMEROUN

« Le mandat précède la méthode. »

Règle du cours

Niveau : *Fondamental* • Chapitre 1.

✦ Objectifs du chapitre

- Citer les dispositions du décret n° 2013/287 qui fondent le contrôle des systèmes d'information par le CONSUPE.
- Expliquer le rôle de l'ANTIC dans l'audit de sécurité des systèmes d'information publics, au titre de la loi n° 2010/012.
- Situer la Chambre des Comptes et expliquer pourquoi elle rencontre les systèmes d'information par extension.
- Situer les autres acteurs : inspections générales, contrôle financier, audit interne, CDBF.
- Déterminer, pour une situation donnée, qui est compétent et comment les interventions s'articulent.

Pourquoi ce chapitre

Dans le prologue, la vérificatrice a exigé une extraction de SIDÉPENSE sans avoir à demander la permission. Elle le pouvait parce qu'un texte lui en donne le droit. Ce chapitre présente ces textes. Il répond à trois questions : *qui a compétence pour contrôler un système d'information public ? Sur quoi porte chaque compétence ? Que devient un constat d'un organe à l'autre ?*

Un principe de méthode gouverne le chapitre : seuls sont cités entre guillemets les textes lus dans leur version disponible. Les autres sont décrits dans leurs grandes lignes, et l'auditeur doit les lire avant de les invoquer.

© MaletYon

4.1 Le Contrôle Supérieur de l'État

4.1.1 Une institution supérieure de contrôle

Le Contrôle Supérieur de l'État est organisé par le décret n° 2013/287 du 4 septembre 2013 [30]. Ses services relèvent de l'autorité directe du Président de la République, à qui ils rendent compte, et sont dirigés par un ministre délégué à la Présidence (art. 1).

Jurisprudence & Droit applicable

Loi Décret n° 2013/287, article 2, alinéa 1 : *« Les services du Contrôle supérieur de l'Etat constituent l'institution supérieure de contrôle des finances publiques (ISC) du Cameroun. Ils sont chargés de l'audit externe. »*

Article 2, alinéa 3 : *« Dans l'exercice de leurs attributions, les services du Contrôle supérieur de l'Etat effectuent : un contrôle de conformité et de régularité ; un contrôle financier ; un contrôle de performance ; un contrôle de l'environnement ; un contrôle des systèmes d'information. »*

Article 2, alinéa 4 : *« Les contrôles sont effectués par les vérificateurs du Contrôle supérieur de l'Etat sur pièces et sur place. A cet effet, et nonobstant les contrôles effectués par les autres organes de contrôle, les responsables des structures auditées sont tenus de présenter les pièces relatives à la période auditée. »*

Portée pour l'audit. Trois conséquences pratiques. Le contrôle des systèmes d'information est une compétence *explicite*, écrite à côté du contrôle de régularité : il n'a pas à être déduit d'une autre mission. Il s'exerce sur place, donc dans l'application, et pas seulement sur les documents qui en sortent. Enfin, l'obligation de présenter les pièces vaut « nonobstant » les autres contrôles : une entité ne peut pas refuser une extraction au motif que l'ANTIC ou une inspection l'a déjà auditée.

4.1.2 Le champ du contrôle

L'article 2, alinéa 1, fixe un champ large. Il couvre notamment les services publics, les établissements publics, les collectivités territoriales décentralisées, les entreprises publiques et parapubliques, les projets à financements extérieurs, et les organismes qui bénéficient de concours financiers, d'avals ou de garanties de l'État. Partout où l'une de ces entités exploite un système d'information, le contrôle des SI s'applique.

L'organisation des services en tire les conséquences. L'article 27, alinéa 2, crée au sein de la Division des inspections et de contrôle des administrations publiques une *section des administrations financières, économiques, sociales et des systèmes d'informations*. L'article 28 charge chaque section du suivi et de l'évaluation des activités des structures de contrôle interne (Chapitre 2).

4.1.3 Les suites : le CDBF

⚖ Jurisprudence & Droit applicable

Loi Décret n° 2013/287, article 3, alinéa 1 : *« Les services du Contrôle supérieur de l'Etat concourent à la sanction des ordonnateurs et des gestionnaires des deniers publics, dans les conditions prévues par les lois et règlements en vigueur. A ce titre, le ministre délégué en charge du Contrôle supérieur de l'Etat préside le conseil de discipline budgétaire et financière, dont l'organisation et le fonctionnement sont fixés par un texte particulier. »*

Portée pour l'audit. Un constat du vérificateur peut fonder une poursuite devant le Conseil de discipline budgétaire et financière (CDBF). Il doit donc être établi avec la rigueur d'une pièce de procédure : critère cité, preuve conservée, contradictoire respecté (Chapitre 8).

4.1.4 Le lien avec l'audit interne

⚖ Jurisprudence & Droit applicable

Loi Décret n° 2013/287, article 5 : *« (1) Les structures d'audit interne transmettent aux services du Contrôle supérieur de l'Etat, à la diligence des chefs de départements ministériels concernés, un exemplaire de chacun des rapports rédigés à la suite de toutes les interventions menées au cours de l'exercice, ainsi qu'un exemplaire du rapport annuel d'activités. (2) Après examen des rapports visés à l'alinéa 1er ci-dessus, les services du Contrôle supérieur de l'Etat peuvent, le cas échéant, saisir le conseil de discipline budgétaire et financière. »*

🔍 Scénario Opérationnel · Dossier CAPNO. Un rapport qui voyage

Constatation. Le 15 mai 2026, M. HAMADOU, auditeur interne de la CAPNO, remet son rapport sur la paie : 37 agents payés ne figurent pas au fichier du personnel. Conformément à l'article 5, le rapport est transmis au CONSUPE.

Analyse (confiance élevée). Le rapport de l'auditeur interne devient une pièce que le CONSUPE peut examiner, et sur laquelle il peut saisir le CDBF. Ses constats doivent donc être reproductibles par un vérificateur : extraction datée, empreinte, critère cité. Un rapport qui écrit seulement « des anomalies ont été relevées dans la paie » ne pourra pas être repris.

4.2 L'ANTIC : l'audit de sécurité

L'Agence nationale des technologies de l'information et de la communication (ANTIC) est le régulateur de la sécurité électronique. La loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité définit l'audit de sécurité et en confie la régulation à l'Agence [21].

Jurisprudence & Droit applicable

Loi Loi n° 2010/012, article 4, point 9 : *« Audit de sécurité : examen méthodique des composantes et des acteurs de la sécurité, de la politique, des mesures, des solutions, des procédures et des moyens mis en oeuvre par une organisation, pour sécuriser son environnement, effectuer des contrôles de conformité, des contrôles d'évaluation de l'adéquation des moyens (organisationnels, techniques, humains, financiers) investis au regard des risques encourus, d'optimisation, de rationalité et de performance. »*

Article 7, alinéa 2 (extrait) : l'Agence est notamment chargée *« de s'assurer de la régularité, de l'effectivité des audits de sécurité des systèmes d'information suivant les normes en la matière, des organismes publics et des autorités de certification ».*

Article 32 : *« (1) Les réseaux de communications électroniques et les systèmes d'information sont soumis à un régime d'audit de sécurité obligatoire et périodique de leurs systèmes de sécurité par l'Agence. (2) L'audit de sécurité et les mesures d'impact de gravité sont effectués chaque année ou lorsque les circonstances l'exigent. (3) Les rapports d'audit sont confidentiels et adressés au Ministre chargé des Télécommunications. »*

Portée pour l'audit. L'ANTIC porte sur la *sécurité* des systèmes : protection, disponibilité, intégrité. Elle ne juge pas la régularité des opérations financières qui y transitent. Pour le vérificateur, l'existence et la date du dernier audit de sécurité sont une pièce à demander ; son absence est un constat. Son contenu est confidentiel : l'auditeur demande au moins la date, le périmètre et le plan d'action qui en est issu.

4.3 La Chambre des Comptes : par extension

La Chambre des Comptes de la Cour suprême juge les comptes des comptables publics et contrôle la gestion des entités publiques. Son texte d'organisation ne figure pas dans le dossier des normes du cours ; il n'est donc pas cité ici, et l'auditeur doit le lire avant de l'invoquer.

Son rapport aux systèmes d'information est indirect, mais réel. Les comptes qu'elle juge sont produits par des applications : un compte de gestion édité par une application de comptabilité ne vaut que ce que valent les contrôles de cette application. La Chambre rencontre donc les SI **par extension** : lorsqu'elle s'interroge sur la fiabilité d'un compte, elle s'interroge sur le système qui l'a produit.

Note

Ce que cela change pour le juge des comptes. Un écart entre deux états produits par la même application, ou entre l'application et les relevés bancaires, n'est pas seulement une irrégularité comptable : c'est le symptôme d'un contrôle

d'application ou d'un contrôle d'interface défaillant (Chapitre 11). Le juge peut demander quel contrôle aurait dû l'empêcher, et qui en avait la charge.

4.4 Les autres acteurs

Acteur	Nature du contrôle	Rapport au système d'information
Inspections générales (ministère des Finances, ministères techniques)	Contrôle interne de l'administration, hiérarchique	Contrôle sur pièces et sur place, souvent déclenché par un événement
Contrôle financier	Contrôle a priori de la dépense	Son visa passe de plus en plus par l'application : il est un profil
Audit interne des ministères et des entités	Évaluation du contrôle interne pour la direction	Rapports transmis au CONSUPE (art. 5)
CDBF	Sanction des fautes de gestion	Juge des suites, sur la base des constats
Chambre des Comptes	Juridictionnel, sur les comptes	Par extension, via les comptes produits par les SI
ANTIC	Régulation de la sécurité électronique	Audit de sécurité des SI des organismes publics

Tableau 4.1. Les acteurs du contrôle des SI publics (rôles généraux ; textes à lire avant citation, sauf le décret n° 2013/287 et la loi n° 2010/012)

4.5 Qui fait quoi, et comment s'articuler

4.5.1 Trois angles sur un même système

Pour un même système, trois questions différentes sont posées par trois institutions.

Institution	Question	Exemple sur SIDÉPENSE
CONSUPE	Le système et son contrôle interne garantissent-ils la régularité, la fiabilité et la performance ?	La séparation entre liquidation et ordonnancement est-elle imposée ?
ANTIC	Le système est-il sécurisé selon les normes ?	Les mots de passe, les sauvegardes, la protection du réseau sont-ils conformes ?
Chambre des Comptes	Les comptes produits sont-ils réguliers et sincères ?	Le compte de gestion reflète-t-il les mandats payés ?

Tableau 4.2. Trois angles sur un même système

4.5.2 Règles d'articulation

1. **S'informer des autres interventions.** Le vérificateur demande, dès la prise de connaissance, les rapports d'audit interne (art. 5), la date du dernier audit de sécurité de l'ANTIC et les éventuelles procédures en cours devant la Chambre des Comptes ou le CDBF.
2. **S'appuyer sans déléguer.** Un rapport d'un autre organe oriente les tests ; il ne remplace pas la preuve que le vérificateur obtient lui-même.
3. **Rester dans son angle.** Le vérificateur qui constate une faille de sécurité la consigne et la signale ; il ne conduit pas un audit de sécurité à la place de l'ANTIC.
4. **Préserver la suite.** Dès qu'un constat peut fonder une sanction ou une poursuite, la preuve doit être conservée selon les règles du Chapitre 7.

★ Attention

Violation typique. Reprendre dans un rapport la conclusion d'un audit de sécurité (« le SI est sécurisé ») comme preuve que les contrôles d'accès de l'application sont efficaces.

Règle : un audit de sécurité et une évaluation du contrôle interne ne répondent pas à la même question. Chacun cite l'autre, aucun ne remplace l'autre.

Application Vérificateur

Citez toujours dans l'ordre de mission la disposition qui fonde votre contrôle : « article 2, alinéa 3, du décret n° 2013/287 ». Face à un refus d'extraction, l'alinéa 4 du même article suffit.

Application Juge des comptes

Quand un compte vous paraît douteux, demandez la liste des applications qui l'ont produit et le dernier rapport du CONSUPE ou de l'audit interne qui les a examinées. Le défaut d'un contrôle d'application explique souvent une irrégularité comptable.

Application Contrôleur financier

Votre visa électronique est une activité de contrôle que le CONSUPE évaluera. Gardez la liste des personnes qui détiennent votre profil, et signalez par écrit toute attribution que vous n'avez pas demandée.

★ À retenir

- **Une compétence explicite.** Le décret n° 2013/287 (art. 2, al. 3) range le contrôle des SI parmi les cinq contrôles du CONSUPE, institution supérieure de contrôle chargée de l'audit externe.
- **Sur pièces et sur place.** Les pièces électroniques sont des pièces ; leur présentation est obligatoire, nonobstant les autres contrôles (al. 4).
- **Des suites.** Le CONSUPE préside le CDBF (art. 3) et reçoit les rapports des audits internes (art. 5).
- **L'ANTIC audite la sécurité.** Loi n° 2010/012 : audit de sécurité obligatoire, périodique, confidentiel.
- **La Chambre des Comptes, par extension.** Elle rencontre les SI à travers les comptes qu'ils produisent.
- **Trois angles, aucun ne remplace l'autre.** S'informer, s'appuyer sans déléguer, rester dans son angle, préserver la suite.

✍ Exercice 4.1. Qui est compétent ? ★☆☆

Pour chaque situation, dites quelle institution est principalement concernée, et sur quel texte vous vous fondez quand il est cité dans ce chapitre.

(a) Le réseau d'une recette des finances n'a jamais fait l'objet d'un audit de sécurité.

(b) Le compte de gestion d'un poste comptable diffère des paiements enregistrés dans l'application.

(c) Une DAF refuse de remettre l'extraction des mandats à un vérificateur, au motif qu'une inspection est en cours.

(d) L'auditeur interne d'un ministère achève un rapport sur la paie.

✍ Exercice 4.2. Lire le décret ★☆☆

Citez les deux dispositions du décret n° 2013/287 qui permettent à un vérificateur (a) de conduire une mission dont l'objet est un système d'information ; (b) d'évaluer le dispositif de contrôle interne d'un ministère.

✍ Exercice 4.3. Articuler ★★☆

Au moment où le CONSUPE ouvre sa mission au MINÉQUIR, l'ANTIC annonce un audit de sécurité de SIDÉPENSE. Rédigez la note de la vérificatrice à son chef de division : ce qu'elle demande à l'ANTIC, ce qu'elle ne fera pas elle-même, et ce qu'elle fera pour préserver la preuve.

✍ Exercice 4.4. Un rapport reproductible ★★★

Réécrivez le constat suivant du rapport de M. HAMADOU pour qu'un vérificateur puisse le reprendre devant le CDBF : « Des anomalies importantes ont été relevées dans la paie, notamment des agents qui ne semblent pas exister. » Indiquez le critère, la preuve, la méthode et ce qui reste à établir.

● Note

Transition. Le mandat est posé. Reste à savoir selon quelles règles professionnelles le conduire, et à quels critères comparer ce que l'on trouve. Le Chapitre 5 présente les normes et les référentiels de l'auditeur public.

5

NORMES ET RÉFÉRENTIELS DE L'AUDITEUR PUBLIC

« La norme dit comment auditer ; le référentiel dit à quoi comparer. »

Règle du cours

Niveau : *Fondamental* • Chapitre 4.

✦ Objectifs du chapitre

- ➢ Distinguer une norme professionnelle (comment auditer) d'un référentiel de critères (à quoi comparer).
- ➢ Situer les normes de l'INTOSAI (ISSAI, GUID 5100) et le manuel de l'IDI dans le travail du vérificateur.
- ➢ Situer les normes de l'IIA dans le travail de l'auditeur interne.
- ➢ Utiliser COBIT 2019 et ISO/IEC 27001 et 27002 comme sources de critères, sans les confondre avec la loi.
- ➢ Choisir, pour un test donné, un critère explicite et le citer correctement.
- ➢ Énoncer les principes de déontologie communs aux auditeurs.

Pourquoi ce chapitre

Le prologue l'a montré : une cote NON n'a de sens que si l'on sait à quoi l'on compare. Ce chapitre sépare deux choses que l'on confond souvent. Les *normes professionnelles* disent comment conduire la mission ; les *référentiels* et les *textes* fournissent les critères. L'auditeur public a besoin des deux.

5.1 Norme, référentiel, critère

© MaletYon

Définition

Norme professionnelle : règle qui encadre la conduite d'une mission : indépendance, planification, preuve, documentation, rapport. Elle s'impose à l'auditeur.

Référentiel : ensemble structuré de bonnes pratiques ou d'exigences (COBIT, ISO/IEC 27002) dans lequel l'auditeur puise des critères. Il ne s'impose à l'entité que si un texte ou un engagement le rend obligatoire.

Critère d'audit : exigence de référence, choisie avant le test, à laquelle on compare la situation constatée.

Source	Force	Exemple de critère
Loi, décret	Obligatoire	Les SI des organismes publics font l'objet d'un audit de sécurité (loi n° 2010/012, art. 32)
Règle interne	Obligatoire pour l'entité	Procédure de la DAF sur la désactivation des comptes
Référentiel adopté	Obligatoire si l'entité l'a adopté	Politique de sécurité fondée sur ISO/IEC 27002
Bonne pratique	Recommandation	Un objectif de gestion COBIT 2019

Tableau 5.1. Hiérarchie des sources de critères

Attention

Violation typique. Écrire « non conforme à ISO/IEC 27002 » pour une administration qui n'a jamais adopté cette norme.

Règle : on n'est « non conforme » qu'à une règle qui s'impose. Face à une simple bonne pratique, on écrit « l'entité ne dispose pas de. . . , alors que les bonnes pratiques (référence) recommandent. . . », et l'on classe l'écart en conséquence.

5.2 Les normes de l'INTOSAI

5.2.1 Le cadre

L'INTOSAI réunit les institutions supérieures de contrôle des finances publiques, dont le CONSUPE fait partie au titre de l'article 2 du décret n° 2013/287. Son cadre de prises de position professionnelles comprend des principes, des normes (ISSAI) et des lignes directrices (GUID).

Texte	Objet
ISSAI 100	Principes fondamentaux de l'audit du secteur public : les trois types d'audit, les éléments de l'audit, les principes généraux
ISSAI 200, 300, 400	Principes de l'audit financier, de performance et de conformité
ISSAI 4000	Norme de l'audit de conformité
GUID 5100	Lignes directrices sur la vérification des systèmes d'information
Manuel de l'IDI	Mise en œuvre pratique de l'audit de conformité selon les ISSAI

Tableau 5.2. Les textes de l'INTOSAI utiles à l'auditeur des SI publics

5.2.2 Le GUID 5100

Le GUID 5100 complète les principes de l'ISSAI 100 pour les missions qui portent sur les systèmes d'information [11]. Il précise qu'un audit des SI peut être autonome ou s'insérer dans un audit financier, de conformité ou de performance, et il énumère treize domaines que la mission peut couvrir, parmi lesquels la politique et la gouvernance des TI, le développement et l'acquisition des systèmes, la gestion des opérations, la sécurité de l'information, la conformité réglementaire, la continuité et la reprise après sinistre, et les contrôles d'applications. Le cours suit la même logique : la Partie IV reprend ces domaines.

5.2.3 L'audit de conformité selon l'IDI

Le manuel de l'IDI décrit l'audit de conformité comme une relation entre trois parties : l'auditeur, la partie responsable (l'entité auditée) et les utilisateurs du rapport [10]. Il insiste sur deux exigences que l'auditeur des SI applique directement : identifier des *critères* appropriés avant le travail de terrain, et documenter suffisamment la mission pour qu'un auditeur expérimenté, sans lien avec elle, comprenne les travaux et les conclusions.

5.3 Les normes de l'audit interne

L'auditeur interne d'un ministère ou d'un établissement public suit les normes de l'Institut des auditeurs internes (IIA). Le dossier des normes contient l'édition 2017 du Cadre de référence international des pratiques professionnelles [35] ; l'IIA l'a remplacée par les normes mondiales d'audit interne publiées en 2024 [36]. Les exigences qui comptent ici sont stables d'une édition à l'autre : indépendance et objectivité, compétence, planification fondée sur les risques, preuve suffisante, communication des résultats et suivi des recommandations.

Note

Vérificateur et auditeur interne parlent la même langue. Les normes de l'INTOSAI et celles de l'IIA convergent sur l'essentiel : critère, preuve, documentation, contradictoire. C'est ce qui permet au CONSUPE de s'appuyer sur les rapports d'audit interne qu'il reçoit au titre de l'article 5 du décret n° 2013/287.

5.4 Les référentiels de critères

5.4.1 COBIT 2019

COBIT 2019, de l'ISACA, est un référentiel de gouvernance et de gestion des informations et des technologies [13]. Il organise quarante objectifs en cinq domaines : un domaine de gouvernance (évaluer, diriger, surveiller) et quatre domaines de gestion [12]. L'auditeur public y puise des critères pour la gouvernance de la fonction informatique, les projets, et la gestion des changements (Chapitres 10 et 13).

5.4.2 ISO/IEC 27001 et 27002

ISO/IEC 27001 fixe les exigences d'un système de management de la sécurité de l'information ; ISO/IEC 27002 détaille les mesures de sécurité, regroupées dans l'édition 2022 en quatre thèmes : mesures organisationnelles, liées aux personnes, physiques et technologiques [15], [16]. Ces normes sont sous droits : le cours les résume, il ne les reproduit pas.

5.4.3 Les textes camerounais comme critères

Texte	Ce qu'il fournit comme critère
Décret n° 2013/287	Le droit du vérificateur à obtenir les pièces, électroniques comprises
Loi n° 2010/012	L'audit de sécurité des SI des organismes publics, les obligations de sécurité des exploitants
Loi n° 2018/012 (régime financier)	Les principes de l'exécution de la dépense et la séparation ordonnateur / comptable (à lire dans le texte) [23]
Loi n° 2024/017	La protection des données personnelles traitées par les SI publics (paie, contribuables, usagers)

Tableau 5.3. Textes camerounais utiles comme critères

5.4.4 Choisir et citer un critère

Papier de travail

Fiche de critère, une par test :

- l'énoncé du critère, en une phrase vérifiable ;
- sa source exacte (texte, article, alinéa ; ou référentiel et objectif), et sa force (Tableau 5.1) ;
- la date à laquelle le texte a été lu, et dans quelle version ;
- le test qui permettra de dire OUI ou NON.

Scénario Opérationnel · Dossier MINÉQUIR. Le critère du contrôle 1

Constatation. La DAF n'a aucune procédure écrite sur la désactivation des comptes.

Analyse (confiance élevée). Faute de règle interne, la vérificatrice fonde son critère sur une bonne pratique (principe 11 du COSO ; gestion des accès dans ISO/IEC 27002) et le signale comme tel. Son constat portera donc sur deux points : l'absence de règle interne, qui est elle-même une déficience de conception, et les 9 comptes encore actifs, qui en sont la conséquence.

5.5 Déontologie

Les codes de l'INTOSAI, de l'IIA et de l'ISACA convergent sur quatre exigences.

Exigence	Ce qu'elle impose dans une mission SI
Intégrité	Ne jamais modifier une donnée de l'entité ; travailler sur une copie
Indépendance et objectivité	Ne pas auditer un système que l'on a conçu, paramétré ou exploité
Compétence	Se faire assister par un spécialiste pour les tests techniques que l'on ne maîtrise pas, et le dire au rapport
Confidentialité	Protéger les extractions (paie, contribuables) et les détruire selon les règles à la fin de la mission

Tableau 5.4. Quatre exigences déontologiques dans une mission SI

Application Vérificateur

Écrivez dans le programme de travail, pour chaque test, la fiche de critère. Lors du contradictoire, la première contestation porte presque toujours sur le critère : « aucun texte ne nous l'impose ».

Application Auditeur interne

Si votre ministère a adopté une politique de sécurité fondée sur ISO/IEC 27002, ses mesures deviennent des règles internes : citez la politique, pas la norme.

★ À retenir

- **Norme et référentiel.** La norme dit comment auditer ; le référentiel fournit des critères.
- **L'INTOSAI pour le vérificateur.** ISSAI 100, 400 et 4000, GUID 5100, manuel de l'IDI.
- **L'IIA pour l'auditeur interne.** Mêmes exigences essentielles : critère, preuve, documentation.
- **COBIT et ISO/IEC 27002 comme sources de critères**, qui ne s'imposent que si l'entité les a adoptés.
- **Une hiérarchie des critères.** Loi, règle interne, référentiel adopté, bonne pratique ; l'écart se qualifie selon la force du critère.
- **Une fiche de critère par test**, avec la source exacte et la date de lecture.
- **Quatre exigences déontologiques.** Intégrité, indépendance, compétence, confidentialité.

✍ Exercice 5.1. Norme ou référentiel ? ★☆☆

Classez : (a) GUID 5100 ; (b) ISO/IEC 27002 ; (c) ISSAI 4000 ; (d) COBIT 2019 ; (e) normes de l'IIA ; (f) loi n° 2024/017.

✍ Exercice 5.2. Qualifier l'écart ★★☆

La CAPNO n'a pas testé ses sauvegardes depuis deux ans. Rédigez le constat dans deux cas : (a) la politique de sécurité de la CAPNO exige un test semestriel ; (b) aucune règle interne n'existe.

✍ Exercice 5.3. Fiches de critère ★★☆

Établissez la fiche de critère des contrôles 2 (séparation LIQ / ORD) et 4 (blocage des doublons) du circuit de la dépense du MINÉQUIR (Tableau 3.2).

✍ Exercice 5.4. Un conflit d'intérêts ★★★

Un vérificateur a participé, deux ans plus tôt, au comité de pilotage du projet SIDÉPENSE. Analysez la situation au regard des exigences déontologiques, et proposez ce que son chef de division doit décider.

● Note

Transition. Le mandat et les normes sont posés. La Partie III conduit la mission elle-même, en commençant par sa préparation (Chapitre 6).

partie III

Démarche de Mission

© MaletYon

6

LA MISSION : PRINCIPES, PRÉPARATION ET DÉCOMPOSITION

« Une mission se gagne avant le terrain. »

Adage des vérificateurs

Niveau : *Intermédiaire* • Chapitres 3 et 5.

✦ Objectifs du chapitre

- ➢ Énoncer les principes de l'audit et les relier aux axiomes de l'auditologie.
- ➢ Décrire le cycle d'une mission en cinq phases, avec les entrées et les sorties de chacune.
- ➢ Rédiger un ordre de mission et des termes de référence qui fixent l'objectif, le périmètre, la période et les critères.
- ➢ Organiser la demande de pièces en trois strates, et décider si une pièce absente vaut NON ou NEK.
- ➢ Conduire une prise de connaissance bornée, par couches du système d'information.
- ➢ Hiérarchiser les zones d'audit en croisant le risque et la connaissance que l'on en a.
- ➢ Décomposer le domaine audité selon le gabarit canonique à huit niveaux, et rédiger une fiche d'assertion par contrôle.
- ➢ Établir le programme de travail.

Pourquoi ce chapitre

Une mission sur un système d'information dispose de peu de temps et d'un objet immense : des milliers d'opérations, des dizaines de profils, des journaux de plusieurs gigaoctets. Tout tester est impossible, et ce que l'on ne regarde pas reste inconnu. La préparation décide donc de ce que la mission saura, et de ce qu'elle ignorera. Elle se juge

à une question : *le programme de travail porte-t-il sur les zones où le risque est élevé et la connaissance faible ?*

Ce chapitre suit la méthode du cours d'audit des systèmes d'information de l'auteur, qui est l'instanciation, pour le praticien, du programme de recherche de l'auditologie [25]. Il en reprend les trois outils de préparation : le cycle de la mission, l'évaluation croisée du risque et de la connaissance, et le gabarit canonique de décomposition.

Plan du chapitre.

1. Les principes de l'audit (section 6.1).
2. Le cycle de la mission (section 6.2).
3. L'ordre de mission et les termes de référence (section 6.3).
4. Les pièces à demander (section 6.4).
5. La prise de connaissance (section 6.5).
6. Hiérarchiser : risque et connaissance (section 6.6).
7. Décomposer : le gabarit canonique et la fiche d'assertion (section 6.7).
8. Le programme de travail (section 6.8).

6.1 Les principes de l'audit

La norme ISO 19011 énonce sept principes de l'audit [14] ; les normes de l'INTOSAI et de l'IIA en portent l'équivalent. Ils ne sont pas des vœux : chacun commande une pratique de la mission.

Principe	Ce qu'il impose	Dans une mission SI
Intégrité	Agir honnêtement, avec diligence	Ne jamais modifier une donnée de l'entité
Restitution impartiale	Rapporter fidèlement, y compris les difficultés	Écrire les NEK restants au rapport
Conscience professionnelle	Exercer le soin et le jugement requis	Vérifier l'intégrité de chaque extraction
Confidentialité	Protéger l'information obtenue	Protéger les fichiers de paie et de fournisseurs
Indépendance	Fonder l'objectivité des conclusions	Ne pas auditer un système que l'on a conçu
Approche fondée sur la preuve	Conclure sur des preuves vérifiables	Partir du système, pas des classeurs
Approche par les risques	Porter l'effort là où il compte	Croiser risque et connaissance (section 6.6)

Tableau 6.1. Les sept principes de l'audit (d'après ISO 19011:2018)

Note

Des principes aux axiomes. L'article *Vers l'auditologie* montre que plusieurs de ces principes se déduisent d'axiomes plus fondamentaux [25]. L'approche fondée sur la preuve découle de l'*observabilité partielle* (axiome 1) : l'auditeur ne voit qu'une partie du système, il doit donc dire sur quoi il s'appuie. L'indépendance n'est pas un axiome, mais une conséquence de l'*interaction stratégique* (axiome 4) et de l'*opposabilité* (axiome 6) : une conclusion qu'un tiers peut contester doit venir de quelqu'un qui n'a pas intérêt au résultat.

6.1.1 Les principes en conflit

Les principes se heurtent parfois. La confidentialité demande de limiter la diffusion d'une extraction ; la restitution impartiale demande d'en montrer les résultats. La règle du cours est de ne jamais sacrifier l'opposabilité : on peut anonymiser une liste d'agents dans le rapport, à condition de conserver au dossier la liste nominative et son empreinte.

6.2 Le cycle de la mission

6.2.1 Cinq phases



Figure 6.1. Le cycle de la mission

La flèche de retour n'est pas un ornement. L'auditologie pose l'*individuation temporelle* (axiome 5) : le système audité évolue, et son état à la mission suivante dépend de la mission précédente [25]. Le suivi n'est donc pas une formalité : il est la première phase du cycle suivant (Chapitre 8).

6.2.2 Entrées et sorties de chaque phase

Phase	Entrées	Sorties
Préparer	Mandat, rapports antérieurs, textes	Ordre de mission, termes de référence, demande de pièces
Planifier	Prise de connaissance, cotation des risques	Décomposition, fiches d'assertion, programme de travail
Exécuter	Programme, pièces, accès au système	Feuilles de test, cotes OUI, NON, NEK, preuves et empreintes
Conclure	Cotes et preuves	Mesures par domaine, observations, rapport provisoire, contradictoire, rapport définitif
Suivre	Plan d'action	Tableau de suivi, comparaison des cycles

Tableau 6.2. Entrées et sorties des cinq phases

6.2.3 L'équipe et la supervision

Une mission du CONSUPE compte au moins un chef de mission et un vérificateur. Le chef de mission répond du programme, de la cohérence des cotes et du rapport ; il vise chaque feuille de test. La supervision n'est pas une relecture finale : elle a lieu pendant l'exécution, quand une cote peut encore être reprise. Au MINÉQUIR, Mme NGO BIYONG revoit chaque soir les feuilles de M. ESSAMA.

6.3 L'ordre de mission et les termes de référence

6.3.1 L'ordre de mission

L'ordre de mission est la première pièce du dossier. Il fonde le droit d'accès du vérificateur (décret n° 2013/287, art. 2, al. 4) et fixe ce que la mission doit démontrer.

Rubrique	Ordre de mission du 16 mars 2026 (MINÉQUIR)
Fondement	Décret n° 2013/287, art. 2, al. 3 (contrôle des SI) et al. 4
Objectif	Évaluer le contrôle interne du circuit de la dépense de la DAF dans SIDÉPENSE, et la régularité des paiements de l'exercice
Périmètre	DAF du MINÉQUIR ; application SIDÉPENSE ; poste comptable pour la seule étape du paiement
Période	Exercice 2025
Durée	Quatre semaines, du 16 mars au 10 avril 2026
Équipe	Mme NGO BIYONG (chef de mission), M. ESSAMA (vérificateur)
Livrables	Rapport provisoire, contradictoire, rapport définitif

Tableau 6.3. Les rubriques d'un ordre de mission

6.3.2 Les termes de référence : quatre questions

Les termes de référence précisent l'ordre de mission. Ils répondent à quatre questions, et à elles seules.

1. **Que doit-on démontrer ?** L'objectif, écrit comme une question fermée : « Le contrôle interne du circuit de la dépense dans SIDÉPENSE est-il efficace pour l'exercice 2025 ? »
2. **Sur quoi ?** Le périmètre : entités, applications, processus inclus, et ce qui est exclu (ici, la paie et la recette).
3. **Par rapport à quoi ?** Les critères et leur source (Chapitre 5).
4. **Avec quelle assurance ?** Raisonnable ou limitée (Chapitre 1), et les seuils de décision que la mission retiendra (Chapitre 8).

★ Attention

Violation typique. Un ordre de mission qui dit « contrôler le système informatique de la DAF », sans objectif, sans période et sans périmètre.

Règle : un objectif s'écrit comme une question à laquelle le rapport répondra par oui ou par non ; le périmètre dit ce qui est exclu autant que ce qui est inclus.

6.4 Les pièces à demander

6.4.1 Trois strates

La demande de pièces part dès le premier jour, par écrit, avec un délai. Elle s'organise en trois strates, de la plus générale à la plus probante.

Strate	Contenu	Au MINÉQUIR
1. Gouvernance	Organigramme, décisions, schéma directeur, politiques	Organigramme de la DAF, décision de création de la cellule
2. Fonctionnement	Procédures, manuels, contrats, comptes rendus	Procédures du circuit, contrat de maintenance de SIDÉPENSE
3. Traces	Extractions, journaux, paramètres, faites devant l'auditeur	Comptes et profils, mandats 2025, journal des opérations

Tableau 6.4. Les trois strates de pièces

N°	Pièce	Destinataire	Délai
1	Liste des utilisateurs de SIDÉPENSE et de leurs profils, extraite devant la vérificatrice	Cellule informatique	J+2
2	Liste des mutations et départs de 2025	Ressources humaines	J+3
3	Extraction des mandats 2025 et du journal des opérations	Cellule informatique	J+5
4	Journal des modifications du fichier des fournisseurs	Cellule informatique	J+5
5	Procédures écrites du circuit et de la gestion des comptes	DAF	J+3
6	Dernier rapport d'audit de sécurité de l'ANTIC (date, périmètre, plan d'action)	Cellule informatique	J+5

Tableau 6.5. Demande de pièces de la mission MINÉQUIR

6.4.2 Une pièce absente : NON ou NEK ?

Une pièce qui ne vient pas n'a pas toujours le même sens. Le cours applique une règle simple, cohérente avec l'instrument de l'article A1 [24].

➢ **non** : la pièce devait exister (une règle l'impose), et l'entité confirme par écrit qu'elle n'existe pas. L'absence est une constatation.

➢ **nek** : la pièce peut exister ailleurs, ou n'a pas encore été produite malgré la relance. On ne sait pas ; on le dit, avec les diligences faites.

Un NEK qui reste à la fin de la mission devient une *limitation d'étendue*, écrite au rapport (Chapitre 8).

6.5 La prise de connaissance

6.5.1 Une prise de connaissance bornée

La prise de connaissance n'a pas pour but de tout comprendre, mais de savoir assez pour formuler des hypothèses de risque. L'article A0 rappelle que l'auditeur est un agent cognitivement limité (axiome 2) [25] : une prise de connaissance sans borne produit un dossier que personne ne relit. Le cours la limite à deux jours sur quatre semaines, et la conduit par couches.

6.5.2 Lire le système d'information en couches

Couche	Question	Au MINÉQUIR
Organisation	Qui décide, qui exécute, qui contrôle ?	DAF propriétaire, cellule exécutante, contrôle financier
Processus	Quelles étapes, dans quel ordre ?	Engagement, liquidation, ordonnancement, paiement
Applications	Quelles applications portent les étapes ?	SIDÉPENSE, logiciel du poste comptable
Données	Quelles données de référence conditionnent tout ?	Fichier des fournisseurs, table des profils
Infrastructure	Où tourne le système, qui l'administre ?	Serveur de la cellule, sauvegardes locales

Tableau 6.6. Les couches du système d'information

6.5.3 La cartographie des applications et des flux

Application	Fonction	Propriétaire	Flux sortant
SIDÉPENSE	Engagement, liquidation, ordonnancement, fournisseurs	DAF	Mandats vers le poste comptable (fichier quotidien)
Logiciel du poste comptable	Paiement, comptabilité	Poste comptable	Ordres de virement vers les banques
Fichier du personnel	Mutations, départs	Direction des ressources humaines	Aucun vers SIDÉPENSE (constat)

Tableau 6.7. Cartographie des applications du périmètre

La dernière ligne est déjà un résultat : aucun flux ne relie le fichier du personnel à SIDÉPENSE. Les mutations ne sont connues de la cellule informatique que si quelqu'un pense à les lui signaler. La cartographie a désigné un risque avant tout test.

6.5.4 Conduire un entretien de prise de connaissance

Papier de travail

Entretien de prise de connaissance :

- préparer une liste de questions ouvertes, par couche ;
- être deux : l'un interroge, l'autre note ;
- demander, pour chaque affirmation, la pièce qui la montre ;
- relire le compte rendu à l'interlocuteur et le faire valider ;
- noter à part ce qui est déclaré sans pièce : ce sont les futurs NEK à lever.

6.6 Hiérarchiser : risque et connaissance

6.6.1 La cotation du risque

Pour chaque risque de la matrice (Chapitre 3), on cote de 1 (faible) à 3 (élevé) le **risque inhérent** (gravité et probabilité de l'anomalie si aucun contrôle n'existait) et le **risque lié au contrôle** (probabilité que le contrôle interne, tel qu'on le connaît, ne l'empêche ni ne la détecte). Leur produit, de 1 à 9, est la priorité.

Risque	Inhérent	Contrôle	Priorité
R1. Un agent parti agit encore	3	3	9
R2. Un agent émet seul un mandat	3	2	6
R3. Le bénéficiaire est changé	3	3	9
R4. Une facture est payée deux fois	3	2	6
R5. Le mandat n'est pas justifié	2	1	2
R6. Une opération ne laisse pas de trace	2	1	2
R7. Une anomalie de fin de gestion passe	2	3	6
R8. Les traces disparaissent	2	2	4

Tableau 6.8. Cotation préliminaire des risques du circuit de la dépense (convention du cours)

6.6.2 Le risque et la connaissance

La cotation du risque ne suffit pas. L'auditologie ajoute une seconde dimension : ce que l'on *sait* de chaque zone. Une zone à risque élevé que l'on connaît bien (un audit récent l'a testée) appelle moins d'effort qu'une zone à risque moyen dont on ignore tout. C'est la distinction d'A0 entre non-conformité *connue* et non-conformité *inconnue* [25] : la seconde est la plus dangereuse, parce qu'elle ne se voit pas.

	Connaissance élevée	Connaissance faible
Risque élevé	Tester ce qui a changé depuis le dernier audit	**Priorité absolue** : tests étendus, preuves de strate 3
Risque faible	Cheminement ou revue analytique	Prise de connaissance complémentaire, puis décider

Tableau 6.9. Croiser le risque et la connaissance

Scénario Opérationnel · Dossier MINÉQUIR. Où regarder d'abord

Constatation. R1 (agents partis) et R3 (RIB) sont cotés 9. Aucun audit n'a jamais porté sur SIDÉPENSE ; l'inspection de janvier n'a examiné que des dossiers papier.

Analyse (confiance moyenne). Les deux risques sont à la fois élevés et inconnus : ce sont les zones de priorité absolue. La vérificatrice leur consacre la première semaine, puis les trois risques cotés 6. Elle ne teste R5 et R6 que par un cheminement : leur priorité ne justifie pas un échantillon.

6.7 Décomposer : le gabarit canonique et la fiche d'assertion

6.7.1 Pourquoi décomposer

Un auditeur ne peut pas examiner « les accès » d'un bloc. George Miller a montré que la mémoire de travail ne retient qu'environ sept éléments à la fois, plus ou moins deux [22] ; Herbert Simon, que les systèmes complexes sont hiérarchiques et presque décomposables [33]. L'article A0 en tire une proposition : tout instrument qui couvre un espace d'audit non trivial doit être organisé en une décomposition hiérarchique dont chaque niveau respecte cette borne [25].

Définition

Espace d'audit : ensemble des objets sur lesquels porte une mission (processus, contrôles, données, traces), tel que le délimite l'ordre de mission.

Décomposition : découpage hiérarchique de l'espace d'audit en niveaux emboîtés, chaque élément d'un niveau se divisant en éléments du niveau inférieur.

La décomposition apporte quatre choses : la **couverture** (on sait ce qui a été audité et ce qui ne l'a pas été), la **traçabilité** (chaque conclusion remonte à une trace, ce qui la rend opposable, axiome 6), la **localisation de l'incertitude** (les NEK se situent à un endroit précis) et la **répartition du travail**.

6.7.2 Le gabarit canonique à huit niveaux

Le programme de l'auditologie propose un **gabarit canonique** de décomposition à huit niveaux [25]. Les quatre premiers disent *ce qui est audité* ; les quatre derniers, *comment on le vérifie*. Le contrôle fait la charnière : c'est l'objet sur lequel l'auditeur se prononce.

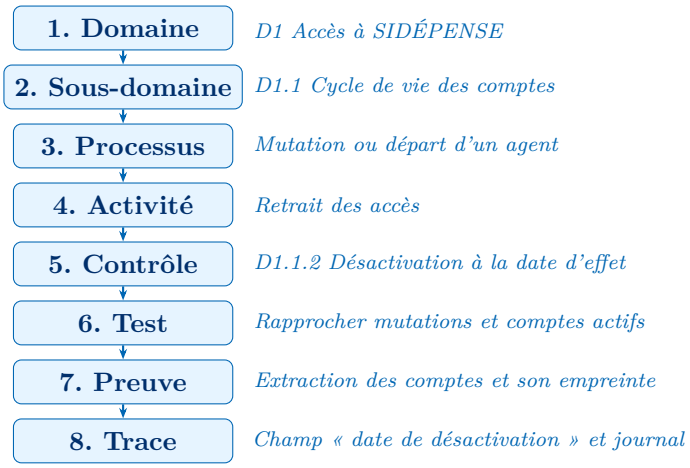


Figure 6.2. Le gabarit canonique appliqué au contrôle des agents partis (d'après [25])

★ Attention

Violation typique. Mettre dans la même liste « une politique d'accès existe » (un document) et « le journal est activé » (une trace), au même niveau que « les accès » (un domaine).

Règle : chaque élément se place à un seul niveau, celui de sa nature. Un mélange de niveaux rend la couverture invérifiable.

6.7.3 Preuve et trace : deux choses différentes

La *trace* existe dans le système, que l'auditeur passe ou non : une entrée de journal, un champ de date. La *preuve* est ce que l'auditeur en tire et conserve : l'extraction horodatée, son empreinte, la requête qui l'a produite. Une trace non extraite n'est pas une preuve ; une preuve qui ne renvoie à aucune trace (une capture d'écran sans contexte) est fragile.

6.7.4 La décomposition de la mission MINÉQUIR

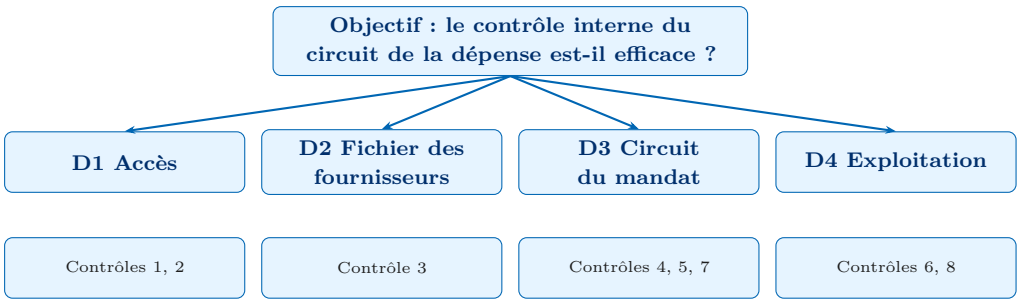


Figure 6.3. Les quatre domaines de la mission MINÉQUIR et les huit contrôles du prologue

6.7.5 La fiche d'assertion

Le gabarit dit *où* se trouve un contrôle. La **fiche d'assertion** dit *ce que l'auditeur affirme* à son sujet, et ce qui arrive si l'affirmation est fausse.

Attribut	Rôle	Forme
Objectif	Ce que le contrôle doit garantir	À l'infinitif : « S'assurer que… »
Critère	La condition vérifiable qui définit la conformité	Au présent : une condition unique, observable
Question	La question posée pour coter le contrôle	Interrogative ; réponse OUI, NON ou NEK
Risque	L'état de non-conformité si la réponse est NON	L'antithèse du critère
Conséquence	L'effet sur l'entité si le risque se réalise	Financier, opérationnel, juridique

Tableau 6.10. Les attributs de la fiche d'assertion

Point de contrôle · D1.1.2 · Désactivation à la date d'effet

Position : D1 Accès → D1.1 Cycle de vie des comptes → mutation ou départ → retrait des accès → contrôle D1.1.2.
Objectif : s'assurer qu'aucun agent muté ou parti ne peut agir dans SIDÉPENSE.
Critère 1 : le compte est désactivé au plus tard à la date d'effet de la mutation.
Question 1 : chaque compte d'agent muté en 2025 a-t-il été désactivé au plus tard à la date d'effet ?
Critère 2 : la DRH notifie par écrit chaque mutation à la cellule informatique.
Question 2 : chaque mutation de 2025 a-t-elle fait l'objet d'une notification écrite ?
Test : rapprocher la liste des 31 mutations et départs de 2025 de la liste des comptes actifs au 23 mars 2026 ; demander les notifications.
Preuve et trace : extractions et empreintes ; champ de date de désactivation ; notifications.
Risque : un compte resté actif est utilisé par son ancien titulaire ou par un tiers.
Conséquence : paiement indu, impossibilité d'imputer une opération à une personne, suites devant le CDBF.

6.7.6 De la fiche à la cotation

Chaque critère reçoit sa propre question et sa propre cote. La cote du contrôle s'en déduit par une règle de composition : un seul critère NON suffit pour que le contrôle soit NON ; à défaut, un seul critère NEK donne NEK ; le contrôle n'est OUI que si tous ses critères le sont.

Critère 1 (désactivé)	Critère 2 (notifié)	Cote D1.1.2	Lecture
OUI	OUI	OUI	Contrôle conforme
OUI	NON	NON	Désactivé par chance, sans procédure
NEK	OUI	NEK	Notifié, mais désactivation non établie
NON	NEK	NON	Un défaut établi suffit

Tableau 6.11. Composer les cotes de deux critères

6.7.7 Les règles de qualité

- **Atomicité** : l'objectif, le critère et la question ne contiennent ni « et » ni « ou » ; toute assertion composée est scindée.
- **Exhaustivité** : les éléments d'un niveau couvrent entièrement l'élément du niveau supérieur.
- **Non-redondance** : un contrôle n'appartient qu'à un domaine, sinon il est compté deux fois.

- **Borne cognitive** : au plus sept à neuf éléments sous un même parent ; au-delà, on ajoute un niveau.

6.8 Le programme de travail

Papier de travail

Le programme de travail, une ligne par contrôle :

- le code et l'intitulé du contrôle (position dans le gabarit) ;
- le risque couvert, sa priorité et la connaissance que l'on en a ;
- la fiche d'assertion (critères, questions) ;
- le test prévu (cheminement, échantillon, essai, analyse de toute la population) et sa taille (Chapitre 7) ;
- les pièces à demander, par strate ;
- les seuils de décision retenus (Chapitre 8) ;
- le membre de l'équipe et la date prévue.

Application Vérificateur

Gardez la trace de chaque relance. Une pièce non remise à l'échéance, malgré relance écrite, devient soit un NON (si elle devait exister), soit une limitation d'étendue à mentionner au rapport.

Application Inspecteur

Même pour une inspection courte, écrivez l'objectif et le périmètre en tête de votre note de mission : ils déterminent la portée de votre conclusion (Chapitre 0).

Application Auditeur interne

Votre plan d'audit annuel est une cotation des risques et des connaissances à l'échelle de l'entité : les applications financières, et leurs jointures, doivent y figurer, avec la date du dernier audit qui les a testées.

★ À retenir

- **Sept principes, des axiomes derrière.** La preuve vient de l'observabilité partielle ; l'indépendance, de l'interaction stratégique et de l'opposabilité.
- **Un cycle en cinq phases** : préparer, planifier, exécuter, conclure, suivre ; le suivi ouvre le cycle suivant.
- **Quatre questions de référence** : quoi démontrer, sur quoi, par rapport à quoi, avec quelle assurance.
- **Trois strates de pièces** ; une pièce absente est NON si elle devait exister, NEK sinon.
- **Risque et connaissance.** La priorité absolue va aux zones à risque élevé que l'on connaît mal.
- **Le gabarit canonique** : huit niveaux, du domaine à la trace ; une fiche d'assertion par contrôle, une cote par critère.
- **Un programme ligne par ligne**, écrit avant le terrain.

✍ Exercice 6.1. Un ordre de mission ★☆☆

Rédigez l'ordre de mission et les termes de référence d'une vérification de la paie de la CAPNO (Garoua) pour l'exercice 2025, en répondant aux quatre questions de la section 6.3.

✍ Exercice 6.2. Risque et connaissance ★★☆

Pour la paie de la CAPNO, cotez au moins six risques, indiquez pour chacun la connaissance dont vous disposez (élevée ou faible) et placez-les dans le Tableau 6.9. Dites lesquels vous testerez par analyse de toute la population, et lesquels par cheminement.

✍ Exercice 6.3. Une fiche d'assertion ★★☆

Rédigez la fiche d'assertion du contrôle « seconde validation de toute modification de RIB » (domaine D2), avec sa position dans le gabarit, deux critères atomiques, leurs questions, le test, la preuve, la trace, le risque et la conséquence. Donnez la cote du contrôle si le premier critère est OUI et le second NEK.

✍ Exercice 6.4. Décomposer e-RECETTES ★★★

Décomposez l'objectif « le système e-RECETTES garantit-il l'exhaustivité des recettes enregistrées ? » selon le gabarit canonique jusqu'au niveau du contrôle, pour au moins trois sous-domaines. Vérifiez les quatre règles de qualité et signalez une violation que vous avez dû corriger.

Note

Transition. Le programme dit quoi tester, et où se trouve chaque contrôle. Le Chapitre 7 dit comment répondre à chaque question : avec quelle preuve, et que faire quand on ne sait pas.

7

COLLECTER LA PREUVE : OUI, NON, NEK

> « Une grille qui interdit de répondre *je ne sais pas*
> ne supprime pas l'ignorance : elle la déguise en certitude. »
>
> Principe de l'auditologie

Niveau : *Intermédiaire* • Chapitre 6.

✦ Objectifs du chapitre

- ➢ Utiliser l'instrument OUI / NON / NEK auprès des répondants et pour coter les contrôles, et justifier la modalité NEK à partir des axiomes de l'auditologie.
- ➢ Mesurer le biais d'une grille binaire par l'indice ρ.
- ➢ Classer les preuves selon leur fiabilité et pratiquer la corroboration.
- ➢ Conduire un entretien d'audit qui produit des réponses cotables.
- ➢ Calculer la taille d'un échantillon par attributs et en tirer une conclusion.
- ➢ Obtenir une extraction dont on garantit l'origine, l'exhaustivité, l'exactitude et l'intégrité.
- ➢ Tenir des papiers de travail qu'un tiers peut relire et refaire.

Pourquoi ce chapitre

Dans le prologue, tout reposait sur deux fichiers et sur huit cotes. Si la DAF avait pu dire « ce fichier n'est pas le nôtre », ou si la vérificatrice avait coté OUI ce qu'elle ne savait pas, le constat tombait. Ce chapitre apprend à répondre à chaque question de la fiche d'assertion avec une preuve qui tient, et à dire honnêtement ce que l'on ne sait pas. Il repose sur l'instrument de réponse construit par l'article A1 [24], à partir des axiomes de l'article A0 [25].

Plan du chapitre.

1. L'instrument OUI / NON / NEK (section 7.1).
2. Le biais du choix forcé (section 7.2).

© *MaletYon*

3. Les preuves et leur fiabilité (section 7.3).
4. Les entretiens (section 7.4).
5. Tester et échantillonner (sections 7.5 et 7.6).
6. Obtenir une extraction (section 7.7).
7. Les papiers de travail (section 7.8).

7.1 L'instrument OUI / NON / NEK

7.1.1 Pourquoi une troisième réponse

L'article *Vers l'auditologie* établit, à partir de quatre de ses axiomes, que tout instrument de réponse d'audit valide doit comporter une modalité explicite de connaissance insuffisante [25]. Le raisonnement est simple.

- **Observabilité partielle** (axiome 1) : l'auditeur ne voit qu'une partie des états du système ; certaines questions n'ont pas de réponse établie au moment où il les pose.
- **Cognition limitée** (axiome 2) : les répondants, comme l'auditeur, ne savent pas tout de ce qu'ils gèrent.
- **Mesurabilité** (axiome 3) : l'incertitude peut se mesurer, à condition d'être enregistrée.
- **Interaction stratégique** (axiome 4) : un répondant a parfois intérêt à répondre OUI quand il ne sait pas.

Une grille qui n'admet que OUI et NON oblige donc à transformer l'ignorance en une réponse fausse. L'article A1 construit l'instrument qui l'évite [24].

Définition

Espace de réponse trichotomique : ensemble $\Omega = \{\text{OUI}, \text{NON}, \text{NEK}\}$ des réponses admises à une question d'audit.

- OUI : le critère est satisfait, et une preuve l'établit.
- NON : le critère n'est pas satisfait, et une preuve l'établit.
- NEK (*Not Enough Knowledge*) : l'information disponible ne permet pas de conclure, malgré des diligences normales.

7.1.2 Deux usages

1. **Auprès des répondants** : une même question est posée à plusieurs interlocuteurs. Pour chaque question, ou chaque domaine, on obtient une distribution de réponses, dont l'article A1 tire trois mesures : μ, la part des OUI ; U, la part des NEK ; H, l'entropie [24]. Le Chapitre 8 apprend à les lire.

2. **Par l'auditeur** : après ses tests, l'auditeur cote chaque contrôle OUI, NON ou NEK, preuve à l'appui. C'est la cote qui entre dans le rapport.

Les deux usages se répondent : une question où les répondants divergent appelle des tests ; les tests permettent ensuite de coter avec preuve.

7.1.3 NEK n'est pas « non applicable »

★ Attention

Violation typique. Coter NEK un contrôle qui ne s'applique pas au périmètre (par exemple, la validation des annulations de recettes dans un service qui n'encaisse rien).

Règle : un contrôle sans objet est *non applicable* : il sort de la décomposition, avec la raison écrite. NEK est réservé à un contrôle applicable dont on ne peut pas établir l'état. Les confondre fausse le taux d'incertitude U.

7.2 Le biais du choix forcé

Une grille binaire force le répondant qui ne sait pas à choisir. Il choisit le plus souvent la réponse attendue, ou la plus confortable : le OUI. La grille binaire *surestime* donc la conformité. L'article A1 mesure cette surestimation par un indice de réduction du biais [24] :

$$\rho = \hat{\mu}^B - \mu^T,$$

où $\hat{\mu}^B$ est la part des OUI obtenue avec l'instrument binaire, et μ^T celle obtenue avec l'instrument trichotomique, sur les mêmes questions et les mêmes répondants.

⚖ Lecture auditologique · Domaine D1, binaire puis trichotomique

En 2025, l'audit interne du MINÉQUIR avait posé cinq questions sur les accès à SIDÉPENSE à quatre interlocuteurs (le DAF, le chef de la cellule informatique, le chef de la liquidation, le contrôleur financier), avec une grille OUI / NON : 17 OUI sur 20 réponses. En mars 2026, la vérificatrice pose les mêmes questions aux mêmes personnes avec l'instrument trichotomique : 11 OUI, 3 NON, 6 NEK.

Constatation. $\hat{\mu}^B = 17/20 = 0{,}85$; $\mu^T = 11/20 = 0{,}55$; $\rho = 0{,}30$.

Analyse (confiance moyenne). La grille binaire surestimait la conformité de trente points : six réponses OUI de 2025 étaient en réalité des « je ne sais pas ». C'est ainsi que l'audit interne avait pu écrire que « la gestion des accès est satisfaisante », quelques mois avant le double paiement.

$\mu = 0{,}55$ · $U = 0{,}30$ · $H = 1{,}41$ **bit**

Note

Ce que ρ ne dit pas. L'indice mesure l'écart entre deux instruments, pas la conformité réelle. Seuls les tests de l'auditeur disent si les contrôles fonctionnent : au Chapitre 9, un seul des six contrôles d'accès sera coté OUI.

7.3 Les preuves et leur fiabilité

7.3.1 Suffisante et appropriée

Définition

Preuve d'audit : information sur laquelle l'auditeur fonde sa cote et ses conclusions. Elle doit être *suffisante* (en quantité, au regard du risque) et *appropriée* (pertinente pour le critère, et fiable).

7.3.2 Une hiérarchie de fiabilité

Rang	Source	Exemple	Fiabilité
1	Trace du système, extraite par l'auditeur	Matrice des profils extraite devant la vérificatrice	La plus élevée
2	Document externe	Relevé bancaire, visa du poste comptable	Élevée
3	Document interne approuvé	Note de service signée	Moyenne
4	Observation directe	La vérificatrice voit un agent liquider	Ponctuelle
5	Déclaration orale	« Les comptes sont désactivés dès qu'on nous informe »	La plus faible

Tableau 7.1. Fiabilité des preuves selon leur source

Une déclaration orale ne suffit jamais à coter OUI : elle oriente la recherche de la preuve. Quand l'auditeur ne dispose que d'une déclaration, la cote est NEK, et la question devient « où est la preuve ? ».

7.3.3 La corroboration

Deux preuves indépendantes qui concordent valent plus que la plus fiable des deux prise seule. Pour les contrôles importants, l'auditeur cherche une seconde source : la liste des mutations de la DRH (rang 3) recoupée avec les dates de désactivation dans SIDÉPENSE (rang 1). Si deux sources se contredisent sans qu'on puisse les départager, la cote est NEK, et l'écart devient lui-même un objet d'investigation.

7.4 Les entretiens

L'entretien d'audit, à la différence de l'entretien de prise de connaissance (Chapitre 6), recueille des réponses cotables. Ses questions sont celles des fiches d'assertion, classées par interlocuteur.

Papier de travail

Règles de l'entretien d'audit :

1. un répondant à la fois, pour éviter qu'un chef ne réponde pour son équipe ;
2. lire la question de la fiche telle quelle, sans la reformuler en suggérant la réponse ;
3. annoncer que NEK est une réponse admise et utile ;
4. noter la réponse, son auteur, la date, et la pièce invoquée ;
5. demander la pièce séance tenante, ou fixer un délai écrit ;
6. faire relire et signer le compte rendu.

★ Attention

Violation typique. Demander au DAF « vous désactivez bien les comptes des agents mutés, n'est-ce pas ? ».

Règle : une question qui suggère la réponse produit un OUI sans valeur. On demande « qui désactive, quand, sur quelle pièce ? », et l'on admet « je ne sais pas ».

7.5 Les techniques de test

Technique	Ce qu'elle établit	Exemple
Entretien	Ce que l'entité déclare	Le chef de la cellule décrit la gestion des comptes
Observation	Ce qui se passe, au moment où l'on regarde	Assister à une désactivation de compte
Inspection	Ce que contient un document ou un enregistrement	Lire la matrice des profils
Ré-exécution	Que le contrôle produit le résultat attendu	Tenter de saisir un mandat en double dans un environnement de test
Analyse de données	Ce que dit toute la population	Rechercher les doublons parmi 9 611 mandats

Tableau 7.2. Les techniques de test

★ Attention

Violation typique. Faire une ré-exécution dans l'application de production (« pour voir si le doublon passe »).

Règle : l'auditeur ne crée, ne modifie ni ne supprime jamais une donnée de production. Les essais se font dans un environnement de test, ou par observation d'une opération réelle.

7.6 Échantillonner dans le système

7.6.1 Population et échantillon

■ Définition

Population : ensemble des opérations sur lesquelles porte la conclusion. Dans un SI, elle se prend dans le système, après rapprochement de ses totaux (Chapitre 0).

Échantillon : partie de la population examinée en détail. Il est *aléatoire* quand chaque opération a la même chance d'être tirée, *raisonné* quand l'auditeur choisit les opérations selon un critère (montant élevé, opération hors heures).

L'échantillon aléatoire permet d'étendre la conclusion à la population ; l'échantillon raisonné va droit aux anomalies probables, mais ne permet pas cette extension. L'auditeur dit toujours lequel il a utilisé.

7.6.2 L'échantillonnage par attributs, démontré

On teste un attribut (le contrôle a-t-il été exécuté ?) sur n opérations tirées au hasard. On veut pouvoir dire, avec une confiance c, que le taux réel d'écart ne dépasse pas un taux toléré t, si l'on ne trouve aucun écart.

Si le taux réel d'écart était exactement t, la probabilité de ne trouver aucun écart sur n tirages indépendants serait $(1-t)^n$. Pour que ce résultat soit peu probable, au plus $1-c$, il faut :

$$(1-t)^n \le 1-c \quad \Longleftrightarrow \quad n \ge \frac{\ln(1-c)}{\ln(1-t)}.$$

Confiance c	Taux toléré t	Calcul	Taille n
95 %	5 %	$\ln 0{,}05 / \ln 0{,}95 \approx 58{,}4$	59
90 %	5 %	$\ln 0{,}10 / \ln 0{,}95 \approx 44{,}9$	45
95 %	10 %	$\ln 0{,}05 / \ln 0{,}90 \approx 28{,}4$	29

Tableau 7.3. Tailles d'échantillon par attributs, sans écart attendu

7.6.3 Conclure sur l'échantillon

- **Aucun écart** : avec une confiance c, le taux d'écart ne dépasse pas t ; le contrôle est coté OUI pour la période.
- **Un écart ou plus** : la conclusion par attributs tombe ; le contrôle est NON, et l'on examine chaque écart (cause, montant).
- **Des éléments introuvables** : s'ils sont nombreux, la cote est NEK, et l'on écrit les diligences faites.

Outils · Tirer un échantillon aléatoire dans un tableur

Dans la feuille des mandats, ajouter une colonne :

```
H2 : =ALEA()
```

Copier la colonne et la coller en valeurs (pour figer le tirage), trier sur H, retenir les n premières lignes. Conserver la feuille triée : elle prouve le caractère aléatoire du tirage.

7.6.4 Tester toute la population

Quand la donnée est fiable, il est souvent plus probant de tester *toute* la population par une analyse : doublons, trous de numérotation, opérations hors heures, montants juste sous un seuil (Chapitre 12). L'analyse désigne des opérations ; chacune est ensuite examinée pièce par pièce.

7.7 Obtenir une extraction

7.7.1 Quatre garanties

Garantie	Question	Comment l'obtenir
Origine	Le fichier vient-il bien de l'application ?	Assister à l'extraction, ou la faire faire sous ses yeux
Exhaustivité	Toutes les opérations y sont-elles ?	Requête écrite ; nombre de lignes et totaux rapprochés d'une source indépendante
Exactitude	Les valeurs sont-elles celles de l'application ?	Comparer quelques lignes à l'écran
Intégrité	Le fichier n'a-t-il pas changé depuis ?	Empreinte SHA-256 calculée à la remise, contresignée

Tableau 7.4. Les quatre garanties d'une extraction

7.7.2 L'empreinte et les totaux de contrôle

Définition

Empreinte (*hash*) : suite de caractères calculée à partir du contenu d'un fichier par une fonction de hachage (SHA-256). Le moindre changement du fichier change l'empreinte.

Totaux de contrôle : nombre de lignes et sommes, rapprochés d'une source que l'auditeur n'a pas obtenue de la même personne (relevé bancaire, compte administratif, état du poste comptable).

L'empreinte prouve que le fichier n'a pas changé ; elle ne prouve pas qu'il était complet. Il faut les deux.

Outils · Calculer et vérifier une empreinte

Sous Windows, dans l'invite de commandes :

```
certutil -hashfile paie_2025-12.csv SHA256
```

Sous Linux (bureau d'analyse de NDAP SUKULU) :

```
sha256sum paie_2025-12.csv
sha256sum -c MANIFESTE_SHA256.txt
```

Scénario Opérationnel · Dossier CAPNO. Trois lignes de moins

Constatation. La première extraction de la paie de décembre 2025, remise sur une clé, compte 4 309 lignes. L'ordre de virement transmis à la banque porte sur 1 293 418 500 FCFA pour 4 312 bénéficiaires. Il manque trois lignes, pour un total de 1 905 000 FCFA.

Analyse (confiance élevée). L'extraction n'était pas exhaustive. M. HAMADOU la fait refaire devant lui le 6 mai 2026 : 4 312 lignes, totaux égaux à l'ordre de virement. Les trois lignes absentes deviennent les premières à examiner : pourquoi manquaient-elles ?

7.8 Les papiers de travail

Le manuel de l'IDI le rappelle : la documentation doit permettre à un auditeur expérimenté, sans lien avec la mission, de comprendre les travaux, les preuves et les conclusions [10]. C'est aussi la traduction pratique de l'axiome d'*opposabilité* : une conclusion qui ne peut pas être refaite ne peut pas être défendue [25].

Papier de travail

Feuille de test, une par contrôle testé :

1. référence (position dans le gabarit, ligne du programme) ;
2. fiche d'assertion (critères et questions) ;
3. population (source, nombre, totaux, empreinte du fichier) ;
4. échantillon (méthode, confiance, taux toléré, taille, liste) ;
5. résultat élément par élément, avec la pièce examinée ;
6. cote de chaque critère et cote du contrôle, avec la constatation ; pour un NEK, les diligences et la relance ;
7. auteur, date, et visa du chef de mission.

Note

Conserver. Les extractions sont des données personnelles (paie) ou sensibles (fournisseurs). Elles sont conservées sur un support protégé, avec leur empreinte, aussi longtemps que les suites possibles l'exigent, puis détruites selon les règles de l'institution.

Application Vérificateur

Annoncez NEK dès le premier entretien : « si vous ne savez pas, dites-le ; c'est une réponse utile ». Vous obtiendrez moins de OUI, et davantage de vérité.

Application Juge des comptes

Une pièce électronique produite à l'instance vaut si l'on peut en établir l'origine et l'intégrité. Demandez le procès-verbal de remise et l'empreinte ; leur absence affaiblit la pièce.

Application Auditeur interne

Remplacez vos grilles OUI / NON par l'instrument à trois réponses, et mesurez ρ sur vos propres questionnaires : vous saurez de combien vos évaluations passées surestimaient la conformité.

À retenir

- **Trois réponses, fondées en théorie.** OUI, NON, NEK ; la modalité NEK découle des axiomes 1 à 4 d'A0.

- **NEK n'est pas « non applicable ».** Un contrôle sans objet sort de la décomposition.
- **La grille binaire surestime** ; ρ mesure de combien (0,30 sur les accès du MINÉQUIR).
- **Une hiérarchie de preuves** ; une déclaration seule donne NEK ; deux sources indépendantes valent mieux qu'une.
- **L'entretien ne suggère pas** ; il admet « je ne sais pas ».
- $n \geq \ln(1-c)/\ln(1-t)$: 59 tirages pour 95 % de confiance et 5 % d'écart toléré.
- **Empreinte et totaux** : intégrité et exhaustivité d'une extraction.
- **Un tiers doit pouvoir refaire** : c'est l'opposabilité.

✍ Exercice 7.1. Coter avec la bonne preuve ★☆☆

Pour chaque situation, donnez la cote et le rang de la preuve (Tableau 7.1) : (a) le DAF affirme que les profils sont revus chaque semestre ; (b) la matrice extraite devant vous montre cinq comptes LIQ + ORD ; (c) une note signée prévoit la désactivation sous 48 heures, mais le journal n'a pas encore été remis ; (d) la DRH et la cellule donnent deux dates de désactivation différentes pour le même agent.

✍ Exercice 7.2. L'indice ρ ★☆☆

Sur le domaine D4 (exploitation), la grille binaire de 2025 donnait 14 OUI sur 20 ; l'instrument trichotomique donne 8 OUI, 4 NON, 8 NEK. Calculez $\hat{\mu}^B$, μ^T et ρ, et dites ce que cela signifie.

✍ Exercice 7.3. Dimensionner ★★☆

Vous voulez conclure, avec 95 % de confiance, que le visa du contrôle financier manque sur moins de 3 % des mandats de 2025. (a) Combien de mandats tirez-vous ? (b) Vous trouvez un mandat sans visa : que concluez-vous ? (c) Que proposez-vous plutôt, puisque l'extraction des 9 611 mandats est disponible ?

✍ Exercice 7.4. Trois lignes ★★★

Les trois lignes absentes de la première extraction de la CAPNO correspondent à trois agents créés le 28 novembre 2025 par le même compte. Dites ce que cela suggère, ce que vous ne pouvez pas encore affirmer, les trois pièces que vous demandez, et la cote provisoire du contrôle « l'extraction remise est exhaustive ».

Note

Transition. Les réponses sont recueillies, les contrôles cotés, les preuves conservées. Le Chapitre 8 apprend à lire ces réponses par trois mesures, à conclure, à rapporter et à suivre.

8

MESURER, CONCLURE, RAPPORTER, SUIVRE

« On ne lit jamais l'entropie sans l'incertitude,
ni l'incertitude sans la conformité. »

Règle du cours, d'après A1

Niveau : *Intermédiaire* • Chapitre 7.

✦ Objectifs du chapitre

- ➢ Calculer et interpréter les trois mesures μ, U et H d'un domaine, et en connaître les cas limites.
- ➢ Décomposer l'entropie en part d'ignorance et part de désaccord.
- ➢ Situer un domaine dans le quadrant conformité × incertitude et en déduire l'action.
- ➢ Appliquer la règle de décision du cours : U d'abord, μ ensuite, H pour contrôler.
- ➢ Rédiger une observation en sept éléments, et la relier au constat en cinq éléments.
- ➢ Conduire la procédure contradictoire et rédiger le rapport.
- ➢ Suivre les recommandations et comparer deux cycles par la divergence de Kullback-Leibler.
- ➢ Préserver la preuve quand le constat peut fonder une suite.

Pourquoi ce chapitre

Les cotes OUI, NON et NEK sont des résultats de travail. Pour conclure, il faut les lire ensemble, domaine par domaine, sans confondre ce que l'on sait et ce que l'on ignore. L'article A1 donne pour cela trois mesures et un quadrant [24] ; l'article A0, la distinction entre non-conformité connue et non-conformité inconnue [25]. Ce chapitre les applique au dossier MINÉQUIR, puis suit le rapport jusqu'au plan d'action et au cycle suivant.

Plan du chapitre.

1. Trois mesures (section 8.1) et la décomposition de l'entropie (section 8.2).
2. Le quadrant et la règle de décision (sections 8.3 et 8.4).
3. Le constat et l'observation (section 8.5).
4. Le rapport et la procédure contradictoire (sections 8.6 et 8.7).
5. Suivre les recommandations et comparer les cycles (sections 8.8 et 8.9).
6. Quand le constat devient une affaire (section 8.10).

8.1 Trois mesures

8.1.1 Les définitions

Pour un ensemble de réponses (une question posée à plusieurs répondants, ou toutes les questions d'un domaine), on note $p(\text{OUI})$, $p(\text{NON})$ et $p(\text{NEK})$ les parts de chaque réponse.

Définition

Taux de conformité : $\mu = p(\text{OUI})$.

Taux d'incertitude : $U = p(\text{NEK})$.

Entropie : dispersion des réponses, en bits,

$$H = -\sum_{m \in \{\text{OUI},\text{NON},\text{NEK}\}} p(m)\log_2 p(m), \qquad 0 \le H \le \log_2 3 \approx 1{,}585,$$

avec la convention $0 \log_2 0 = 0$.

Définitions de l'article A1 [24] ; l'entropie est celle de Shannon [31].

L'entropie est nulle quand tous répondent la même chose, maximale quand les trois réponses sont également fréquentes. Au niveau d'un domaine, on agrège les réponses de toutes ses questions avant de calculer : les mesures se recalculent toujours à partir des réponses, jamais comme moyenne des mesures du niveau inférieur.

8.1.2 Quatre cas limites

Situation	μ	U	H	Lecture
Tous répondent OUI	1	0	0	Conformité certaine
Tous répondent NON	0	0	0	Non-conformité certaine
Tous répondent NEK	0	1	0	**Ignorance unanime**
Réponses également réparties	1/3	1/3	1,585	Dispersion maximale

Tableau 8.1. Les cas limites des trois mesures (d'après [24])

★ Attention

Violation typique. Conclure « certitude » parce que l'entropie est nulle.

Règle : une entropie nulle signifie seulement que tous ont donné la même réponse. Si cette réponse est NEK, personne ne sait rien : $H = 0$ et $U = 1$. On ne lit jamais H sans U ni μ.

8.1.3 Les quatre domaines du MINÉQUIR

En mars 2026, la vérificatrice a posé cinq questions par domaine aux quatre interlocuteurs du Chapitre 7, soit vingt réponses par domaine.

Domaine	oui	non	nek	μ	U	H
D1 Accès	11	3	6	0,55	0,30	1,41
D2 Fichier des fournisseurs	6	12	2	0,30	0,10	1,30
D3 Circuit du mandat	15	3	2	0,75	0,10	1,05
D4 Exploitation	8	4	8	0,40	0,40	1,52

Tableau 8.2. Les trois mesures des quatre domaines (réponses des répondants, mars 2026)

>_ Outils · Calculer les trois mesures

Dans un tableur, avec les effectifs en B2 (OUI), C2 (NON), D2 (NEK) :

```
E2 (mu) : =B2/SOMME(B2:D2)
F2 (U)  : =D2/SOMME(B2:D2)
G2 (H)  : =-SOMME(SI(B2:D2>0;B2:D2/SOMME(B2:D2)*LOG(B2:D2/SOMME(
   B2:D2);2);0))
```

La dernière formule se valide comme formule matricielle dans les tableurs qui l'exigent.

8.2 Décomposer l'entropie

Une entropie élevée peut venir de deux choses très différentes : beaucoup de répondants ne savent pas (ignorance), ou ceux qui savent ne sont pas d'accord (désaccord entre OUI et NON). On ne traite pas l'ignorance comme le désaccord.

On regroupe les réponses en deux classes : NEK (probabilité U) et « réponse informée » (OUI ou NON, probabilité $1-U$). Dans la seconde classe, la part des OUI vaut $\mu/(1-U)$. La règle de chaînage de l'entropie [6], [31] donne, pour $U < 1$:

$$H = \underbrace{H_b(U)}_{\text{ignorance}} + \underbrace{(1-U)\, H_b\!\left(\frac{\mu}{1-U}\right)}_{\text{désaccord}}, \qquad H_b(x) = -x\log_2 x - (1-x)\log_2(1-x).$$

Domaine	H	$H_b(U)$	Désaccord	Part d'ignorance	Lecture
D1 Accès	1,41	0,88	0,53	63 %	Surtout ignorance
D2 Fournisseurs	1,30	0,47	0,83	36 %	Surtout désaccord
D4 Exploitation	1,52	0,97	0,55	64 %	Surtout ignorance

Tableau 8.3. Décomposition de l'entropie de trois domaines

Lecture auditologique · Deux entropies voisines, deux démarches

D1 et D2 ont des entropies proches (1,41 et 1,30), pour des raisons opposées.

Analyse (confiance élevée). Dans D1, près des deux tiers de l'entropie viennent de l'ignorance : personne ne sait vraiment qui désactive les comptes ; on cherche la preuve. Dans D2, la dispersion vient du désaccord : le DAF croit les RIB contrôlés, le chef de la liquidation sait qu'ils ne le sont pas ; on confronte les deux versions à la trace. Le même chiffre appelle deux démarches.

$\mu = 0{,}55$ · $U = 0{,}30$ · $H = 1{,}41$ **bit**

8.3 Le quadrant conformité × incertitude

L'article A1 propose de lire ensemble la conformité et l'incertitude dans un quadrant à quatre régions, chacune appelant une action différente [24]. Le cours retient, par convention, un seuil de 0,5 pour μ et de 0,20 pour U ; chaque mission peut fixer les siens, à condition de les écrire dans le programme de travail.

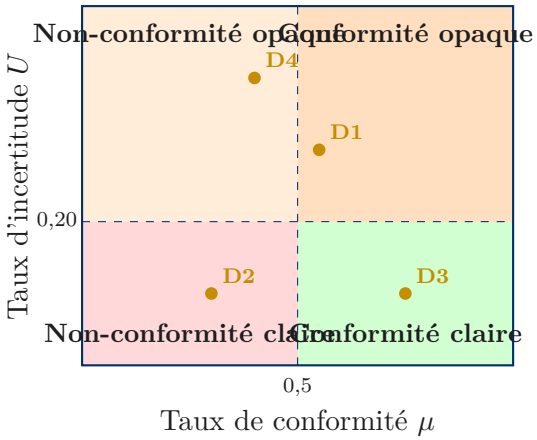


Figure 8.1. Le quadrant diagnostique et les quatre domaines du MINÉQUIR (d'après [24] ; seuils du cours ; échelle verticale $U \times 10$)

Région	Situation	Action
Conformité claire	On s'accorde, avec assurance, sur la conformité	Validation courante
Non-conformité claire	On s'accorde, avec assurance, sur la non-conformité	Correctifs
Conformité opaque	Des OUI nombreux, mais une part importante de NEK	**Alerte prioritaire** : rechercher la preuve avant toute conclusion
Non-conformité opaque	Des NON nombreux et une part importante de NEK	Rechercher la preuve et engager des premiers correctifs

Tableau 8.4. Les quatre régions et leurs actions (d'après [24])

La conformité opaque est la région la plus dangereuse : une grille binaire la confond avec la conformité claire. C'est le domaine D1 du MINÉQUIR, celui du double paiement. L'article A0 dit la même chose dans son vocabulaire : la *non-conformité connue* appelle des correctifs ; la *non-conformité inconnue*, que cachent les régions opaques, appelle d'abord des investigations [25].

8.4 La règle de décision du cours

Papier de travail

Conclure sur un domaine.

1. *U* **d'abord.** Si $U \geq 0{,}20$, le domaine est opaque : aucune conclusion de conformité n'est possible. L'auditeur recherche la preuve, ou conclut *sur l'opacité elle-même.*
2. μ **ensuite.** Si $U < 0{,}20$, le domaine est clair : conforme si $\mu \geq 0{,}5$, non conforme sinon.
3. *H* **pour contrôler.** Une entropie élevée avec *U* faible signale un désaccord : le domaine n'est pas homogène ; on le décompose avant de conclure (Chapitre 6).
4. **Les cotes de l'auditeur prévalent.** Les mesures des répondants orientent ; la conclusion repose sur les contrôles cotés par l'auditeur, preuve à l'appui (Chapitre 7).

Lecture auditologique · Les quatre domaines du MINÉQUIR

Analyse (confiance moyenne).

- *D1* : conformité opaque ; alerte prioritaire. Les tests (Chapitre 9) établiront un seul contrôle sur six conforme : l'opacité cachait une non-conformité.
- *D2* : non-conformité claire ; correctifs immédiats sur les RIB.
- *D3* : conformité claire selon les répondants ; mais l'auditeur a coté NON le blocage des doublons (règle 4) : la conclusion suit les cotes.
- *D4* : non-conformité opaque ; investigations et premiers correctifs.

Attention

Violation typique. Moyenner les quatre domaines pour donner une note globale (« le circuit est conforme à 50 % »).

Règle : une moyenne efface les régions du quadrant. Le rapport présente chaque domaine dans sa région.

8.5 Le constat en cinq éléments

8.5.1 Le constat

Élément	Question	Règle de rédaction
Condition	Qu'a-t-on constaté ?	Un fait vérifiable, chiffré, daté, avec sa source et sa cote
Critère	Que fallait-il ?	La règle citée exactement, avec sa force (Chapitre 5)
Cause	Pourquoi l'écart ?	Ce qui, dans le dispositif, l'explique ; la cause appelle la recommandation
Effet	Qu'est-ce que cela produit ou permet ?	Le risque réalisé ou possible, chiffré quand on le peut
Recommandation	Que faire ?	Une action, un responsable, une échéance

Tableau 8.5. Les cinq éléments d'un constat

8.5.2 L'observation en sept éléments

La méthode du cours d'audit de l'auteur développe le constat en une **observation** en sept éléments. Les deux éléments ajoutés sont indispensables à l'opposabilité (axiome 6 d'A0 [25]) : la trace du contradictoire, et une conclusion explicite qui sépare la position de l'auditeur de son analyse.

Constat en cinq éléments	Observation en sept éléments
Critère	1. Norme
Condition	2. Constatation (avec la cote)
Effet	3. Risques
(absent)	4. Contradictoire
Cause	5. Analyse (avec un niveau de confiance)
(absent)	6. Conclusion
Recommandation	7. Recommandations

Tableau 8.6. Du constat à l'observation

Point de contrôle · D1.1.2 · Observation

1. Norme : le compte d'un agent est désactivé à la date d'effet de sa mutation (bonne pratique : COSO 2013, principe 11 ; aucune règle interne).
2. Constatation : au 23 mars 2026, 9 des 31 agents mutés ou partis en 2025 ont un compte actif, dont `mbarga.j`, qui cumule LIQ, ORD et FRS (extractions et empreintes au dossier). Cote NON.
3. Risques : un compte resté actif a servi, les 27 et 28 décembre 2025, à modifier un RIB et à émettre seul un mandat de 187 450 000 FCFA.

4. Contradictoire : le 30 avril 2026, la DAF indique que les mutations ne lui sont pas notifiées par les ressources humaines.
5. Analyse (confiance élevée) : la cause est l'absence de flux entre le fichier du personnel et la cellule informatique, et l'absence de procédure ; non la négligence d'un agent.
6. Conclusion : le contrôle D1.1.2 n'est pas efficace ; déficience majeure du domaine D1 (Chapitre 3).
7. Recommandations : désactiver les 9 comptes ; organiser la notification écrite des mutations par la DRH ; imposer dans SIDÉPENSE l'incompatibilité LIQ / ORD.

★ Attention

Violation typique. Écrire dans les risques : « M. MBARGA a détourné 187 450 000 FCFA ».

Règle : l'observation dit ce que la preuve établit : un compte, pas une personne. L'imputation relève d'une autre procédure.

8.5.3 Écrire une recommandation

Mal écrite	Bien écrite
Renforcer la sécurité des accès	Organiser la notification écrite des mutations de la DRH vers la cellule, avant le 31 juillet 2026 (responsable : DRH)
Désactiver les comptes inutiles	Désactiver sous 48 heures les 9 comptes identifiés (annexe C), puis revoir chaque semestre les comptes actifs (responsable : DAF)
Sanctionner M. MBARGA	(Hors du rôle de l'auditeur : la sanction relève de l'autorité compétente, après enquête.)

Tableau 8.7. Écrire une recommandation

8.6 Le rapport

1. **Synthèse** : l'objectif, la conclusion sur l'efficacité du contrôle interne, les domaines dans leur région du quadrant, les déficiences majeures, en une page.
2. **Mandat et étendue** : fondement, périmètre, période, travaux, seuils de décision, et **limitations d'étendue** (les NEK restants, avec les diligences faites).
3. **Mesures par domaine** : μ, U, H et région.

4. **Observations**, classées par domaine puis par gravité.
5. **Tableau des déficiences** et leur classement.
6. **Réponses de l'entité** et position de l'auditeur.
7. **Annexes** : matrice des risques et des contrôles, décomposition, liste des pièces et de leurs empreintes.

Un NEK qui reste n'est pas caché : la restitution impartiale l'exige, et la conclusion ne peut pas porter sur ce qui n'a pas pu être établi.

8.7 La procédure contradictoire

8.7.1 Pourquoi le contradictoire

Le rapport provisoire est adressé à l'entité, qui répond par écrit dans un délai fixé. Le contradictoire n'est pas une politesse : il réduit l'incertitude. L'audité connaît des faits que l'auditeur ignore ; sa réponse peut lever un NEK, corriger une cause, ou révéler une pièce. Il est aussi la condition de l'opposabilité : une conclusion que l'audité n'a pas pu discuter se défend mal devant le CDBF ou la Chambre des Comptes.

Réponse de la DAF (30 avril 2026)	Position de la vérificatrice	Effet sur le rapport
« Les mutations ne nous ont pas été notifiées par les ressources humaines. »	Exact ; c'est la cause relevée ; ne change pas la condition	Observation maintenue, cause précisée
« Les 9 comptes ont été désactivés le 20 avril. »	Pièce fournie (journal)	Mention au rapport ; R-01 mise en œuvre
« La séparation a toujours été respectée en pratique. »	Contredit par le mandat 2025-09342 (journal)	Observation maintenue

Tableau 8.8. Le contradictoire du dossier MINÉQUIR

8.7.2 Maintenir, modifier, retirer

Pour chaque réponse, l'auditeur décide, et motive : il *maintient* l'observation, la *modifie* au vu d'une pièce nouvelle, ou la *retire*. Une déclaration sans pièce ne fait jamais changer une cote NON ; elle peut, au mieux, transformer une cause.

Papier de travail

Fiche de contradictoire, une par observation : date d'envoi du rapport provisoire ; réponse reçue (date, signataire, texte) ; pièces nouvelles ; position motivée ;

modification apportée au rapport définitif.

8.8 Suivre les recommandations

N°	Recommandation	Responsable	Échéance	Statut
R-01	Désactiver les 9 comptes	Cellule informatique	20/04/2026	Fait
R-02	Imposer l'incompatibilité LIQ / ORD dans SIDÉPENSE	Cellule, éditeur	30/06/2026	En cours
R-03	Double validation des RIB	DAF, cellule	30/06/2026	En cours
R-04	Bloquer les doublons (fournisseur, montant, facture normalisée)	Cellule, éditeur	30/06/2026	En cours
R-05	Notification des mutations par les ressources humaines	DRH	31/07/2026	Non commencé
R-06	Revue des mandats de fin de gestion	DAF, contrôle financier	31/12/2026	Non commencé

Tableau 8.9. Plan d'action du MINÉQUIR (situation au 15 mai 2026)

Le suivi vérifie la mise en œuvre par une preuve, pas par une déclaration : pour R-02, la vérificatrice demandera une tentative, en environnement de test, d'attribuer LIQ et ORD au même compte.

Note

L'audit modifie ce qu'il observe. L'article A0 énonce une proposition de *réflexivité* : l'acte d'audit fait partie de la trajectoire du système audité [25]. Le plan d'action change le système ; le cycle suivant n'audite donc pas le même objet. C'est pourquoi on compare des distributions, et non des taux isolés.

8.9 Comparer deux cycles

8.9.1 Pourquoi le taux de conformité ne suffit pas

Le taux de conformité seul peut rester stable alors que l'état de connaissance change : des NEK deviennent des NON, l'entité sait désormais ce qu'elle ignorait. Il faut comparer les *distributions* de réponses. C'est la conséquence de l'*individuation temporelle* (axiome 5) : les conclusions d'une mission ne se testent que sur plusieurs cycles [25].

Définition

Divergence de Kullback-Leibler : pour deux distributions p (nouveau cycle) et q (cycle précédent) sur $\{\text{OUI}, \text{NON}, \text{NEK}\}$ [18], [24],

$$D_{\mathrm{KL}}(p \,\|\, q) = \sum_{m} p(m) \log_2 \frac{p(m)}{q(m)}.$$

Elle est positive ou nulle, nulle si et seulement si les deux distributions sont identiques ; elle n'est pas symétrique (on mesure toujours le nouveau cycle par rapport à l'ancien) ; elle s'exprime en bits.

Scénario Opérationnel · Dossier MINÉQUIR. Le domaine D1 en novembre 2026

Faits. En mars 2026, D1 donnait 11 OUI, 3 NON, 6 NEK. À l'audit de suivi de novembre 2026, après R-01 à R-03, les mêmes questions posées aux mêmes fonctions donnent 17 OUI, 2 NON, 1 NEK.

Calcul. μ passe de 0,55 à 0,85, U de 0,30 à 0,05, H de 1,41 à 0,75 bit. La divergence vaut

$$0{,}85 \log_2 \frac{0{,}85}{0{,}55} + 0{,}10 \log_2 \frac{0{,}10}{0{,}15} + 0{,}05 \log_2 \frac{0{,}05}{0{,}30} \approx 0{,}534 - 0{,}058 - 0{,}129 \approx 0{,}35 \text{ bit}.$$

Analyse (confiance moyenne). D1 est passé de la conformité opaque à la conformité claire. La vérificatrice confirmera par ses propres tests (revue des comptes actifs, essai de cumul en environnement de test) avant de conclure.

8.9.2 Le lissage

Si une réponse est absente au premier cycle et présente au second, un terme de la divergence devient infini : ce n'est pas que le changement soit infini, c'est que le premier échantillon, petit, n'a rien observé. On ajoute alors une unité fictive à chaque réponse des deux cycles (lissage de Laplace). La divergence de D1 devient 0,25 bit. On applique le même lissage à toutes les comparaisons d'une mission, et on l'écrit dans le programme.

Outils · Calculer la divergence (Python)

```python
from math import log2
def dkl(nouveau, ancien, lissage=0):
    a = [x + lissage for x in nouveau]
    b = [x + lissage for x in ancien]
    p = [x / sum(a) for x in a]
    q = [x / sum(b) for x in b]
    return sum(pi * log2(pi / qi) for pi, qi in zip(p, q) if pi > 0)

```

```
print(round(dkl([17, 2, 1], [11, 3, 6]), 3))      # 0.346
print(round(dkl([17, 2, 1], [11, 3, 6], 1), 3))   # 0.247 (lissée)
```

8.10 Quand le constat devient une affaire

Une observation peut fonder une suite : saisine du CDBF, que le CONSUPE peut engager (décret n° 2013/287, art. 3 et 5) ; transmission à la Chambre des Comptes ; plainte pénale. L'auditeur n'instruit pas ces procédures, mais il les rend possibles ou impossibles par la qualité de sa preuve.

- **Geler la preuve** : conserver les extractions originales, leurs empreintes et les procès-verbaux ; travailler sur des copies.
- **Ne pas alerter** : ne pas interroger la personne soupçonnée sur les faits avant que l'autorité ait décidé de la suite.
- **Demander la conservation** des journaux au-delà de leur durée habituelle.
- **Séparer** : le rapport traite du contrôle interne ; une note distincte, adressée à la hiérarchie, présente les faits susceptibles de poursuite.

Application Vérificateur

Présentez dans la synthèse les domaines par région du quadrant, et non par une note globale. Une « conformité opaque » écrite en toutes lettres protège votre rapport mieux qu'un taux flatteur.

Application Juge des comptes

Une limitation d'étendue écrite au rapport dit ce que l'auditeur n'a pas pu établir ; elle désigne les pièces que l'instruction peut exiger.

Application Auditeur interne

Refaites chaque année les mêmes questions aux mêmes fonctions, et calculez la divergence entre les cycles : c'est la mesure la plus honnête de l'effet de vos recommandations.

★ À retenir

- **Trois mesures** : μ (conformité), U (incertitude), H (entropie, au plus $\log_2 3$) ; jamais l'une sans les autres.
- **L'entropie se décompose** en ignorance et désaccord ; chacun appelle sa démarche.
- **Le quadrant** sépare quatre régions ; la conformité opaque est la plus dangereuse.
- **La règle de décision** : U d'abord, μ ensuite, H pour contrôler ; les cotes de l'auditeur prévalent.
- **Sept éléments** : l'observation ajoute au constat le contradictoire et la conclusion, pour l'opposabilité.
- **Le contradictoire réduit l'incertitude** ; une déclaration sans pièce ne fait pas changer un NON.
- **Comparer les cycles** par la divergence de Kullback-Leibler, avec le même lissage partout.
- **Préserver la suite** : geler la preuve, ne pas alerter, séparer rapport et note de faits.

✍ Exercice 8.1. Calculer et situer ★☆☆

Calculez μ, U et H pour (a) 18 OUI, 1 NON, 1 NEK ; (b) 0 OUI, 0 NON, 20 NEK ; (c) 10 OUI, 8 NON, 2 NEK. Situez chacun dans le quadrant et dites l'action.

✍ Exercice 8.2. Ignorance ou désaccord ? ★★☆

Décomposez l'entropie du domaine D3 (15 OUI, 3 NON, 2 NEK) et dites quelle démarche elle appelle. Expliquez pourquoi la conclusion du domaine reste NON sur le blocage des doublons.

✍ Exercice 8.3. L'observation ★★☆

Rédigez l'observation en sept éléments sur le contrôle « seconde validation des modifications de RIB » (domaine D2), à partir des faits du prologue et de la réponse de la DAF : « les RIB sont modifiés sur demande écrite du fournisseur » (aucune demande n'est produite pour BATIRURAL).

✍ Exercice 8.4. Deux cycles ★★★

À l'audit de suivi, D4 donne 8 OUI, 10 NON, 2 NEK (contre 8, 4, 8 en mars). (a) Le taux de conformité a-t-il changé ? (b) Calculez la divergence. (c) Dites si l'exploitation s'est améliorée, et rédigez la phrase du rapport de suivi.

Note

Transition. La méthode est complète, du mandat au cycle suivant. La Partie IV l'applique domaine par domaine, en commençant par celui dont tout dépend : les accès (Chapitre 9).

partie IV

Domaines d'Audit

© *MaletYon*

9

ACCÈS ET HABILITATIONS

« Un droit d'accès est une signature que l'on peut prêter. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3 et 7.

✦ Objectifs du chapitre

- ➢ Décrire le cycle de vie d'un compte et les contrôles attendus à chaque étape.
- ➢ Repérer les comptes à risque : partis, génériques, à privilèges, inactifs.
- ➢ Croiser la liste des comptes avec le fichier du personnel.
- ➢ Analyser une matrice de profils et identifier les conflits de séparation des tâches.
- ➢ Évaluer la revue périodique des habilitations.
- ➢ Coter les contrôles d'accès et classer les déficiences.

Pourquoi ce chapitre

Les accès sont le premier des contrôles généraux informatiques, et le plus important : s'ils ne sont pas maîtrisés, aucun autre contrôle n'est fiable (Chapitre 2). Le double paiement du prologue est d'abord une défaillance des accès. Ce chapitre donne la grille complète pour les évaluer.

9.1 Le cycle de vie d'un compte

© MaletYon

Étape	Contrôle attendu	Preuve à demander
Création	Demande écrite, validée par le chef de service, pour un agent identifié	Formulaires de demande, liste des créations
Attribution des profils	Profils conformes à la fiche de poste ; pas de combinaison interdite	Matrice des profils, demandes
Modification	Nouvelle demande validée lors d'un changement de poste	Historique des profils
Revue périodique	Le propriétaire de l'application valide la liste des comptes et des profils	Revues signées, avec suites
Désactivation	À la date d'effet du départ ou de la mutation	Journal des désactivations, rapproché du fichier du personnel

Tableau 9.1. Le cycle de vie d'un compte

Définition

Propriétaire d'application : responsable métier qui décide des droits dans une application (pour SIDÉPENSE, le directeur des affaires financières). La cellule informatique *exécute* les décisions du propriétaire ; elle ne les prend pas.

9.2 Les comptes à risque

Type	Risque	Test
Compte d'un agent parti	Utilisé par l'ancien titulaire ou par un tiers	Croiser avec le fichier du personnel
Compte générique (`saisie01`)	Aucune action n'est imputable à une personne	Lister les comptes sans titulaire nominatif
Compte à privilèges (ADM)	Peut tout faire, y compris effacer ses traces	Lister les détenteurs, vérifier la journalisation de leurs actions
Compte inactif	Oublié, donc non surveillé	Dernière connexion de plus de 90 jours

Tableau 9.2. Les comptes à risque

Outils · Croiser les comptes avec le fichier du personnel

Deux feuilles dans le même classeur : `COMPTES` (colonne A matricule) et `PERSONNEL` (colonne A matricule, colonne D situation). Dans `COMPTES` :

```
E2 : =SIERREUR(RECHERCHEV(A2;PERSONNEL!$A:$D;4;FAUX);"ABSENT")
```

Un filtre sur `E` donne les comptes d'agents mutés ou partis (situation autre que « en poste ») et les comptes sans titulaire au fichier (`ABSENT`), qui sont souvent des comptes génériques.

Scénario Opérationnel · Dossier MINÉQUIR. Les 47 comptes

Constatation. Au 23 mars 2026, SIDÉPENSE compte 47 comptes actifs. Le croisement avec le fichier du personnel donne 9 comptes d'agents mutés ou partis et 3 comptes sans titulaire : `saisie01`, `daf` et `admin`. Le profil ADM est détenu par `atangana.p` et par le compte générique `admin`. Les mots de passe n'expirent jamais.

Analyse (confiance élevée). Le compte `admin` est le plus grave : il peut tout faire, et rien de ce qu'il fait n'est imputable à une personne. Le journal du prologue ne serait d'aucune aide si les opérations du 28 décembre avaient été faites sous ce compte.

9.3 La matrice des profils

L'analyse part de la matrice extraite par l'auditeur (un compte par ligne, un profil par colonne) et des paires interdites du Tableau 2.6.

Outils · Repérer les conflits dans la matrice

Colonnes `B` à `F` : ENG, LIQ, ORD, FRS, ADM (1 si le compte détient le profil, 0 sinon). Une colonne par paire interdite :

```
G2 (LIQ+ORD) : =SI(ET(C2=1;D2=1);"CONFLIT";"")
H2 (FRS+ORD) : =SI(ET(E2=1;D2=1);"CONFLIT";"")
I2 (FRS+LIQ) : =SI(ET(E2=1;C2=1);"CONFLIT";"")
J2 (ADM+...) : =SI(ET(F2=1;SOMME(B2:E2)>0);"CONFLIT";"")
```

Scénario Opérationnel · Dossier MINÉQUIR. Les conflits

Constatation. Cinq comptes réunissent LIQ et ORD, dont `mbarga.j` ; deux réunissent FRS et ORD (`mbarga.j` et `nkolo.r`). Aucune revue des habilitations n'a été faite depuis la mise en service de SIDÉPENSE en 2024.

Analyse (confiance élevée). Le conflit LIQ + ORD n'est pas un cas isolé : il touche cinq comptes, ce qui montre que la séparation n'a jamais été conçue dans

l'attribution des profils. L'absence de revue explique que personne ne l'ait vu.

9.4 La revue des habilitations

Définition

Revue des habilitations : contrôle détectif par lequel le propriétaire de l'application examine, à intervalle fixé, la liste des comptes et de leurs profils, confirme ou retire chaque droit, et signe. Elle n'est efficace que si la liste est exhaustive et extraite de l'application, et si les retraits décidés sont exécutés.

Point de contrôle · C-ACC-03 · Revue des habilitations

Objectif. Les droits dans SIDÉPENSE restent conformes aux fonctions.
Risque couvert. Accumulation de droits, comptes oubliés.
Critère. Revue semestrielle signée par le DAF (bonne pratique ; aucune règle interne).
Test de conception. Une procédure de revue existe-t-elle ? Non.
Test de fonctionnement. Sans objet : aucune revue n'a eu lieu.
Cote. NON.

9.5 L'authentification

L'authentification relie un compte à une personne. Les contrôles attendus sont simples : un compte par personne, un mot de passe personnel, une longueur minimale, un changement périodique ou une authentification à deux facteurs pour les profils sensibles, un verrouillage après plusieurs échecs. Ces règles relèvent aussi de l'audit de sécurité de l'ANTIC (Chapitre 4) : le vérificateur les note sans conduire lui-même un audit de sécurité.

★ Attention

Violation typique. Constater que les mots de passe n'expirent jamais, et conclure que la sécurité de SIDÉPENSE est défaillante.

Règle : rester dans son objectif. Pour le contrôle interne de la dépense, le constat est que l'imputation des opérations aux personnes n'est pas garantie ; la sécurité d'ensemble relève de l'audit de sécurité.

9.6 Lecture du domaine

Contrôle	Cote	Pièce
Création sur demande validée	NON	Aucune demande archivée
Profils sans combinaison interdite	NON	Matrice (5 et 2 conflits)
Désactivation à la date du départ	NON	9 comptes sur 31
Revue des habilitations	NON	Aucune revue
Comptes nominatifs	NON	3 comptes génériques
Journalisation des actions des comptes ADM	OUI	Journal

Tableau 9.3. Lecture du domaine D1 (accès)

Lecture auditologique · Domaine D1, accès à SIDÉPENSE

Constatation. Un contrôle sur six fonctionne.
Analyse (confiance élevée). Le domaine est au niveau 0 ou 1 de l'échelle du Chapitre 3. La déficience est majeure : elle prive de valeur tous les contrôles d'application de SIDÉPENSE.

1 oui sur 6 contrôles applicables · 0 nek

Application Vérificateur

Demandez toujours trois listes extraites devant vous : les comptes et leurs profils, la dernière connexion de chaque compte, et les détenteurs des profils d'administration. Croisez-les avec le fichier du personnel du même jour.

Application Contrôleur financier

Votre visa électronique est un profil. Si un compte générique ou un autre agent peut viser à votre place, votre contrôle n'existe pas : signalez-le par écrit.

Application Auditeur interne

Proposez à la direction une revue semestrielle des habilitations, signée par le propriétaire de l'application : c'est le contrôle le moins coûteux du domaine, et celui qui aurait détecté les cinq conflits.

À retenir

➢ **Cinq étapes, cinq contrôles.** Création, attribution, modification, revue, désactivation.

- ➢ **Le propriétaire décide, la cellule exécute.**
- ➢ **Quatre comptes à risque.** Partis, génériques, à privilèges, inactifs.
- ➢ **Croiser avec le personnel**, le même jour, sur des listes extraites devant l'auditeur.
- ➢ **La matrice révèle les conflits** ; la revue les fait disparaître.
- ➢ **Rester dans son objectif.** L'authentification se note ; l'audit de sécurité relève de l'ANTIC.

✍ Exercice 9.1. Classer les comptes ★☆☆

Classez selon le Tableau 9.2 : (a) `admin` ; (b) `mbarga.j` au 23 mars 2026 ; (c) `saisie01` ; (d) un compte dont la dernière connexion date de juin 2025.

✍ Exercice 9.2. Une formule ★☆☆

Écrivez la formule qui signale, dans la matrice, un compte qui détient à la fois ENG et ORD, puis dites si cette combinaison doit être interdite.

✍ Exercice 9.3. La revue qui ne sert à rien ★★☆

À la CAPNO, une revue des habilitations est signée chaque semestre. Elle porte sur une liste saisie à la main par l'informaticien, et aucun retrait n'a jamais été décidé. Cotez le contrôle et rédigez le constat.

✍ Exercice 9.4. Un petit service ★★★

La recette des finances de Bafoussam n'a que trois agents pour e-RECETTES. Proposez une attribution des profils, les contrôles compensatoires nécessaires et la preuve que chacun doit laisser.

● Note

Transition. Les accès maîtrisés, il faut encore que les programmes et leurs paramètres ne changent pas sans contrôle, et que l'exploitation tienne. C'est l'objet du Chapitre 10.

10

CHANGEMENTS, EXPLOITATION ET CONTINUITÉ

« Une sauvegarde que l'on n'a jamais restaurée est un espoir, pas un contrôle. »

Adage des exploitants

Niveau : *Intermédiaire* • Chapitre 9.

✦ Objectifs du chapitre

- ➢ Évaluer la gestion des changements : demande, test, approbation, mise en production, trace.
- ➢ Repérer une modification directe des données ou des paramètres hors de toute procédure.
- ➢ Évaluer l'exploitation : traitements, incidents, journaux.
- ➢ Tester les sauvegardes par leur journal et par une restauration.
- ➢ Évaluer le plan de continuité et le situer par rapport à l'audit de sécurité de l'ANTIC.

Pourquoi ce chapitre

Un contrôle automatique n'est fiable que si personne ne peut le modifier sans contrôle. Une donnée n'est conservée que si l'on peut la restaurer. Ce chapitre évalue les deux autres familles de contrôles généraux informatiques, sur le dossier e-RECETTES de Bafoussam[1].

[1] La recette des finances, le prestataire NUMÉRIKA SARL, les dates et les montants de ce dossier sont fictifs ; les mécanismes sont exacts.

© *MaletYon*

10.1 La gestion des changements

10.1.1 Le circuit attendu

Définition

Changement : toute modification d'un programme, d'un paramètre (taux, plafond, barème) ou de la structure d'une base, en environnement de production.

Gestion des changements : ensemble des contrôles qui garantissent qu'un changement est demandé, analysé, testé, approuvé par le propriétaire de l'application, mis en production par une autre personne que le développeur, et tracé.

Étape	Contrôle	Preuve
Demande	Écrite, motivée, émise par le métier	Ticket ou fiche
Test	En environnement de test, par le métier	Procès-verbal de recette
Approbation	Par le propriétaire de l'application	Signature, date
Mise en production	Par une personne distincte du développeur	Journal des mises en production
Trace	Toute modification de production est journalisée	Journal de la base

Tableau 10.1. Le circuit d'un changement

10.1.2 Le test

On rapproche la liste des mises en production (journal technique) de la liste des demandes (tickets). Toute mise en production sans demande approuvée est un écart ; toute modification de la base hors mise en production est un écart grave.

Scénario Opérationnel · Dossier e-RECETTES. Quatorze mises en production

Constatation. En 2025, le journal compte 14 mises en production d'e-RECETTES. Onze n'ont aucune demande écrite ; trois seulement ont un procès-verbal de tests. Le 9 septembre 2025, le journal de la base montre une modification directe du taux de pénalité de retard, faite par le compte du prestataire NUMÉRIKA, sans mise en production.

Analyse (confiance élevée). Le paramétrage d'e-RECETTES peut être modifié par le prestataire, sans demande et sans approbation. Tout contrôle automatique de l'application, y compris le calcul des pénalités, perd donc sa valeur probante jusqu'à ce que l'on sache ce qui a été modifié, et quand.

10.2 L'exploitation

L'exploitation fait tourner le système au quotidien : traitements programmés (calculs de fin de mois, transferts vers la trésorerie), surveillance, gestion des incidents, journaux.

Contrôle	Ce que l'on vérifie	Preuve
Traitements	Ils s'exécutent comme prévu ; les échecs sont repris	Journal des traitements, comptes rendus
Incidents	Ils sont enregistrés, analysés, clos	Registre des incidents
Journaux	Ils sont activés, protégés et conservés	Paramètres, échantillon de journaux
Interfaces	Les transferts sont complets	Totaux de contrôle à l'émission et à la réception

Tableau 10.2. Les contrôles d'exploitation

10.3 Les sauvegardes

Point de contrôle · C-EXP-01 · Sauvegardes et restauration

Objectif. Les données d'e-RECETTES peuvent être restaurées après une perte.
Risque couvert. Perte de données de recettes (panne, erreur, attaque).
Critère. Sauvegarde quotidienne réussie, copie hors du site, restauration testée au moins une fois par an (bonne pratique ; aucune règle interne).
Test de conception. La copie est sur un disque dans la salle du serveur : pas de copie hors du site.
Test de fonctionnement. Journal des sauvegardes 2025 : 365 jours, 23 échecs, dont 6 consécutifs du 14 au 19 août 2025. Aucune restauration n'a jamais été tentée.
Cote. NON.

Outils · Analyser un journal de sauvegardes

Le journal donne une ligne par jour (colonne A date, colonne B statut `OK` ou `ECHEC`). Pour compter les échecs et la plus longue suite :

```
Nombre d'echecs  : =NB.SI(B:B;"ECHEC")
C2 (suite)       : =SI(B2="ECHEC";C1+1;0)
Plus longue suite: =MAX(C:C)
```

La plus longue suite d'échecs mesure la perte maximale de données que l'entité a courue sans le savoir.

10.4 La continuité

Définition

Plan de continuité d'activité (PCA) : document qui fixe comment l'entité continue ses missions essentielles pendant une interruption, et comment elle revient à la normale. Il fixe deux durées : l'interruption maximale admissible, et la perte de données maximale admissible.

Le vérificateur ne conduit pas un audit de continuité selon ISO 22301 ; il vérifie trois choses : qu'un plan existe pour les applications financières, qu'il a été testé, et que ses durées sont compatibles avec les sauvegardes réelles. Pour la sécurité d'ensemble, il demande la date et le plan d'action du dernier audit de sécurité de l'ANTIC (loi n° 2010/012, art. 32) ; son absence est un constat (Chapitre 4).

Scénario Opérationnel · Dossier e-RECETTES. Ni plan, ni audit

Constatation. La recette des finances n'a pas de plan de continuité. Aucun audit de sécurité de l'ANTIC n'a été réalisé depuis la mise en service d'e-RECETTES. Les données sont hébergées par NUMÉRIKA hors du pays (Chapitre 13).

Analyse (confiance élevée). Une panne du serveur d'hébergement arrêterait l'encaissement des recettes sans solution de repli, et la dernière sauvegarde utilisable pourrait dater de plusieurs jours.

Lecture auditologique · Domaine D4, changements et exploitation d'e-RECETTES

Constatation. Sur sept contrôles attendus (demande écrite, test, approbation, absence de modification directe, journalisation, sauvegardes, plan de continuité), un seul fonctionne : la journalisation, qui a permis de voir la modification du 9 septembre.

Analyse (confiance élevée). Déficience majeure : le paramétrage n'est pas maîtrisé et la restauration n'est pas garantie.

1 oui sur 7 contrôles applicables · 0 nek

Application Vérificateur

Demandez le journal des mises en production et la liste des demandes de la même période, puis rapprochez-les ligne à ligne. Une mise en production sans demande se voit en quelques minutes.

Application Juge des comptes

Si un taux ou un barème a été modifié en cours d'exercice sans procédure, les montants calculés par l'application avant et après la modification ne reposent pas sur la même règle : demandez la date exacte et l'acte qui l'autorisait.

Application Auditeur interne

Proposez un test de restauration annuel, en présence d'un témoin du métier, avec procès-verbal. C'est la seule preuve qu'une sauvegarde sert à quelque chose.

★ À retenir

- **Un changement suit un circuit.** Demande, test, approbation, mise en production par un tiers, trace.
- **Rapprocher les mises en production des demandes.** Ce qui n'a pas de demande est un écart.
- **La modification directe en base** est l'écart le plus grave : elle prive les contrôles automatiques de valeur.
- **L'exploitation se prouve par ses journaux** : traitements, incidents, interfaces.
- **Une sauvegarde se prouve par une restauration**, et se mesure par la plus longue suite d'échecs.
- **Continuité et sécurité.** Plan testé ; audit de sécurité de l'ANTIC demandé, pas refait.

Exercice 10.1. Le circuit ★☆☆

Pour la modification du taux de pénalité du 9 septembre 2025, dites quelles étapes du Tableau 10.1 ont manqué et quelle preuve aurait dû exister pour chacune.

Exercice 10.2. Le journal des sauvegardes ★☆☆

Un journal de 30 jours contient la suite : 10 `OK`, 3 `ECHEC`, 5 `OK`, 4 `ECHEC`, 8 `OK`. Donnez le nombre d'échecs, la plus longue suite, et ce qu'elle signifie.

✍ Exercice 10.3. Les effets d'un changement ★★☆

Le taux de pénalité est passé de 10 % à 5 % le 9 septembre. Dites quels tests vous faites sur les recettes encaissées après cette date, et ce que vous écrivez dans l'effet du constat.

✍ Exercice 10.4. Classer ★★★

Classez les déficiences du domaine D4 d'e-RECETTES (Tableau 3.7 du Chapitre 3) et rédigez la conclusion du domaine.

● Note

Transition. Les contrôles généraux évalués, on peut enfin se fier, ou non, aux contrôles intégrés aux applications. Le Chapitre 11 les teste sur la chaîne de la dépense et de la recette.

11

CONTRÔLES D'APPLICATION DE LA DÉPENSE ET DE LA RECETTE

« L'application fait ce qu'on lui a dit ; l'auditeur vérifie ce qu'on lui a dit. »

Principe du cours

Niveau : *Intermédiaire* • Chapitres 3 et 9.

✦ Objectifs du chapitre

- ➢ Classer les contrôles d'application : saisie, traitement, interface, sortie.
- ➢ Identifier les contrôles d'application attendus sur la chaîne de la dépense et sur celle de la recette.
- ➢ Tester un contrôle automatique, en sachant à quelle condition un essai unique suffit.
- ➢ Tester un contrôle par l'analyse de toute la population quand l'essai n'est pas possible.
- ➢ Coter les contrôles d'application et en tirer une conclusion.

Pourquoi ce chapitre

Une fois les contrôles généraux évalués, l'auditeur sait s'il peut se fier aux contrôles intégrés à l'application. Ce chapitre les passe en revue sur la dépense (SIDÉPENSE) et sur la recette (e-RECETTES), et montre comment les tester sans jamais toucher à la production.

11.1 Quatre familles de contrôles d'application

© MaletYon

Famille	Objectif	Exemples
Saisie	Seules des données valides entrent	Champs obligatoires, formats, listes de valeurs, doublons, plafonds
Traitement	Les calculs et les enchaînements sont justes	Montant liquidé au plus égal à l'engagement, calcul des pénalités
Interface	Les données transmises arrivent toutes, et intactes	Totaux de contrôle entre SIDÉPENSE et le poste comptable
Sortie	Les états sont complets et ne vont qu'aux destinataires prévus	Numérotation continue des quittances, états signés

Tableau 11.1. Les quatre familles de contrôles d'application

11.2 Sur la chaîne de la dépense

Contrôle attendu	Famille	Ce qu'il empêche
Engagement au plus égal au crédit disponible	Saisie	Le dépassement de crédit
Liquidation au plus égale à l'engagement	Traitement	Le paiement d'un montant non engagé
Blocage des doublons (fournisseur, montant, facture normalisée)	Saisie	Le double paiement
Visa du contrôle financier au-delà d'un seuil	Traitement	Le paiement d'un mandat important sans visa
Imputation cohérente avec la nature de la dépense	Saisie	Les imputations de complaisance
Totaux de contrôle de la transmission au poste comptable	Interface	La perte ou l'ajout d'un mandat en cours de route

Tableau 11.2. Les contrôles d'application de la dépense

Définition

Normalisation : transformation d'une donnée avant comparaison (suppression des espaces, des tirets, des suffixes comme « bis », passage en majuscules), pour que deux

valeurs qui désignent la même chose soient reconnues comme égales. Un contrôle de doublon sans normalisation se contourne par une lettre.

11.3 Sur la chaîne de la recette

Contrôle attendu	Famille	Ce qu'il empêche
Numérotation continue et automatique des quittances	Sortie	Une recette encaissée sans quittance enregistrée
Annulation d'une quittance sur motif et validation d'un second agent	Traitement	L'annulation de complaisance
Rapprochement quotidien des encaissements et des versements	Interface	Une recette non reversée
Calcul automatique des pénalités selon le taux en vigueur	Traitement	Les remises non autorisées

Tableau 11.3. Les contrôles d'application de la recette

Scénario Opérationnel · Dossier e-RECETTES. Trous et annulations

Constatation. En 2025, les quittances vont de Q-000001 à Q-018640 ; 37 numéros n'existent pas dans la base. Sur 112 annulations, 61 ont été faites par le même agent, M. FOMEKONG, sans validation d'un second agent : e-RECETTES ne l'exige pas.

Analyse (confiance moyenne). Les 37 numéros absents peuvent correspondre à des quittances émises puis supprimées, ce que la numérotation continue devait empêcher. La concentration des annulations sur un agent n'est pas une preuve de fraude, mais un indice qui justifie l'examen pièce par pièce des 61 annulations (Chapitre 12).

11.4 Tester un contrôle automatique

11.4.1 L'essai, si les contrôles généraux tiennent

Un contrôle automatique fait la même chose à chaque opération. Si les contrôles généraux sont efficaces (le programme et le paramètre n'ont pas changé pendant la période), un essai qui doit passer et un essai qui doit être bloqué suffisent, en environnement de test, avec un paramétrage identique à la production.

11.4.2 L'analyse de la population, sinon

Si les contrôles généraux ne tiennent pas, ou s'il n'existe pas d'environnement de test, on teste le contrôle par son *résultat* : on cherche, dans toute la population, les opérations que le contrôle aurait dû bloquer. Zéro opération trouvée sur toute l'année est une preuve forte de fonctionnement ; une seule suffit à coter NON.

Outils · Tester deux contrôles de SIDÉPENSE par la population

Feuille des 9 611 mandats : D montant liquidé, E montant engagé, F montant, G visa (`OUI` ou vide).

```
Liquidation > engagement :
H2 : =SI(D2>E2;"ECART";"")
Mandats > 50 M sans visa :
I2 : =SI(ET(F2>50000000;G2<>"OUI");"SANS VISA";"")
```

Scénario Opérationnel · Dossier MINÉQUIR. Deux contrôles par leur résultat

Constatation. Aucun des 9 611 mandats n'a une liquidation supérieure à l'engagement. Sur les 212 mandats de plus de 50 000 000 FCFA, 4 n'ont pas de visa du contrôle financier.

Analyse (confiance moyenne). Le contrôle de la liquidation a fonctionné toute l'année (OUI), mais la confiance reste moyenne : les accès n'étant pas maîtrisés, un compte ADM aurait pu le désactiver puis le réactiver. Le contrôle du visa n'est pas bloquant (NON) : les 4 mandats sont à examiner un par un.

Point de contrôle · C-APP-03 · Blocage des doublons

Objectif. Une même facture n'est payée qu'une fois.
Critère. SIDÉPENSE refuse un mandat de même fournisseur, même montant et même facture normalisée qu'un mandat existant.
Test de conception. Le contrôle porte sur le numéro de facture brut, sans normalisation.
Test de fonctionnement. Analyse des 9 611 mandats : avec le numéro brut, aucune paire ; avec le numéro normalisé, une paire, celle du prologue (les deux autres paires de même fournisseur et même montant ont des factures différentes, justifiées par des livraisons distinctes).
Cote. NON.

Lecture auditologique · Contrôles d'application de SIDÉPENSE

Constatation. Sur six contrôles attendus (Tableau 11.2), trois fonctionnent : crédit, liquidation, transmission ; trois non : doublons, visa, imputation (non bloquante).

Analyse (confiance moyenne). Les contrôles qui fonctionnent restent fragiles tant que la déficience majeure des accès n'est pas corrigée.

3 oui sur 6 contrôles applicables · 0 nek

Application Vérificateur

Avant tout essai, demandez s'il existe un environnement de test dont le paramétrage est identique à la production. S'il n'en existe pas, testez par la population : c'est plus long, mais c'est sans risque pour l'entité.

Application Contrôleur financier

Si votre visa n'est pas bloquant dans l'application, chaque mandat qui passe sans lui est un mandat que vous n'avez pas contrôlé. Demandez que le seuil soit paramétré comme contrôle bloquant.

Application Juge des comptes

Une numérotation de quittances avec des trous est un indice d'exhaustivité défaillante des recettes. Demandez l'explication de chaque numéro absent.

★ À retenir

- **Quatre familles.** Saisie, traitement, interface, sortie.
- **Dépense :** crédit, liquidation, doublons, visa, imputation, transmission.
- **Recette :** numérotation continue, annulations validées, rapprochement, pénalités.
- **Normaliser avant de comparer** : un doublon se cache derrière une lettre.
- **Un essai suffit** si les contrôles généraux tiennent ; sinon, tester par la population.
- **Zéro sur toute la population** est une preuve forte ; un seul cas suffit à coter NON.

Exercice 11.1. Classer ★☆☆

Rattachez à une famille : (a) champ RIB obligatoire ; (b) total des mandats transmis égal au total reçu ; (c) calcul de la pénalité de retard ; (d) quittance imprimée avec un numéro.

✍ Exercice 11.2. Normaliser ★☆☆

Écrivez la formule de tableur qui transforme « F-2025-117 bis » et « F2025117 » en une même valeur.

✍ Exercice 11.3. Les 37 numéros ★★☆

Décrivez votre démarche pour les 37 numéros de quittance absents d'e-RECETTES : pièces demandées, personnes interrogées, et ce qui ferait passer l'indice au constat.

✍ Exercice 11.4. Essai ou population ★★★

La DAF vous propose de tester le nouveau blocage des doublons par un essai en production, « avec un mandat fictif qu'on annulera ». Dites pourquoi vous refusez, ce que vous proposez, et à quelles conditions vous concluriez OUI pour l'année 2026.

● Note

Transition. L'analyse de toute la population a montré sa puissance. Le Chapitre 12 en fait un outil à part entière, pour la paie et les marchés, et pour la détection de la fraude.

12

ANALYSE DE DONNÉES ET DÉTECTION DE LA FRAUDE

> « Les données ne mentent pas ; elles attendent qu'on leur pose la bonne question. »
>
> — Adage des auditeurs de données

Niveau : *Expert* • Chapitres 7 et 11.

✦ Objectifs du chapitre

- ➢ Expliquer le risque de fraude au sens du COSO (principe 8) et le triangle de la fraude.
- ➢ Conduire sur un fichier de paie les tests d'existence, d'unicité et de cohérence.
- ➢ Repérer le fractionnement des commandes sous un seuil.
- ➢ Appliquer la loi de Benford à une série de montants et en interpréter l'écart avec prudence.
- ➢ Passer d'un indice à un constat, sans confondre anomalie et fraude.

Pourquoi ce chapitre

Les chapitres précédents ont testé des contrôles. Celui-ci teste les *données* elles-mêmes, sur toute la population, pour y chercher ce que les contrôles auraient dû empêcher. C'est l'outil le plus puissant de l'auditeur public d'aujourd'hui : un tableur suffit, et quelques formules révèlent ce que des semaines de contrôle sur pièces ne voient pas.

12.1 Le risque de fraude

© MaletYon

Définition

Fraude : acte intentionnel destiné à obtenir un avantage indu, par la tromperie ou la dissimulation. Elle se distingue de l'erreur par l'intention, que l'auditeur ne peut pas établir seul.

Le COSO demande à l'organisation d'évaluer le risque de fraude (principe 8) [4], et le guide commun du COSO et de l'ACFE en détaille la démarche [5]. L'analyse classique de Cressey réunit trois conditions, dites **triangle de la fraude** : une *pression*, une *occasion*, une *rationalisation* [7]. L'auditeur ne peut agir que sur l'occasion : c'est exactement ce que créent les déficiences du contrôle interne.

Schéma	Occasion dans le SI, et test de données
Agent fictif	Un profil peut créer un agent et valider la paie ; tester l'existence au fichier du personnel
Double paiement	Pas de blocage des doublons ; tester fournisseur, montant, facture normalisée
Changement de bénéficiaire	RIB modifiable sans seconde validation ; tester les RIB modifiés avant un paiement
Fractionnement	Seuil de mise en concurrence ; tester les montants juste sous le seuil
Annulation de recette	Annulation sans second agent ; tester la concentration des annulations

Tableau 12.1. Schémas de fraude, occasions et tests

12.2 Analyser un fichier de paie

12.2.1 Trois questions

1. **Existence** : chaque agent payé existe-t-il au fichier du personnel, en position d'activité ?
2. **Unicité** : chaque agent n'est-il payé qu'une fois, sur un compte qui n'est qu'à lui ?
3. **Cohérence** : l'âge, le grade, l'indice et les éléments de solde sont-ils compatibles entre eux et avec les règles ?

Outils · Tests de paie dans un tableur

Feuille `PAIE` : A matricule, B nom, C date de naissance, D compte bancaire, E net. Feuille `PERSONNEL` : A matricule.

```
F2 (existence) : =SI(NB.SI(PERSONNEL!A:A;A2)=0;"ABSENT";"")
```

```
G2 (compte)     : =NB.SI(D:D;D2)
H2 (age)        : =DATEDIF(C2;DATE(2025;12;31);"y")
```

Un filtre sur `ABSENT`, sur `G > 1` et sur `H > 60` donne les trois listes à examiner.

Scénario Opérationnel · Dossier CAPNO. Les trois listes

Constatation. Sur les 4 312 agents payés en décembre 2025 : 37 ne figurent pas au fichier du personnel (net cumulé 9 842 500 FCFA par mois) ; 12 comptes bancaires sont partagés par 27 agents ; 9 agents ont plus de 60 ans et sont toujours payés.

Analyse (confiance moyenne). Les 37 absents sont des agents fictifs *probables*, pas certains : un retard de mise à jour du fichier du personnel peut en expliquer une partie. Les comptes partagés peuvent être des comptes de couples. Chaque cas est examiné avec sa pièce ; seuls les cas inexpliqués deviennent des constats.

★ Attention

Violation typique. Écrire au rapport « 37 agents fictifs » à la sortie du tableur.

Règle : l'analyse de données produit des *indices*. Le constat vient après l'examen de chaque cas : dossier individuel, présence physique, acte de recrutement.

12.3 Le fractionnement des commandes

Quand un seuil déclenche une procédure plus lourde (mise en concurrence, visa), la tentation est de découper une commande en plusieurs commandes sous le seuil. Le test est simple : compter les montants dans une bande juste sous le seuil, par fournisseur et par période.

Scénario Opérationnel · Dossier MINÉQUIR. Juste sous le seuil

Constatation. La DAF fixe à 5 000 000 FCFA le seuil de mise en concurrence de ses bons de commande[a]. En 2025, 23 bons de commande sont compris entre 4 800 000 et 4 999 999 FCFA ; ils sont adressés à trois fournisseurs seulement.

Analyse (confiance moyenne). La concentration dans une bande étroite sous le seuil, sur peu de fournisseurs, est un indice classique de fractionnement. Il faut examiner, pour chaque fournisseur, l'objet et la date des bons : des commandes de même objet à quelques jours d'intervalle confirmeraient l'indice.

[a] Seuil interne fictif, propre au cas ; il ne reproduit pas les seuils de la réglementation des marchés publics.

12.4 La loi de Benford

Dans de nombreuses séries de montants naturels, le premier chiffre n'est pas uniformément réparti : le 1 apparaît environ trois fois sur dix, le 9 moins d'une fois sur vingt [1], [28]. La proportion attendue du premier chiffre d est $\log_{10}(1 + 1/d)$.

Premier chiffre	1	2	3	4	5	6	7	8	9
Attendu (%)	30,1	17,6	12,5	9,7	7,9	6,7	5,8	5,1	4,6

Tableau 12.2. Distribution de Benford du premier chiffre

Outils · Premier chiffre et proportion attendue

```
B2 (premier chiffre) : =GAUCHE(TEXTE(A2;"0");1)*1
Attendu pour d       : =LOG10(1+1/d)
Observe pour d       : =NB.SI(B:B;d)/NB(B:B)
```

Note

Prudence. La loi de Benford vaut pour des séries nombreuses, étalées sur plusieurs ordres de grandeur, et non bornées par des seuils ou des barèmes. Une paie (barème) ou des montants plafonnés ne la suivent pas, sans aucune fraude. L'écart désigne où regarder ; il ne prouve rien.

Scénario Opérationnel · Dossier MINÉQUIR. Le chiffre 4

Constatation. Parmi les montants des bons de commande de 2025, le premier chiffre 4 apparaît dans 15,8 % des cas, contre 9,7 % attendus.

Analyse (confiance faible à moyenne). L'excès de 4 est cohérent avec les 23 bons compris entre 4,8 et 5 millions. Benford ne dit rien de plus que le test de bande ; il le confirme par une autre voie.

12.5 De l'indice au constat

Papier de travail

Feuille d'analyse de données :

1. fichier analysé (source, date, empreinte, totaux rapprochés) ;
2. question posée et formule ou requête utilisée, recopiée intégralement ;
3. résultat brut (nombre de cas, liste en annexe) ;

4. examen de chaque cas, avec la pièce : expliqué, inexpliqué, en attente ;
5. constat sur les seuls cas inexpliqués ; NEK sur les cas en attente.

Application Vérificateur

Gardez la formule exacte de chaque test dans le dossier. Lors du contradictoire, l'entité refera votre calcul ; elle doit trouver le même résultat.

Application Juge des comptes

Un paiement à un agent absent du fichier du personnel engage la responsabilité de celui qui a payé sans vérifier l'existence du créancier. Demandez quel contrôle d'application devait l'en empêcher.

Application Auditeur interne

Faites tourner chaque mois les trois tests de paie et le test de fractionnement : c'est un contrôle continu peu coûteux, qui relève du pilotage (principe 16 du COSO).

★ À retenir

- **La fraude suppose une intention**, que l'auditeur ne peut établir seul ; il agit sur l'occasion.
- **Chaque déficience ouvre un schéma**, et chaque schéma appelle un test de données.
- **Paie :** existence, unicité, cohérence.
- **Fractionnement :** une bande étroite sous le seuil, peu de fournisseurs.
- **Benford désigne, ne prouve pas** ; il ne s'applique pas à des séries bornées.
- **Un indice n'est pas un constat.** Chaque cas est examiné avec sa pièce.

Exercice 12.1. Le triangle ★☆☆

Pour le double paiement du MINÉQUIR, dites ce que l'auditeur peut établir de chaque côté du triangle de la fraude, et ce qui ne relève pas de lui.

Exercice 12.2. Benford ★☆☆

Calculez la proportion attendue du premier chiffre 1 et du premier chiffre 9. Dites pourquoi on n'applique pas le test aux indemnités de logement de la CAPNO, qui suivent un barème.

✍ Exercice 12.3. Les comptes partagés ★★☆

Proposez la démarche d'examen des 12 comptes partagés par 27 agents de la CAPNO : pièces, ordre d'examen, critères pour classer un cas comme expliqué.

✍ Exercice 12.4. Du tableur au rapport ★★★

Après examen, 31 des 37 agents absents restent inexpliqués. Rédigez le constat en cinq éléments, avec l'effet chiffré sur l'exercice 2025, et dites ce que vous écrivez sur les 6 autres.

● Note

Transition. Il reste à regarder le système d'information de plus haut : qui le pilote, comment il est acheté, et à qui il est confié. C'est l'objet du Chapitre 13.

13

GOUVERNANCE, PROJETS NUMÉRIQUES ET PRESTATAIRES

« On peut confier un service ; on ne confie pas sa responsabilité. »

Principe du cours

Niveau : *Intermédiaire* • Chapitre 2.

✦ Objectifs du chapitre

- Évaluer la gouvernance de la fonction informatique d'une administration : schéma directeur, organisation, pilotage.
- Auditer un projet numérique et le marché qui le porte, de l'expression du besoin à la réception.
- Évaluer les contrats avec les prestataires : propriété des données, réversibilité, accès, niveaux de service.
- Repérer les risques de l'hébergement externe.
- Situer les obligations de protection des données personnelles.

Pourquoi ce chapitre

Les déficiences des chapitres précédents ont souvent une cause commune, plus haut : un système acheté sans besoin écrit, reçu sans tests, confié à un prestataire sans contrat solide, piloté par personne. Ce chapitre remonte à cette cause, sur le dossier e-RECETTES.

13.1 La gouvernance de la fonction informatique

© MaletYon

Élément	Question	Pièce
Schéma directeur	Les projets répondent-ils à des objectifs écrits ?	Schéma directeur adopté, suivi annuel
Organisation	Qui décide, qui exécute, qui contrôle ?	Organigramme, décisions, propriétaires d'application
Pilotage	Un comité suit-il les projets et les risques ?	Comptes rendus
Budget	Le coût complet du SI est-il connu ?	Budget informatique, contrats
Compétences	L'entité peut-elle contrôler ses prestataires ?	Effectifs, formations

Tableau 13.1. Les éléments de la gouvernance de la fonction informatique

COBIT 2019 sépare la *gouvernance* (évaluer, diriger, surveiller), qui relève de la direction, de la *gestion*, qui relève des services [13]. Dans une administration, la gouvernance revient à l'ordonnateur et à la direction ; elle ne peut pas être laissée au prestataire.

13.2 Auditer un projet numérique

13.2.1 Le cycle du projet et ses contrôles

Phase	Contrôle attendu	Pièce
Besoin	Besoin écrit par le métier, rattaché au schéma directeur	Note de besoin, étude d'opportunité
Marché	Cahier des charges qui inclut les contrôles internes attendus, la sécurité, la réversibilité	Dossier d'appel d'offres, contrat
Réalisation	Suivi par un comité, avec les risques	Comptes rendus
Recette	Tests par le métier, anomalies bloquantes levées avant réception	Cahier de recette, PV de réception
Mise en service	Reprise des données contrôlée, formation	PV de reprise, totaux de contrôle

Tableau 13.2. Les contrôles du cycle d'un projet

Scénario Opérationnel · Dossier e-RECETTES. Une réception trop tôt

Constatation. Le marché de 640 000 000 FCFA a été attribué à NUMÉRIKA SARL en mars 2024. e-RECETTES est en service depuis le 2 janvier 2025. Le procès-verbal de réception, signé le 15 janvier 2025, mentionne 47 anomalies ouvertes, dont 9 bloquantes. Le cahier des charges ne prévoit ni contrôle des annulations, ni numérotation continue des quittances. Il n'existe pas de schéma directeur.

Analyse (confiance élevée). Les déficiences constatées aux Chapitres 10 et 11 étaient inscrites dans le projet : ce qui n'est pas demandé au cahier des charges n'est pas livré, et ce qui est reçu avec des anomalies bloquantes est payé sans être conforme.

★ Attention

Violation typique. Prononcer la réception d'un système pour respecter le calendrier budgétaire, avec des anomalies bloquantes ouvertes.

Règle : une réception avec réserves exige un plan de levée daté et une retenue sur paiement ; une réception sans réserve d'un système défaillant engage la responsabilité de celui qui la signe.

13.3 Les prestataires et l'hébergement externe

Clause	Ce que l'auditeur vérifie
Propriété des données	Les données appartiennent à l'administration, qui peut les obtenir à tout moment dans un format exploitable
Réversibilité	Les conditions de reprise du service par l'administration ou un autre prestataire sont écrites
Accès du prestataire	Ses accès en production sont nominatifs, limités, journalisés, et ouverts sur demande
Niveaux de service	Disponibilité, délais de correction, pénalités
Localisation	Lieu d'hébergement connu et compatible avec les obligations légales
Droit d'audit	L'administration et ses contrôleurs peuvent auditer le prestataire

Tableau 13.3. Les clauses à vérifier dans un contrat de prestation informatique

Scénario Opérationnel · Dossier e-RECETTES. Le contrat de NUMÉRIKA

Constatation. Le contrat ne contient ni clause de propriété des données, ni clause de réversibilité, ni droit d'audit. Les données sont hébergées hors du pays. Le prestataire dispose d'un compte d'administration permanent en production (Chapitre 10).

Analyse (confiance élevée). La recette des finances dépend entièrement de NUMÉRIKA pour accéder à ses propres données. Le décret n° 2013/287 oblige les responsables de l'entité auditée à présenter les pièces ; s'ils ne peuvent pas les obtenir de leur prestataire, c'est l'entité qui est en défaut.

13.4 Les données personnelles

Les systèmes financiers publics traitent des données personnelles : agents (paie), contribuables, usagers, fournisseurs personnes physiques. La loi n° 2024/017 du 23 décembre 2024 encadre ces traitements au Cameroun. Le cours n'en cite pas les articles ; l'auditeur les lit avant de s'y référer. Il vérifie au moins que les traitements sont recensés, que l'accès aux données est limité aux personnes qui en ont besoin, et que les transferts vers un hébergeur, en particulier hors du pays, sont encadrés.

Note

Les extractions de l'auditeur sont aussi des données personnelles. Le fichier de paie de la CAPNO, avec ses 4 312 noms et comptes bancaires, doit être protégé par le vérificateur avec le même soin qu'il l'exige de l'entité (Chapitre 5).

Lecture auditologique · Gouvernance et projet e-RECETTES

Constatation. Sur huit contrôles attendus (schéma directeur, cahier des charges complet, comité de suivi, réception sans anomalie bloquante, propriété des données, réversibilité, accès du prestataire encadré, droit d'audit), un seul fonctionne : un comité de suivi s'est réuni trois fois pendant le projet.

Analyse (confiance élevée). La cause première des déficiences d'e-RECETTES est dans la gouvernance du projet.

1 oui sur 8 contrôles applicables · 0 nek

Application Vérificateur

Pour tout système acquis par marché, demandez le cahier des charges et le procès-verbal de réception. Comparez les contrôles demandés aux contrôles livrés : l'écart explique souvent les déficiences.

Application Inspecteur

Une réception signée avec des anomalies bloquantes ouvertes est un fait précis, daté et signé. Elle mérite une question écrite à son signataire.

Application Contrôleur financier

Avant de viser le paiement d'un solde de marché informatique, demandez le procès-verbal de réception et la liste des réserves levées.

★ À retenir

- **La gouvernance reste à l'administration** : schéma directeur, propriétaires, comité, budget, compétences.
- **Le projet porte les contrôles** : ce qui n'est pas au cahier des charges n'est pas livré.
- **La réception engage** ; des anomalies bloquantes ouvertes imposent réserves, plan et retenue.
- **Six clauses de contrat** : données, réversibilité, accès, niveaux de service, localisation, droit d'audit.
- **Les données personnelles** des systèmes financiers sont encadrées par la loi n° 2024/017, y compris chez l'auditeur.

Exercice 13.1. Gouvernance ou gestion ? ★☆☆

Classez : (a) adopter un schéma directeur ; (b) faire les sauvegardes ; (c) décider d'externaliser l'hébergement ; (d) attribuer un profil.

Exercice 13.2. Un cahier des charges ★★☆

Rédigez les six exigences de contrôle interne que le cahier des charges d'e-RECETTES aurait dû contenir, à partir des Chapitres 9 à 11.

Exercice 13.3. Le contrat ★★☆

Rédigez la recommandation sur le contrat de NUMÉRIKA, avec les clauses à ajouter par avenant et l'ordre de priorité.

Exercice 13.4. Les causes ★★★

Reliez chaque déficience d'e-RECETTES relevée aux Chapitres 10 et 11 à une défaillance du projet ou du contrat, et dites quelle recommandation de gouvernance les traiterait toutes.

Note

Transition. Toutes les pièces sont en place. Le Chapitre 14 les réunit dans une mission complète, conduite en équipe en deux heures.

partie V

Synthèse

© *MaletYon*

14

CAS INTÉGRATEUR : LA MISSION E-RECETTES

« Une mission se juge à sa conclusion. »

Règle du cours

Niveau : *Expert* • L'ensemble du cours.

✦ Objectifs du chapitre

- ➢ Conduire, en équipe et en temps limité, une mission complète d'évaluation du contrôle interne d'un système d'information public.
- ➢ Mobiliser le mandat, la matrice des risques et des contrôles, le questionnaire, les tests et le classement des déficiences.
- ➢ Rédiger au moins deux constats en cinq éléments.
- ➢ Formuler et défendre oralement une conclusion sur l'efficacité du contrôle interne.

Mode d'emploi

Le cas se traite en salle, le dernier jour, en deux heures, par équipes de quatre ou cinq. Chaque équipe est une équipe de vérification du Contrôle Supérieur de l'État. Elle reçoit le dossier de la section 14.2, suit le déroulé de la section 14.3, et restitue ses résultats oralement en dix minutes. Le formateur dispose du corrigé dans le livret de correction.

14.1 Le mandat

© MaletYon

Rubrique	Ordre de mission
Fondement	Décret n° 2013/287, art. 2, al. 3 et 4
Objectif	Le contrôle interne d'e-RECETTES garantit-il l'exhaustivité et la régularité des recettes de la recette des finances de Bafoussam ?
Périmètre	e-RECETTES ; le contrat avec NUMÉRIKA SARL ; les versements au Trésor
Période	Exercice 2025
Livrables	Matrice des risques et des contrôles, cotations, tableau des déficiences, deux constats, conclusion

Tableau 14.1. Ordre de mission du cas intégrateur

14.2 Le dossier

Pièce 1. Fiche de l'entité

La recette des finances de Bafoussam encaisse les recettes de l'État de son ressort. Depuis le 2 janvier 2025, les encaissements passent par e-RECETTES, livré par NUMÉRIKA SARL au titre d'un marché de 640 000 000 FCFA. 12 400 contribuables y sont enregistrés. Trois agents utilisent l'application.

Pièce 2. Profils d'e-RECETTES

Compte	Fonction	Profils
`fomekong.a`	Caissier	ENC (encaisser), ANN (annuler)
`tagne.m`	Chef de la recette	ENC, ANN, VAL (valider la journée)
`mbida.s`	Comptable	VER (verser au Trésor)
`numerika_adm`	Prestataire	ADM (administration)

Pièce 3. Réponses au questionnaire de contrôle interne

Question	Réponse déclarée
Les quittances sont-elles numérotées automatiquement et sans trou ?	« Oui, l'application numérote. »
Une annulation exige-t-elle une validation ?	« Le chef valide la journée. »
Les encaissements sont-ils rapprochés des versements ?	« Chaque fin de mois. »
Les changements de l'application sont-ils approuvés ?	« NUMÉRIKA nous prévient. »
Les sauvegardes sont-elles testées ?	« NUMÉRIKA s'en occupe. »

Pièce 4. Résultats d'extractions (faites devant l'équipe)

- Quittances 2025 : Q-000001 à Q-018640 ; 37 numéros absents.
- Annulations : 112, dont 61 par `fomekong.a` ; aucune validation d'un second agent n'est enregistrée.
- Recettes encaissées en 2025 : 2 184 600 000 FCFA ; versements au Trésor : 2 171 950 000 FCFA.
- Aucune trace d'un rapprochement mensuel.

Pièce 5. Journaux techniques

- 14 mises en production en 2025, dont 11 sans demande écrite.
- 9 septembre 2025 : modification directe du taux de pénalité par `numerika_adm`.
- Sauvegardes : 23 échecs, dont 6 consécutifs ; aucune restauration testée.

Pièce 6. Contrat et réception

- Ni propriété des données, ni réversibilité, ni droit d'audit ; hébergement hors du pays.
- Procès-verbal de réception du 15 janvier 2025 : 47 anomalies ouvertes, dont 9 bloquantes.
- Aucun audit de sécurité de l'ANTIC.

Pièce 7. Réponses des répondants (instrument OUI / NON / NEK)

Cinq questions par domaine, posées à quatre fonctions (chef de la recette, caissier, comptable, correspondant de NUMÉRIKA), soit vingt réponses par domaine.

Domaine	oui	non	nek
R1 Encaissement, quittances, annulations	9	4	7
R2 Accès et changements	6	7	7
R3 Sauvegardes et continuité	3	9	8

14.3 Le déroulé

Temps	Travail de l'équipe	Chapitres mobilisés
0 – 10 min	Lire le mandat ; répartir les rôles (chef de mission, rédacteur, deux testeurs)	4, 6
10 – 30 min	Construire la matrice des risques et des contrôles (au moins 10 lignes)	3, 11
30 – 50 min	Confronter le QCI aux pièces ; coter chaque contrôle ; calculer μ, U, H (pièce 7) et situer les domaines dans le quadrant	7, 8
50 – 65 min	Regrouper et classer les déficiences	3
65 – 85 min	Rédiger deux observations et la conclusion	8
85 – 105 min	Restitution : 5 à 7 minutes par équipe, questions du jury	tout le cours
105 – 120 min	Ouverture sur la recherche : quel sujet de mémoire ce cas suggère-t-il ?	15

Tableau 14.2. Déroulé du cas en deux heures

14.4 La grille de restitution

Critère	Points
Le mandat est cité et l'objectif reformulé correctement	2
La matrice part des risques et couvre accès, changements, exploitation, application, versements, prestataire	4
Les cotes distinguent les déclarations (QCI) des preuves ; les trois domaines sont situés dans le quadrant	3
Le classement identifie au moins une déficience majeure, et la justifie	4
Les deux observations ont leurs sept éléments et parlent de comptes, pas de personnes	4
La conclusion porte sur un objectif, une période et un périmètre	3
Total	**20**

Tableau 14.3. Grille d'évaluation de la restitution

14.5 Les erreurs fréquentes

Erreur	Ce qu'il fallait faire
Conclure « conforme à 45 % » sur R1	$U = 0{,}35 \geq 0{,}20$: le domaine est opaque ; aucune conclusion de conformité (règle 1)
Coter OUI la numérotation parce que l'application « numérote »	Partir des 37 numéros absents : NON
Coter NEK le rapprochement mensuel	Aucune trace : l'absence d'une trace exigée est un NON
Écrire « M. FOMEKONG détourne des recettes »	Constater la concentration des annulations sur un compte, sans validation
Conclure sur la sécurité d'ensemble	Rester dans l'objectif ; signaler l'absence d'audit de l'ANTIC
Additionner les NON comme autant de déficiences	Regrouper par cause (accès, changements, projet)
Oublier l'écart de 12 650 000 FCFA	C'est l'effet chiffré le plus direct sur l'objectif d'exhaustivité

Tableau 14.4. Grille des erreurs fréquentes

Application Vérificateur

Dans un vrai dossier, l'écart entre recettes encaissées et versements appellerait une note de faits distincte du rapport (Chapitre 8) : c'est une suite possible devant le CDBF.

Application Juge des comptes

L'écart entre encaissements et versements concerne directement le compte du comptable : il sera examiné, par extension, à travers les comptes produits par e-RECETTES.

○

★ À retenir

- **Une mission complète** tient en six gestes : mandat, matrice, cotation, classement, constats, conclusion.
- **Le QCI se confronte aux pièces** ; une déclaration ne vaut pas preuve.
- **Les déficiences se regroupent par cause.**
- **La conclusion se défend** : objectif, période, périmètre, travaux.

✍ Exercice 14.1. La matrice ★★☆

Construisez la matrice des risques et des contrôles d'e-RECETTES (au moins dix lignes), à partir des pièces du dossier.

✍ Exercice 14.2. Les déficiences ★★★

Regroupez les contrôles cotés NON en déficiences, classez-les avec la grille du Chapitre 3, et justifiez chaque déficience majeure.

✍ Exercice 14.3. La conclusion ★★★

Rédigez la conclusion de la mission et le premier paragraphe de la synthèse du rapport.

● Note

Transition. La mission est complète. Le Chapitre 15 remonte aux fondements de la méthode, le programme de recherche de l'auditologie, et ouvre des pistes de mémoire pour les auditeurs qui voudront contribuer à le tester.

partie VI

Ouverture sur la Recherche

© *MaletYon*

15

OUVRIR SUR LA RECHERCHE : L'AUDITOLOGIE

> « Ce que l'organisation ignore de ses propres systèmes conditionne la qualité des décisions qu'elle peut prendre à leur sujet. »
>
> *Vers l'auditologie* [25]

Niveau : *Recherche* • L'ensemble du cours, en particulier les Chapitres 6 à 8.

✦ Objectifs du chapitre

- ➢ Définir l'auditologie et la mission auditologique.
- ➢ Énoncer les six axiomes de l'article A0 et relier chacun à une pratique du cours.
- ➢ Présenter les cinq piliers théoriques et les prédictions falsifiables qu'ils engendrent.
- ➢ Distinguer ce qui est établi par des travaux publiés, ce qui est déposé en prépublication, et ce qui reste à valider.
- ➢ Identifier des axes de recherche à partir de la pratique de l'audit public, et formuler un sujet de mémoire falsifiable.

Pourquoi ce chapitre

Tout au long du cours, des choix de méthode ont été justifiés par une recherche : la réponse NEK, la décomposition en huit niveaux, les mesures μ, U et H, le quadrant, la comparaison des cycles. Ces outils viennent d'un programme de recherche que l'auteur a nommé *auditologie* [25], et dont l'instrument de réponse est étudié dans un second article [24]. Ce chapitre le présente pour lui-même, puis montre comment un auditeur des finances publiques peut y contribuer, par un mémoire ou par sa pratique.

© MaletYon

Ce que ce chapitre est, et n'est pas

Il expose un programme de recherche déposé en prépublication, non un savoir établi. Les axiomes et les piliers forment un cadre ; les prédictions qui en découlent restent à tester. C'est précisément là que les auditeurs publics, qui disposent de missions réelles et répétées, peuvent apporter ce qui manque : des données longitudinales.

15.1 L'objet : la mission auditologique

L'article A0 part d'un constat : l'audit des systèmes d'information dispose de méthodes, de référentiels et d'une abondante littérature instrumentale, mais d'aucun socle axiomatique ni d'aucun espace de mesure unifié pour son objet central, la réduction de l'incertitude. Il propose de le constituer en une science appliquée.

Définition

Mission auditologique (A0) : quintuplet $\mathcal{M} = \langle \mathcal{S}, \mathcal{A}, \mathcal{I}, \mathcal{G}, \mathcal{T} \rangle$, où $\mathcal{S}$ est le système audité (ensemble sociotechnique d'agents, d'artefacts, de flux et de dispositifs), $\mathcal{A}$ l'architecture cognitive de l'auditeur ou de l'équipe, $\mathcal{I}$ le canal d'information par lequel les preuves parviennent à $\mathcal{A}$, $\mathcal{G}$ la structure stratégique de l'interaction entre l'auditeur, l'audité et les tiers, et $\mathcal{T}$ la trajectoire temporelle du système au fil des missions.

Auditologie : science appliquée de la réduction de l'incertitude sur les missions auditologiques.

	Composante	Dans la mission MINÉQUIR
$\mathcal{S}$	Système audité	La DAF, SIDÉPENSE, ses 47 comptes, ses procédures, le poste comptable
$\mathcal{A}$	Architecture cognitive	L'équipe du CONSUPE, sa méthode, ses papiers de travail
$\mathcal{I}$	Canal d'information	Entretiens, pièces des trois strates, extractions faites devant la vérificatrice
$\mathcal{G}$	Structure stratégique	DAF, cellule informatique, DRH, contrôle financier, vérificateurs, CDBF
$\mathcal{T}$	Trajectoire	Mars 2026, novembre 2026, et les cycles suivants

Tableau 15.1. La mission MINÉQUIR comme mission auditologique

15.2 Six axiomes

L'article A0 pose six axiomes, qui contraignent toute mission auditologique [25]. Le cours les a rencontrés chapitre après chapitre ; leur numérotation est celle de l'article.

N°	Axiome	Énoncé résumé	Dans le cours
1	Observabilité partielle	L'auditeur n'accède qu'à une partie des états du système, elle-même partiellement opaque	Partir du système ; la réponse NEK (Ch. 7)
2	Cognition limitée	L'auditeur et l'audité sont des agents cognitivement limités	Décomposition bornée à sept éléments (Ch. 6)
3	Mesurabilité	L'incertitude épistémique se mesure par l'entropie et ses généralisations	μ, U, H (Ch. 8)
4	Interaction stratégique	Auditeur et audité ont des intérêts distincts, dans un jeu à information imparfaite	Biais du choix forcé, indice ρ ; indépendance
5	Individuation temporelle	Le système évolue, et son état dépend des missions antérieures	Suivi, divergence entre cycles
6	Opposabilité	Toute conclusion doit pouvoir être défendue devant un tiers légitime	Papiers de travail, contradictoire, observation en sept éléments

Tableau 15.2. Les six axiomes de l'auditologie (d'après A0)

A0 écarte explicitement trois candidats : l'*indépendance* n'est pas un axiome, mais une conséquence des axiomes 4 et 6 ; la *conformité à un référentiel* est un choix de fonction objectif ; la *matérialité* est un paramètre dérivé de l'opposabilité.

15.2.1 Quatre propositions

A0 en tire quatre propositions, que ce cours a mises en pratique.

1. **Modalité d'ignorance explicite** (axiomes 1 à 4) : tout instrument de réponse valide inclut NEK.
2. **Décomposition hiérarchique** (axiomes 2 et 6) : tout instrument couvrant un espace d'audit non trivial est organisé en niveaux, bornés par la mémoire de travail.
3. **Métriques longitudinales** (axiome 5) : les conclusions ne se testent que par l'observation de plusieurs cycles.
4. **Réflexivité** (axiomes 4 et 6) : l'audit fait partie de la trajectoire du système qu'il observe.

15.3 Cinq piliers

Les axiomes disent ce qu'est une mission ; les piliers apportent les théories qui permettent de la modéliser. A0 en retient cinq, chacun avec une prédiction falsifiable.

Pilier	Ancrage	Prédiction falsifiable
1. Cognition limitée	Miller, Simon, Kahneman [17], [22], [32]	Les grilles de plus de neuf dimensions simultanées produisent plus d'incohérences et d'oublis
2. Théorie de l'information	Shannon, Kullback et Leibler [18], [31]	Le diagnostic conformité et entropie prédit mieux que le seul taux de conformité
3. Théorie des jeux	von Neumann, Nash, Harsanyi [8], [26], [27]	Les instruments compatibles avec les incitations réduisent la dissimulation
4. Systèmes dynamiques	Chaînes de Markov [29]	Les prévisions par matrice de transition entre niveaux de maturité battent la persistance naïve
5. Ontologie critique-réaliste	Bhaskar, Simondon, Latour [2], [20], [34]	Les cadres qui tiennent compte des personnes, des procédures et des artefacts font mieux appliquer les recommandations

Tableau 15.3. Les cinq piliers et leurs prédictions (d'après A0)

15.4 La méthode : science du design et falsifiabilité

15.4.1 Une science du design

L'auditologie produit des artefacts : instruments, métriques, grilles, outils. A0 l'inscrit dans la recherche en science du design : on construit un artefact, on l'évalue dans son environnement, on l'appuie sur la base de connaissances, et l'on recommence [9]. Les outils de ce cours (l'instrument OUI / NON / NEK, le gabarit canonique, les labs de NDAP SUKULU) sont de tels artefacts, et chaque promotion d'auditeurs participe à leur évaluation.

15.4.2 Un noyau dur et une ceinture protectrice

A0 adopte le falsificationnisme sophistiqué de Lakatos [19]. Les axiomes et les piliers forment un *noyau dur*, qui n'est pas directement testé ; les hypothèses auxiliaires, les procédures de mesure et les prédictions forment la *ceinture protectrice*, qui l'est. La réfutation d'une prédiction n'emporte pas le programme : elle oblige à réviser la ceinture.

15.4.3 Ce que l'auditologie n'est pas

A0 précise quatre refus : l'auditologie n'est pas *normative* (elle ne prescrit pas le bon audit), ni *critique* (elle n'invalide pas les cadres existants), ni *un référentiel de plus*, ni *une idéologie* (ses propositions sont falsifiables). C'est pourquoi le cours a enseigné ensemble les normes du métier (Partie II) et leur lecture auditologique (Partie III).

15.5 Établi, déposé, à valider

Statut	Contenu	Références
Établi par des travaux publiés	Borne de la mémoire de travail, entropie de Shannon, divergence de Kullback-Leibler, théorie des jeux, contrôle interne	Miller, Shannon, Kullback, Nash, COSO
Déposé en prépublication	Axiomes, piliers, mission auditologique, instrument OUI / NON / NEK, mesures, quadrant	A0 et A1, sur HAL [24], [25]
À valider	Les prédictions des cinq piliers, sur des missions réelles et répétées	Les recherches à venir, dont les vôtres

Tableau 15.4. Le statut des travaux sur lesquels repose le cours

15.6 Axes de recherche pour l'auditeur public

Les auditeurs des finances publiques disposent de ce qui manque le plus à la recherche en audit : des missions réelles, sur des systèmes réels, répétées dans le temps. Huit axes s'ouvrent à partir de ce cours. Pour chacun, un exemple de sujet de mémoire est donné, avec sa question falsifiable.

Axe	Thème	Question de recherche	Pilier, axiome
1	Le biais du choix forcé	De combien les grilles binaires des inspections surestiment-elles la conformité ?	Pilier 3 ; axiome 4
2	L'incertitude dans les rapports publics	Quelle part des conclusions des rapports de contrôle repose sur des déclarations sans preuve ?	Pilier 2 ; axiome 1
3	La valeur prédictive du quadrant	Les domaines en conformité opaque révèlent-ils plus d'irrégularités aux missions suivantes ?	Pilier 2 ; axiome 3
4	Trajectoires des recommandations	Le suivi des recommandations suit-il une chaîne de Markov prévisible ?	Pilier 4 ; axiome 5
5	L'usage stratégique de NEK	Les audités répondent-ils davantage NEK en entretien formel qu'en auto-évaluation ?	Pilier 3 ; axiome 4
6	La décomposition et l'erreur	Les grilles qui dépassent la borne de sept produisent-elles plus d'oublis ?	Pilier 1 ; axiome 2
7	Contrôle interne des applications de l'État	Quelles déficiences reviennent dans les applications financières publiques, et pourquoi ?	Pilier 5 ; axiome 1
8	L'opposabilité de la preuve électronique	Quelles conditions rendent une extraction recevable devant le CDBF et la Chambre des Comptes ?	Axiome 6

Tableau 15.5. Huit axes de recherche ouverts par le cours

15.6.1 Exemples de sujets

Scénario Opérationnel · Axe 1. Mesurer le biais des grilles binaires

Sujet. *Le biais du choix forcé dans les questionnaires de contrôle interne des administrations financières camerounaises : mesure par l'indice ρ.*

Hypothèse falsifiable. Sur les mêmes questions et les mêmes répondants, la part de OUI d'une grille binaire dépasse d'au moins dix points celle de l'instrument trichotomique.

Données. Deux passages d'un même questionnaire (binaire puis trichotomique) dans trois à cinq services, avec l'accord de la hiérarchie.

Méthode. Calcul de ρ par question et par domaine ; test statistique de l'écart ; analyse des questions où le biais est le plus fort.

Réfutation. Un ρ proche de zéro sur l'ensemble des services.

Scénario Opérationnel · Axe 3. La valeur prédictive du quadrant

Sujet. *Conformité opaque et irrégularités ultérieures : étude longitudinale de missions de vérification.*
Hypothèse falsifiable. Les domaines classés en conformité opaque à une mission présentent, à la mission suivante, plus d'irrégularités établies que les domaines en conformité claire.
Données. Les mesures μ, U, H de domaines audités sur deux cycles au moins, et les constats de la mission suivante.
Méthode. Comparaison des taux d'irrégularités par région ; contrôle de la taille des domaines.
Réfutation. Aucune différence entre régions, ou une différence inverse.

Scénario Opérationnel · Axe 4. Trajectoires des recommandations

Sujet. *Le suivi des recommandations de contrôle comme processus de Markov : estimation d'une matrice de transition des niveaux de maturité.*
Hypothèse falsifiable. Une matrice de transition estimée sur trois cycles prévoit le niveau de maturité au cycle suivant mieux que la simple reconduction du niveau actuel.
Données. Les niveaux de maturité (échelle du Chapitre 3) de plusieurs domaines, sur au moins quatre cycles.
Méthode. Estimation de la matrice, prévision, comparaison à la persistance naïve.
Réfutation. Aucun avantage prédictif de la matrice.

Scénario Opérationnel · Axe 8. L'opposabilité de la preuve électronique

Sujet. *Les conditions de recevabilité des extractions informatiques dans les procédures du CDBF et de la Chambre des Comptes.*
Question. Quelles garanties (origine, exhaustivité, exactitude, intégrité) sont effectivement exigées, et lesquelles manquent le plus souvent ?
Données. Un échantillon de dossiers, anonymisés, avec l'autorisation des institutions ; entretiens avec des rapporteurs.
Méthode. Grille d'analyse fondée sur les quatre garanties du Chapitre 7 ; étude des cas où une pièce a été écartée.

15.7 Conduire un mémoire de recherche appliquée

Papier de travail

Les étapes d'un mémoire en auditologie appliquée :

1. partir d'une difficulté réelle de mission, et la rattacher à un axiome ou à un pilier ;
2. formuler une hypothèse *falsifiable* : dire à l'avance quel résultat la réfuterait ;
3. obtenir l'autorisation écrite de la hiérarchie et des entités concernées ;
4. construire le protocole : instrument, échantillon, mesures (μ, U, H, ρ, D_{KL}), seuils déclarés ;
5. anonymiser les données personnelles et protéger les extractions ;
6. analyser, puis séparer ce qui est établi, ce qui est probable et ce qui reste inconnu ;
7. discuter les limites, et proposer la révision de la ceinture protectrice si la prédiction est réfutée.

★ **Attention**

Violation typique. Formuler un sujet du type « l'importance de l'audit des SI dans l'administration camerounaise ».

Règle : un sujet de recherche pose une question à laquelle des données peuvent répondre non. « Importance » ne se réfute pas ; « les domaines en conformité opaque révèlent plus d'irrégularités au cycle suivant » se réfute.

Application Vérificateur

Vos missions répétées sur les mêmes entités sont des données longitudinales rares. Conservez, d'un cycle à l'autre, les mêmes questions et les mêmes fonctions répondantes : vous rendez possibles les axes 3 et 4.

Application Auditeur interne

Mesurer ρ sur vos propres questionnaires est un premier travail de recherche, utile dès la première année.

★ **À retenir**

- **L'auditologie** est la science appliquée de la réduction de l'incertitude ; son objet est la mission $\langle \mathcal{S}, \mathcal{A}, \mathcal{I}, \mathcal{G}, \mathcal{T} \rangle$.
- **Six axiomes** : observabilité partielle, cognition limitée, mesurabilité, interaction

stratégique, individuation temporelle, opposabilité.

- **Quatre propositions** fondent les pratiques du cours : NEK, décomposition, mesures longitudinales, réflexivité.
- **Cinq piliers**, chacun avec une prédiction falsifiable.
- **Une science du design, à la Lakatos** : un noyau dur, une ceinture protectrice qui se teste.
- **Un statut clair** : A0 et A1 sont des prépublications ; les prédictions restent à valider.
- **Huit axes** s'ouvrent aux auditeurs publics ; un bon sujet dit à l'avance ce qui le réfuterait.

✍ Exercice 15.1. Axiomes et pratiques ★☆☆

Pour chacune des pratiques suivantes, citez l'axiome d'A0 qui la fonde : (a) coter NEK une pièce non encore remise ; (b) borner chaque niveau de la décomposition à sept éléments ; (c) comparer deux cycles par la divergence ; (d) soumettre le rapport provisoire à l'entité.

✍ Exercice 15.2. Rendre un sujet falsifiable ★★☆

Réécrivez les sujets suivants pour qu'ils deviennent falsifiables, en précisant l'hypothèse, les données et la condition de réfutation : (a) « Le rôle du CONSUPE dans la bonne gouvernance numérique » ; (b) « Les enjeux de la dématérialisation des recettes ».

✍ Exercice 15.3. Un protocole ★★★

Choisissez l'un des huit axes du Tableau 15.5 et rédigez le protocole complet d'un mémoire : question, hypothèse, données et autorisations, instrument, mesures, seuils, analyse, condition de réfutation, risques éthiques et parade.

● Note

Pour finir. Le cours s'arrête ici ; le métier, et peut-être la recherche, commencent. Chaque mission refera les mêmes gestes : partir du système, écrire ses critères avant de tester, coter honnêtement, y compris NEK, conclure sur ce que l'on a prouvé, et mesurer, d'un cycle à l'autre, ce que l'on a appris.

A

GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les définitions données dans les chapitres. Le renvoi indique le chapitre où le terme est défini.

nek (*Not Enough Knowledge*) Cote réservée au contrôle dont l'auditeur ne peut pas établir l'état malgré des diligences normales (Ch. 0, 3).

Analyse Interprétation tirée de constatations au regard d'un critère, avec un niveau de confiance déclaré (Ch. 0).

Assurance limitée Confiance plus faible, exprimée sous forme négative, après des travaux réduits (Ch. 1).

Assurance raisonnable Confiance élevée mais non absolue, exprimée sous forme positive (Ch. 1).

Audit Examen méthodique, indépendant et documenté, qui compare une situation à des critères et conduit à une opinion motivée (Ch. 1).

Changement Toute modification d'un programme, d'un paramètre ou d'une base en production (Ch. 10).

Constatation Fait vérifiable, établi par l'auditeur et appuyé sur une preuve conservée (Ch. 0).

Contrôle Dispositif ou action de l'entité qui empêche ou détecte une anomalie (Ch. 1).

Contrôle compensatoire Revue indépendante qui couvre un cumul de profils que l'on ne peut pas éviter (Ch. 2).

Contrôle correctif, détectif, préventif Contrôle qui corrige, repère après coup, ou empêche une anomalie (Ch. 2).

Contrôle interne Processus qui fournit une assurance raisonnable sur les opérations, l'information et la conformité, selon le COSO 2013 (Ch. 2).

Contrôles d'application Contrôles intégrés à une application : saisie, traitement, interface, sortie (Ch. 2, 11).

Contrôles généraux informatiques Contrôles de l'environnement des applications : accès, changements, exploitation, acquisition (Ch. 2).

© *MaletYon*

Critère d'audit Exigence de référence, choisie avant le test (Ch. 1, 5).

Déficience Insuffisance d'une composante ou d'un principe qui réduit la probabilité d'atteindre les objectifs (Ch. 3).

Déficience majeure Déficience, ou combinaison, qui réduit fortement cette probabilité ; elle interdit de conclure à l'efficacité (Ch. 3).

Échantillon Partie de la population examinée en détail, aléatoire ou raisonnée (Ch. 7).

Empreinte Valeur calculée par une fonction de hachage (SHA-256) qui change au moindre changement du fichier (Ch. 7).

Fraude Acte intentionnel destiné à obtenir un avantage indu (Ch. 12).

Gestion des changements Contrôles qui garantissent qu'un changement est demandé, testé, approuvé, mis en production par un tiers et tracé (Ch. 10).

Inspection Vérification ponctuelle au nom de l'autorité hiérarchique (Ch. 1).

Limitation d'étendue Partie de l'objectif que la mission n'a pas pu établir, déclarée au rapport (Ch. 8).

Matrice des risques et des contrôles Liste des risques d'un circuit et des contrôles attendus en face, établie avant les tests (Ch. 3).

Normalisation Transformation d'une donnée avant comparaison (Ch. 11).

Norme professionnelle Règle qui encadre la conduite d'une mission (Ch. 5).

Plan de continuité d'activité Document qui fixe comment l'entité poursuit ses missions pendant une interruption (Ch. 10).

Population Ensemble des opérations sur lesquelles porte la conclusion, prise dans le système (Ch. 7).

Profil Ensemble de droits attribué dans une application (Ch. 2).

Propriétaire d'application Responsable métier qui décide des droits dans une application (Ch. 9).

Questionnaire de contrôle interne Questions fermées, tirées de la matrice, qui recueillent les contrôles déclarés (Ch. 3).

Référentiel Ensemble structuré de bonnes pratiques où l'on puise des critères (Ch. 5).

Revue des habilitations Examen périodique et signé des comptes et profils par le propriétaire de l'application (Ch. 9).

Risque inhérent, risque lié au contrôle Gravité et probabilité d'une anomalie sans contrôle ; probabilité que le contrôle ne l'empêche ni ne la détecte (Ch. 6).

Séparation des tâches Répartition des étapes d'une opération entre des personnes différentes (Ch. 2).

Système de contrôle interne Ensemble organisé des dispositifs de contrôle interne d'une entité, évalué comme un tout (Ch. 2).

Test de cheminement Suivi d'une opération réelle du début à la fin du circuit (Ch. 3).

Totaux de contrôle Nombre de lignes et sommes rapprochés d'une source indépendante pour prouver l'exhaustivité (Ch. 7).

Triangle de la fraude Pression, occasion, rationalisation (Ch. 12).

Vérification Activité des vérificateurs du CONSUPE, sur pièces et sur place (Ch. 1).

Auditologie Science appliquée de la réduction de l'incertitude sur les missions d'audit, selon l'article A0 (Ch. 15).

Divergence de Kullback-Leibler Mesure, en bits, de l'écart entre les distributions de réponses de deux cycles (Ch. 8).

Entropie Dispersion des réponses OUI, NON, NEK, en bits, au plus $\log_2 3$ (Ch. 8).

Espace d'audit Ensemble des objets sur lesquels porte une mission (Ch. 6).

Fiche d'assertion Objectif, critère, question, risque et conséquence d'un contrôle (Ch. 6).

Gabarit canonique Décomposition en huit niveaux, du domaine à la trace (Ch. 6).

Mission auditologique Quintuplet $\langle \mathcal{S}, \mathcal{A}, \mathcal{I}, \mathcal{G}, \mathcal{T} \rangle$ de l'article A0 (Ch. 15).

Observation Développement du constat en sept éléments : norme, constatation, risques, contradictoire, analyse, conclusion, recommandations (Ch. 8).

Quadrant diagnostique Lecture croisée de μ et de U en quatre régions ; la conformité opaque est la plus dangereuse (Ch. 8).

Taux de conformité (μ), taux d'incertitude (U) Parts des réponses OUI et NEK (Ch. 8).

B

RÉFÉRENTIEL DES OUTILS

Le cours ne demande qu'un tableur (Excel ou LibreOffice Calc) et l'outil de calcul d'empreinte du système. Les formules sont données avec les noms français des fonctions et le point-virgule comme séparateur.

Intégrité des fichiers

Besoin	Commande
Empreinte sous Windows	`certutil -hashfile fichier.csv SHA256`
Empreinte sous Linux	`sha256sum fichier.csv`
Vérifier un manifeste	`sha256sum -c MANIFESTE_SHA256.txt`

Formules de tableur

Test	Formule	Chapitre
Doublons sur une clé	`=NB.SI($F$2:$F$9612;F2)`	0
Tirage aléatoire	`=ALEA()` puis tri, valeurs figées	7
Existence dans une autre liste	`=SIERREUR(RECHERCHEV(A2; PERSONNEL!$A:$D;4;FAUX);"ABSEN`	9
Conflit de profils	`=SI(ET(C2=1;D2=1);"CONFLIT";""`	9
Suite d'échecs	`=SI(B2="ECHEC";C1+1;0)` puis `=MAX(C:C)`	10
Seuil sans visa	`=SI(ET(F2>50000000;G2<>"OUI"); VISA";"")`	11
Âge	`=DATEDIF(C2;DATE(2025;12;31);"`	12
Premier chiffre	`=GAUCHE(TEXTE(A2;"0");1)*1`	12
Proportion de Benford	`=LOG10(1+1/d)`	12

NDAP SUKULU

Les labs se font dans le bureau d'analyse de NDAP SUKULU, ouvert dans le navigateur. Il contient un tableur, un éditeur de texte et un terminal. Les pièces sont en lecture seule dans `preuves` ; on travaille sur la copie du dossier `travail`.

C

PAPIERS DE TRAVAIL TYPES

Les modèles ci-dessous reprennent les encadrés « Papier de travail » des chapitres. Ils sont à recopier dans le tableur ou le traitement de texte de l'institution.

C.1 Ordre de mission

Rubrique	À remplir
Fondement	Texte, article, alinéa
Objectif	Une question à laquelle le rapport répondra
Périmètre	Entité, applications, ce qui est exclu
Période	Exercice ou dates
Durée et équipe	Dates, noms, chef de mission
Livrables	Rapport provisoire, contradictoire, rapport définitif

C.2 Demande de pièces

N°	Pièce (extraite devant l'auditeur ?)	Destinataire	Délai	Reçue le
1				
2				

C.3 Questionnaire de contrôle interne

N°	Question (qui, quand, quelle trace ?)	Réponse déclarée	Répondant	Pièce
1				
2				

C.4 Feuille de test

© MaletYon

Rubrique	À remplir
Référence	Domaine, contrôle, ligne du programme
Critère	Énoncé, source, force
Population	Source, nombre, totaux, empreinte
Échantillon	Méthode, taille, liste
Résultats	Élément par élément, avec la pièce
Cote	OUI / NON / NEK, et constatation
Visa	Auteur, date, chef de mission

C.5 Fiche de constat

Élément	À remplir
Condition	Fait chiffré, daté, sourcé
Critère	Règle citée et sa force
Cause	Ce qui, dans le dispositif, explique l'écart
Effet	Risque réalisé ou possible, chiffré
Recommandation	Action, responsable, échéance
Classement	Déficience ou déficience majeure, et pourquoi

C.6 Grille de classement des déficiences

Déficience	Perte possible	Probabilité	Compensatic prouvée	Fraude	Classe
A					
B					

C.7 Plan d'action et suivi

N°	Recommandation	Responsable	Échéance	Statut	Preuve
R-01					
R-02					

D

TEXTES JURIDIQUES ET NORMATIFS

Les extraits ci-dessous sont recopiés de la version des textes disponible dans le dossier des normes du cours. L'auditeur les vérifie sur la version officielle avant de les citer dans un rapport.

D.1 Décret n° 2013/287 du 4 septembre 2013 portant organisation des services du Contrôle supérieur de l'État

Jurisprudence & Droit applicable

Article 1er : *« (1) Les services du Contrôle supérieur de l'Etat relèvent de l'autorité directe du Président de la République, dont ils reçoivent les instructions et à qui ils rendent compte. (2) Ils sont dirigés par un ministre délégué à la présidence de la République. »*

Article 2, alinéa 1 (début) : *« Les services du Contrôle supérieur de l'Etat constituent l'institution supérieure de contrôle des finances publiques (ISC) du Cameroun. Ils sont chargés de l'audit externe. »*

Article 2, alinéa 3 : *« Dans l'exercice de leurs attributions, les services du Contrôle supérieur de l'Etat effectuent : un contrôle de conformité et de régularité ; un contrôle financier ; un contrôle de performance ; un contrôle de l'environnement ; un contrôle des systèmes d'information. »*

Article 2, alinéa 4 : *« Les contrôles sont effectués par les vérificateurs du Contrôle supérieur de l'Etat sur pièces et sur place. A cet effet, et nonobstant les contrôles effectués par les autres organes de contrôle, les responsables des structures auditées sont tenus de présenter les pièces relatives à la période auditée. »*

Article 3, alinéa 1 : *« Les services du Contrôle supérieur de l'Etat concourent à la sanction des ordonnateurs et des gestionnaires des deniers publics, dans les conditions prévues par les lois et règlements en vigueur. A ce titre, le ministre délégué en charge du Contrôle supérieur de l'Etat préside le conseil de discipline budgétaire et financière, dont l'organisation et le fonctionnement sont fixés par un texte particulier. »*

Article 5 : *« (1) Les structures d'audit interne transmettent aux services du Contrôle supérieur de l'Etat, à la diligence des chefs de départements ministériels concernés, un exemplaire de chacun des rapports rédigés à la suite de toutes les interventions*

© MaletYon

menées au cours de l'exercice, ainsi qu'un exemplaire du rapport annuel d'activités. (2) Après examen des rapports visés à l'alinéa 1er ci-dessus, les services du Contrôle supérieur de l'Etat peuvent, le cas échéant, saisir le conseil de discipline budgétaire et financière. »

Article 27, alinéa 2 (extrait) : la Division des inspections et de contrôle des administrations publiques comprend notamment *« la section des administrations financières, économiques, sociales et des systèmes d'informations »*.

Article 28, alinéa 1 : les sections sont chargées, chacune dans son domaine de compétence, *« de la préparation et de l'exécution des opérations de vérification ; du suivi et de l'évaluation des activités des structures de contrôle interne ; de la tenue de la documentation technique et du fichier. »*

D.2 Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité

Jurisprudence & Droit applicable

Article 4, point 9 : *« Audit de sécurité : examen méthodique des composantes et des acteurs de la sécurité, de la politique, des mesures, des solutions, des procédures et des moyens mis en oeuvre par une organisation, pour sécuriser son environnement, effectuer des contrôles de conformité, des contrôles d'évaluation de l'adéquation des moyens (organisationnels, techniques, humains, financiers) investis au regard des risques encourus, d'optimisation, de rationalité et de performance. »*

Article 7, alinéa 2 (extrait) : l'Agence est notamment chargée *« de s'assurer de la régularité, de l'effectivité des audits de sécurité des systèmes d'information suivant les normes en la matière, des organismes publics et des autorités de certification »*.

Article 13, alinéa 1 : *« Sont soumis à un audit de sécurité obligatoire, les réseaux de communications électroniques et les systèmes d'information, des opérateurs, des autorités de certification et des fournisseurs de services de communications électroniques. »*

Article 32 : *« (1) Les réseaux de communications électroniques et les systèmes d'information sont soumis à un régime d'audit de sécurité obligatoire et périodique de leurs systèmes de sécurité par l'Agence. (2) L'audit de sécurité et les mesures d'impact de gravité sont effectués chaque année ou lorsque les circonstances l'exigent. (3) Les rapports d'audit sont confidentiels et adressés au Ministre chargé des Télécommunications. »*

D.3 Textes décrits sans citation

Texte	Usage dans le cours
Loi n° 2018/012 du 11 juillet 2018 portant régime financier de l'État et des autres entités publiques	Exécution de la dépense, séparation ordonnateur / comptable (Ch. 2)
Texte organisant la Chambre des Comptes de la Cour suprême	Contrôle des comptes ; les SI par extension (Ch. 4)
Loi n° 2024/017 du 23 décembre 2024 relative à la protection des données personnelles	Données des agents, contribuables, usagers (Ch. 13)

D.4 Normes

Norme	Passages utilisés
COSO 2013 (traduction IFACI)	Définition, composantes et principes, efficacité, déficiences (§§ 138 à 140)
INTOSAI GUID 5100	Audit des SI autonome ou intégré ; treize domaines
Manuel d'audit de conformité de l'IDI	Relation tripartite, critères, documentation
Normes de l'IIA (2017, 2024)	Exigences de l'audit interne
COBIT 2019, ISO/IEC 27001 et 27002	Sources de critères (résumés, aucune reproduction)

E

BIBLIOGRAPHIE COMMENTÉE

Cette annexe dit, pour chaque référence principale, ce qu'elle apporte à l'auditeur public et par où commencer. La liste complète figure dans les références bibliographiques à la fin du livre.

Pour l'évaluation du contrôle interne

- **COSO, *Référentiel intégré de contrôle interne*** (2013, traduction IFACI 2014) [4]. Le texte de base des Chapitres 2 et 3. Lire d'abord la synthèse, puis le chapitre sur l'efficacité du contrôle interne.
- **COSO et ACFE, guide de gestion du risque de fraude** (2016) [5]. La démarche du principe 8, utile pour le Chapitre 12.

Pour l'audit public

- **INTOSAI, GUID 5100** [11]. Les lignes directrices de la vérification des SI par les institutions supérieures de contrôle ; les treize domaines d'une mission.
- **IDI, manuel d'audit de conformité** [10]. Le plus pratique des textes de l'INTOSAI : critères, preuve, documentation, rapport.
- **Décret n° 2013/287** [30]. À connaître par cœur pour ses articles 2, 3, 5 et 28.

Pour l'audit interne et les référentiels

- **IIA, normes** [35], [36]. Les exigences de l'auditeur interne ; l'édition 2024 remplace celle de 2017.
- **ISACA, COBIT 2019** [12], [13]. À consulter comme catalogue de critères, objectif par objectif.
- **ISO/IEC 27001 et 27002** [15], [16]. Les mesures de sécurité, à citer quand l'entité les a adoptées.

Pour l'analyse de données

- **Nigrini, *Benford's Law*** [28]. La référence pour appliquer la loi de Benford en audit, avec ses limites.
- **Cressey** [7]. L'origine du triangle de la fraude.

© *MaletYon*

Pour aller plus loin

- **Minka, *Vers l'auditologie*** et l'article sur la réponse NEK [24], [25]. Le programme de recherche dont le cours tire la cotation OUI / NON / NEK ; prépublications sur HAL.
- **Le cours INF3226** (ENSPY), version complète de ce cours, pour qui veut approfondir chaque domaine.

F

CONTACTS ET RESSOURCES

Les adresses ci-dessous sont celles des sites institutionnels à la date de rédaction ; elles peuvent changer et sont à vérifier avant usage.

Institutions camerounaises

Institution	Rôle dans le cours	Site
Contrôle Supérieur de l'État	Institution supérieure de contrôle, contrôle des SI (Ch. 4)	·
Chambre des Comptes de la Cour suprême	Contrôle des comptes ; SI par extension	·
ANTIC	Audit de sécurité des SI publics (loi n° 2010/012)	`www.antic.cm`
Ministère des Finances	Régime financier, applications financières	`www.minfi.gov.cm`
PSSFP, Université de Yaoundé II	Formation des auditeurs des finances publiques	·

Organisations internationales et professionnelles

Organisation	Apport	Site
INTOSAI	Normes ISSAI, GUID 5100	`www.intosai.org`
Initiative de développement de l'INTOSAI (IDI)	Manuels de mise en œuvre	`www.idi.no`
COSO	Référentiels de contrôle interne	`www.coso.org`
IIA	Normes de l'audit interne	`www.theiia.org`
ISACA	COBIT, certification CISA	`www.isaca.org`

Le cours

- NDAP SUKULU : portail des fiches et des labs, code de cours CAS3401.
- Contact de l'enseignant : maletyon@proton.me.

© *MaletYon*

RÉFÉRENCES BIBLIOGRAPHIQUES

[1] F. Benford, « The Law of Anomalous Numbers, » *Proceedings of the American Philosophical Society*, t. 78, n° 4, p. 551-572, 1938.

[2] R. Bhaskar, *A Realist Theory of Science*. Leeds : Leeds Books, 1975.

[3] Committee of Sponsoring Organizations of the Treadway Commission (COSO), *Internal control – integrated framework*, COSO, 2013.

[4] COSO, *Référentiel intégré de contrôle interne : principes de mise en œuvre et de pilotage*. Paris : Eyrolles, 2014, Traduction de l'IFACI et de PwC de l'édition 2013 ; copie dans le dossier Normes.

[5] COSO et Association of Certified Fraud Examiners (ACFE), *Fraude : guide de gestion du risque de fraude – synthèse*, Traduction française de la synthèse ; copie dans le dossier Normes, COSO, ACFE, déc. 2016.

[6] T. M. Cover et J. A. Thomas, *Elements of Information Theory*, 2e éd. Hoboken, NJ : Wiley-Interscience, 2006.

[7] D. R. Cressey, *Other People's Money: A Study in the Social Psychology of Embezzlement*. Glencoe (Illinois) : Free Press, 1953.

[8] J. C. Harsanyi, « Games with Incomplete Information Played by "Bayesian" Players. Part I–III, » *Management Science*, t. 14, n° 3, 5, 7, p. 159-182, 320-334, 486-502, 1967.

[9] A. R. Hevner, S. T. March, J. Park et S. Ram, « Design Science in Information Systems Research, » *MIS Quarterly*, t. 28, n° 1, p. 75-105, 2004.

[10] Initiative de Développement de l'INTOSAI, *Audit de conformité : manuel de mise en œuvre des ISSAI, version 1*, IDI, Oslo, 2021.

[11] INTOSAI, *GUID 5100 : Lignes directrices sur la vérification des systèmes d'information*, Organisation internationale des institutions supérieures de contrôle des finances publiques, 2019.

[12] ISACA, *COBIT 2019 Framework: Governance and Management Objectives*, ISACA, Schaumburg, IL, 2018.

[13] ISACA, *COBIT 2019 Framework: Introduction and Methodology*, ISACA, Schaumburg, IL, 2018.

[14] *ISO 19011:2018 – Lignes directrices pour l'audit des systèmes de management*, Troisième édition ; l'édition de 2011 comptait six principes, celle de 2018 en compte sept, Organisation internationale de normalisation, 2018.

[15] ISO/IEC, *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection – Information security management systems – Requirements*, Genève : ISO, 2022.

[16] ISO/IEC, *ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection – Information security controls*, Genève : ISO, 2022.

[17] D. Kahneman, *Thinking, Fast and Slow*. Farrar, Straus et Giroux, 2011.

[18] S. Kullback et R. A. Leibler, « On Information and Sufficiency, » *The Annals of Mathematical Statistics*, t. 22, n° 1, p. 79-86, 1951.

[19] I. Lakatos, « Falsification and the Methodology of Scientific Research Programmes, » in *Criticism and the Growth of Knowledge*, I. Lakatos et A. Musgrave, éd., Cambridge University Press, 1970, p. 91-196.

[20] B. Latour, *Reassembling the Social: An Introduction to Actor-Network-Theory*. Oxford University Press, 2005.

[21] *Loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité au Cameroun*, Version anglaise officielle : Law No. 2010/012 of 21 December 2010 relating to cybersecurity and cybercriminality in Cameroon, 21 déc. 2010.

[22] G. A. Miller, « The Magical Number Seven, Plus or Minus Two: Some Limits on Our Capacity for Processing Information, » *Psychological Review*, t. 63, n° 2, p. 81-97, 1956.

[23] Ministère des Finances du Cameroun, *Régime financier de l'État et des autres entités publiques*, Collection « Les essentiels de la réforme », présentation de la loi n° 2018/012 du 11 juillet 2018, MINFI, Yaoundé, 2023.

[24] T. E. Minka Mi Nguidjoï. « Modelling epistemic uncertainty in information systems audit: A trichotomous response instrument and its information-theoretic properties. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701270. adresse : https://hal.science/hal-05701270

[25] T. E. Minka Mi Nguidjoï. « Vers l'auditologie : un agenda de recherche en science du design pour une science appliquée de la réduction de l'incertitude dans l'audit des systèmes d'information. » Prépublication, licence CC BY-NC 4.0. HAL : hal-05701007. adresse : https://hal.science/hal-05701007

[26] J. F. Nash, « Non-Cooperative Games, » *Annals of Mathematics*, t. 54, n° 2, p. 286-295, 1951.

[27] J. von Neumann et O. Morgenstern, *Theory of Games and Economic Behavior*. Princeton University Press, 1944.

[28] M. J. Nigrini, *Benford's Law: Applications for Forensic Accounting, Auditing, and Fraud Detection*. Hoboken, NJ : Wiley, 2012.

[29] J. R. Norris, *Markov Chains*. Cambridge University Press, 1998.

[30] République du Cameroun, *Décret n° 2013/287 du 4 septembre 2013 portant organisation des services du Contrôle supérieur de l'État*, Texte lu dans sa version disponible, Yaoundé, 4 sept. 2013.

[31] C. E. Shannon, « A Mathematical Theory of Communication, » *Bell System Technical Journal*, t. 27, n° 3–4, p. 379-423, 623-656, 1948.

[32] H. A. Simon, *Models of Man: Social and Rational*. John Wiley & Sons, 1957.

[33] H. A. Simon, « The Architecture of Complexity, » *Proceedings of the American Philosophical Society*, t. 106, n° 6, p. 467-482, 1962.

[34] G. Simondon, *Du mode d'existence des objets techniques*. Paris : Aubier, 1958.

[35] The Institute of Internal Auditors, *Cadre de référence international des pratiques professionnelles de l'audit interne (CRIPP), édition 2017 : Normes et Code de déontologie*, IIA, 2017.

[36] The Institute of Internal Auditors, *Global Internal Audit Standards*, IIA, Lake Mary, FL, 2024.

INDEX

Analyse, 6
analyse, 6
Assurance limitée, 19
assurance limitée, 19
Assurance raisonnable, 19
assurance raisonnable, 19
Audit, 18
audit, 18
Auditologie, 154
auditologie, 154

Changement, 120
changement, 120
Constatation, 6
constatation, 6
Contrôle, 18
contrôle, 18
contrôle compensatoire, 33
Contrôle correctif, 30
contrôle correctif, 30
Contrôle détectif, 30
contrôle détectif, 30
Contrôle interne, 26
contrôle interne, 8, 26
Contrôle préventif, 30
contrôle préventif, 30
contrôles compensatoires, 33
Contrôles d'application, 30
contrôles d'application, 30
Contrôles généraux informatiques, 30
contrôles généraux informatiques, 30
Critère d'audit, 60
critère d'audit, 60

Divergence de Kullback-Leibler, 107
divergence de Kullback-Leibler, 107
Décomposition, 78
décomposition, 78
déficience, 43
Déficience du contrôle interne, 43
Déficience majeure, 44
déficience majeure, 44

Empreinte, 92
empreinte, 92
Entropie, 98
entropie, 98
Espace d'audit, 78
espace d'audit, 78
Espace de réponse trichotomique, 86
espace de réponse trichotomique, 86

fiche d'assertion, 79
Fraude, 132
fraude, 132

gabarit canonique, 78
Gestion des changements, 120
gestion des changements, 120

Inspection, 18
inspection, 18

limitation d'étendue, 104
limitations d'étendue, 104

matrice des risques et des contrôles, 39
Mission auditologique, 154
mission auditologique, 154

Normalisation, 126
normalisation, 126
Norme professionnelle, 60
norme professionnelle, 60

observation, 103

plan de continuité, 122
Plan de continuité d'activité, 122
Population, 90

population, 90
Preuve d'audit, 88
preuve d'audit, 88
Profil, 32
profil, 32
Propriétaire d'application, 114
propriétaire d'application, 114

Questionnaire de contrôle interne, 40
questionnaire de contrôle interne, 40

Revue des habilitations, 116
revue des habilitations, 116
risque inhérent, 76
risque lié au contrôle, 76
Référentiel, 60
référentiel, 60

Système de contrôle interne, 26
système de contrôle interne, 26
Séparation des tâches, 32
séparation des tâches, 32

Taux d'incertitude, 98
taux d'incertitude, 98
Taux de conformité, 98
taux de conformité, 98
termes clés, viii
Test de cheminement, 41
test de cheminement, 41
Totaux de contrôle, 92
totaux de contrôle, 92
triangle de la fraude, 132

Vérification, 18
vérification, 18

Échantillon, 90
échantillon, 90

À propos de ce cours

Quand l'administration financière s'informatise, le contrôle interne ne disparaît pas : il passe du dossier papier aux droits d'accès, aux contrôles automatiques et aux journaux. Ce cours apprend à l'auditeur public à le suivre, à l'évaluer et à conclure sur son efficacité.

Il progresse en six parties, précédées d'un prologue : le contrôle interne et son évaluation, les institutions et les normes, la démarche de mission et la mesure de l'incertitude, l'évaluation domaine par domaine (accès, exploitation, applications, données, projets), un cas intégrateur, et une ouverture sur la recherche en auditologie.

Chaque notion est ancrée dans les normes internationales (INTOSAI, COSO, IIA, ISACA, ISO) et dans le droit camerounais, à commencer par le décret qui confie au Contrôle Supérieur de l'État le contrôle des systèmes d'information. Le cours s'adresse aux vérificateurs, juges des comptes, inspecteurs, contrôleurs financiers et auditeurs internes du secteur public.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information

Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information